

CEN/CLC/JTC 13

Date: 2026-05-12

prEN 40000-1-4

Secretariat: DIN

WI Number: JT013091

Cybersecurity requirements for products with digital elements – Generic Security Requirements

ICS:

CCMC will prepare and attach the official title page.

Contents

European foreword.....	6
Introduction	7
1 Scope	9
2 Normative references.....	9
3 Terms and definitions	9
3.1 Access control mechanism.....	9
3.2 Authentication.....	9
3.3 sensitive assets.....	10
3.4 audit logging.....	10
3.5 Monitoring	10
3.6 Confidential cryptographic key.....	10
3.7 User Data	10
4 General.....	10
4.1 How to select appropriate controls.....	14
5 Essential requirements.....	14
5.1 (a) Vulnerability Assessment (M47: Round 1)	14
5.1.1 Description	14
5.1.2 Mapping threats and security objectives.....	15
5.1.3 Mapping with technical controls	18
5.2 (b) Secure Configuration	19
5.2.1 Description	19
5.2.2 Mapping threats and security objectives.....	19
5.2.3 Mapping with technical controls	25
5.3 (c) Security Updates	26
5.3.1 Description	26
5.3.2 Mapping threats and security objectives.....	26
5.3.3 Mapping with technical controls	30
5.4 (d) Access Control	31
5.4.1 Description	31
5.4.2 Mapping threats and security objectives.....	32
5.4.3 Mapping with technical controls	35
5.5 (e) Confidentiality protection.....	36
5.5.1 Description	36
5.5.2 Mapping threats and security objectives.....	36
5.5.3 Mapping with technical controls	41
5.6 (f) Integrity protection	42
5.6.1 Description	43
5.6.2 Mapping threats and security objectives.....	43
5.6.3 Mapping with technical controls	44
5.7 (g) Data minimization.....	45
5.7.1 Description	45
5.7.2 Mapping threats and security objectives.....	46
5.7.3 Mapping with technical controls	49
5.8 (h) Availability	50
5.8.1 Description	50
5.8.2 Mapping threats and security objectives.....	50
5.8.3 Mapping with technical controls	54
5.9 (i) External impact protection.....	55
5.9.1 Description	55

5.9.2	Mapping threats and security objectives.....	55
5.9.3	Mapping with technical controls.....	57
5.10	(j) Attack surface minimization	58
5.10.1	Description	58
5.10.2	Mapping threats and security objectives.....	58
5.10.3	Mapping with technical controls	59
5.11	(k) Reduce impact of incident.....	60
5.11.1	Description	60
5.11.2	Mapping threats and security objectives.....	60
5.11.3	Mapping with technical controls	61
5.12	(l) Logging and Monitoring	61
5.12.1	Description	61
5.12.2	Mapping threats and security objectives.....	61
5.12.3	Mapping with technical controls	62
5.13	(m) Data Deletion.....	63
5.13.1	Description	63
5.13.2	Mapping threats and security objectives.....	63
5.13.3	Mapping with technical controls	67
6	TO BE DELETED.....	67
7	Technical Controls	68
7.1	[ACM] Access control mechanism.....	68
7.1.1	[ACM-1] Void	68
7.1.2	[ACM-2] Access control mechanisms (Appropriate access control mechanisms)(EN 18031) (MERGE ACM-1 ACM2)	68
7.2	[AUM] Authentication mechanism.....	71
7.2.1	[AUM-1] Authentication mechanisms (EN 18031) (VOID)	71
7.2.2	[AUM-2] Appropriate authentication mechanisms (EN 18031).....	71
7.2.3	[AUM-3] Authenticator validation (EN 18031).....	74
7.2.4	[AUM-4] Changing authenticators (EN 18031).....	76
7.2.5	[AUM-5] Password strength (EN 18031)	77
7.2.6	[AUM-6] Brute force protection (EN 18031)	79
7.3	[SUM] Secure Update Mechanism (EN 18031)	81
7.3.1	[SUM-1] Updateability	81
7.3.2	[SUM-2] Secure updates Integrity and Authenticity (EN 18031)	85
7.3.3	[SUM-3] Automated updates (EN 18031)	87
7.3.4	[SUM-4] Postponement of Software Updates (NEW)	89
7.3.5	[SUM-5] Opt-out from automatic software installation(NEW)	91
7.3.6	[SUM-6] Automatic Updates by default (NEW)	92
7.3.7	[SUM-7] User Security Update Notification(NEW).....	93
7.4	[SSM] Secure storage mechanism (EN 18031).....	95
7.4.1	[SSM-1] Secure storage mechanisms (EN 18031).....	95
7.4.2	[SSM-2] Integrity protection for secure storage mechanisms (EN 18031)	96
7.4.3	[SSM-3] Confidentiality protection for secure storage mechanisms (EN 18031).....	99
7.4.4	PROPOSAL: [SSM-4] Authenticity of data on removable media.....	101
7.5	[SCM] Secure communication mechanism	101
7.5.1	[SCM-1] <i>Applicability of secure communication mechanisms</i> (EN 18031) VOID	101
7.5.2	[SCM-2] Appropriate integrity and authenticity protection for secure communication mechanisms (EN 18031)	101
7.5.3	[SCM-3] Secure communication mechanisms with confidentiality protection (EN 18031).....	106

7.5.4	[SCM-4] Replay protection for secure communication mechanisms (EN 18031)	110
7.6	[LGM] Logging mechanism (18031)	112
7.6.1	[LGM-1] Logging mechanisms (18031)	112
7.6.2	[LGM-2] Persistent storage of log data (18031).....	114
7.6.3	[LGM-3] Minimum number of persistently stored events (18031).....	116
7.6.4	[LGM-4] Time-related information of persistently stored log data (18031).....	117
7.6.5	[LGM-5] Disabling logging (NEW).....	119
7.6.6	[LGM-6] Exclude sensitive personal information (NEW).....	121
7.7	[DLM] Deletion mechanism (EN 18031)	122
7.7.1	[DLM-1] Secure Data deletion mechanisms.....	122
7.8	[UNM] User notification mechanism	125
7.8.1	[UNM-1] User notification mechanisms (EN 18031-2)	125
7.8.2	[UNM-2] Appropriate user notification content (EN 18031-2).....	126
7.9	[RLM] Resilience mechanism.....	128
7.9.1	[RLM-1] Resilience mechanism.....	129
7.9.2	[RLM-2] Recovery from incidents	131
7.9.3	[RLM-3] Network prioritization.....	133
7.9.4	[RLM-4] Resource prioritization	134
7.9.5	[RLM-5] Resource management.....	136
7.9.6	[RLM-6] Control system backup.....	138
7.10	[NMM] Network monitoring mechanism (EN 18031)	139
7.10.1	[NMM-1] Network monitoring mechanisms (EN 18031).....	140
7.11	[TCM] Traffic control mechanism (EN 18031).....	142
7.11.1	[TCM-1] Traffic control mechanism	142
7.12	[CCK] Confidential cryptographic keys	144
7.12.1	[CCK-1] Appropriate CCKs (EN 18031).....	144
7.12.2	[CCK-2] CCK generation mechanisms (EN 18031).....	147
7.12.3	[CCK-3] Preventing static default values for preinstalled CCKs (EN 18031).....	150
7.13	[GEC] General Equipment Capabilities	151
7.13.1	[GEC-1] Up-to-date software and hardware without known exploitable vulnerabilities (EN 18031 - Title modified - publicly).....	151
7.13.2	[GEC-2] Limit exposure of services via related network interfaces (EN 18031)	158
7.13.3	[GEC-3] Configuration of optional services and the related exposed network interfaces (EN 18031).....	160
7.13.4	[GEC-4] Documentation of exposed network interfaces and exposed services via network interfaces (EN 18031).....	162
7.13.5	[GEC-5] No unnecessary external interfaces (EN 18031)	163
7.13.6	[GEC-6] Input validation (EN 18031)	165
7.13.7	[GEC-7] Documentation of external sensing capabilities (EN 18031).....	167
7.13.8	[GEC-8] Product Integrity (EN 18031)	169
7.13.9	[GEC-9] Secure startup configuration (NEW)	170
7.13.10	[GEC-10] Factory Reset (NEW)	171
7.13.11	[GEC-11] Exploit mitigation mechanisms (NEW)	173
7.13.12	[GEC-12] No Unneeded Software Components (NEW)	174
7.13.13	[GEC-13] Report on possible unauthorised access and corruption (NEW)	176
7.14	[CRY] Cryptography	178
7.14.1	[CRY-1] Best practice cryptography (EN 18031)	179
7.15	[DTM] Data minimization.....	181
7.15.1	[DTM-1] Data minimisation in relation to intended purpose (NEW).....	181
7.15.2	[DTM-2] Default Data Processing Minimisation (NEW)	182
7.15.3	[DTM-3] Configurable Controls for Optional Data Processing (NEW)	185

7.16	[MON] Monitoring of security activities (NEW)	187
7.16.1	[MON-1] Monitor security relevant activities	187
7.16.2	[MON-2] Disable monitoring	189
7.17	[SPD] Secure Processed Data	190
7.17.1	[SPD-1] Secure Processed Data	190
7.18	[LIM] Limitation of Negative Impact on External Systems	194
7.18.1	[LIM-1] Egress traffic rate limiting and connection throttling (NEW)	194
7.18.2	[LIM-2] No unauthenticated reflection/amplification or open relay behaviour (NEW)	195
7.18.3	[LIM-3] Source-address integrity / anti-spoofing (NEW)	197
7.18.4	[LIM-4] Abuse-aware monitoring focused on external impact (NEW)	198
7.18.5	[LIM-5] Quarantine / degraded networking mode to minimise harm (NEW)	200
7.18.6	[LIM-6] Per-connected-device fairness controls for hubs/gateways (NEW)	201
Annex A (informative) Mapping to the CRA essential requirements		203
Annex B (informative) Mapping between the RED 18031 and the 40000-1-4 controls		204
Annex C (informative) (T.B.D.) Mapping(s) other security control standards (e.g., EN 303645) to the 40000-1-4 controls		205
Annex D (informative) Working Template to convert 18031 into 40000-1-4 requirements (TO BE DELETED)		206
Annex K (normative) Annex K		213
D.1	K.1 State of the Art Cryptography (CRY-SOTA)	213
D.1.1	K.1.1 Requirement	213
D.1.2	K.1.2 Assessment criteria	214
D.2	K.2. Crypto agility	218
D.2.1	K.2.1 Requirement	218
D.2.2	K.2.2 Assessment criteria	219
Bibliography		220

European foreword

This document (prEN 40000-1-54:2026) by Technical Committee CEN-CLC/JTC 13 "Cybersecurity and Data Protection", the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a mandate given to CEN, Cenelec, ETSI by the European Commission and supports essential requirements of EU Directive(s).

For relationship with EU Directive(s), see informative Annex ZA, which is an integral part of this document.

Introduction

Warning — THIS DOCUMENT IS CURRENTLY BEING DRAFTED AND HAS MANY EDITORIAL NOTES CAPTURED IN NORMAL NOTES, EXAMPLE AND WARNING SECTIONS. ALL OF THESE WILL BE REMOVED WHEN EDITING IS COMPLETED!

PT2 has the following recommendations for the HAS assessment:

- **Clause 7 should be the focus**, the majority is included but assessment criteria are missing; Several approaches have been taken, for example some have 18031 requirements including applicability and appropriateness, in other sections we combined applicability and appropriateness or have none. The preference is to use the template in Annex D as a guidance to transfer the 18031 requirements to the 40000-1-4 requirements.
- **Clause 6 is empty and will be removed** (still in there to align with the references)
- **Clause 5 should be taken entirely as working notes.**
- It contains sections called '**Gaps to be solved**' with additional discussion notes and warning sections marked as "**WARNING — Vertical analysis and highlights:**" that contain the analysis of the vertical standards which are used to discuss whether they can be considered for inclusion or used as a guidance for the controls.
- The WG still needs to decide if:
 - we might remove clause 5 entirely as most of the information is already expressed in the TR 40000-1-5
 - Clause 5 might be reworked completely to address the security problem definition and security objectives if all is not covered in the TR 40000-1-5
 - Or we might move parts to an informative annex and still remove this clause 5.
- **Informative Annex A** will provide the mapping between the essential requirements, security objectives and security controls, which we might format similar to an Annex Z. The information is currently still located in clause 5.

Vigilance is needed from manufacturers to improve the overall resilience against cybersecurity threats related to the use of products with digital elements, hereafter also referred to as 'products', and the growing ability of malicious threat actors to cause harm to users, organizations, and society.

The technical security requirements presented in this baseline standard are developed to improve the ability of products to protect against cybersecurity threats.

It is important to note that to achieve the overall cybersecurity of products, defence in depth best practices will be needed by both the manufacturer and user. In particular, no single measure will suffice to achieve the given objectives, indeed achieving even a single security objective will usually need a suite of mechanisms and measures.

The selection and maintenance of appropriate technical controls is based on cybersecurity risk management as for instance defined in [Error! Reference source not found.](#) and other frameworks like [Error! Reference source not found.](#) when addressing the essential requirements.

The technical controls listed in Clause 7 are only indicative possibilities, as there are other possibilities that are not listed, and will not be sufficient unless the mechanisms and measures chosen are implemented in a coordinated fashion.

EN 40000-1-4 is part of a set of standards requested by standardization request M/606 to support CRA (Regulation (EU) 2024/2847) compliance that have the following structure:

- Horizontal documents for cybersecurity requirements relating to the properties of products with digital elements, including:
 - prEN 40000-1-1, Cybersecurity requirements for products with digital elements - Part 1-1: Vocabulary;
 - [Error! Reference source not found.](#) Cybersecurity requirements for products with digital elements - Part 1-2: Generic Cybersecurity Principles, Product Risk Management Element and Product Lifecycle Activities for Cyber Resilience;
 - [Error! Reference source not found.](#) Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling;
 - EN 40000-1-4, Cybersecurity requirements for products with digital elements - Generic Security Requirements. (this document);
 - TR 40000-1-5, Cybersecurity requirements for products with digital elements -Threats and Security Objectives.
- Vertical standards for cybersecurity requirements relating to the properties of products with digital elements covering product category specific requirements and requirements on vulnerability handling.

Vertical standards can build on this framework document by augmenting or requiring specific technical cybersecurity controls that need to be implemented to address specific risks.

1 Scope

This document supports the selection and application of appropriate technical cybersecurity control requirements by identifying common threats and security objectives to aid in the products cybersecurity risk assessment to cover all risks.

The requirements include implementation categories which specify alternative methods to implement the security control objective.

For the purposes of this document, all references to the term ‘product’ shall be deemed to include Remote Data Processing Solutions (RDPS). Any explicit reference to RDPS is provided solely to prompt consideration of possible RDPS-specific aspects.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 40000-1-1, *Cybersecurity requirements for products with digital elements - Vocabulary*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in Regulation (EU) 2024/2847 (CRA), prEN 40000-1-1 and the following apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <http://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

3.1 Access control mechanism

equipment functionality to grant, restrict or deny access to specific equipment’s *resources*

Note 1 to entry: Access to specific equipment’s resources can amongst others be:

- reading specific data; or
- writing specific data to equipment’s persistent storage; or
- performing a specific equipment functionality such as recording audio.

3.2 Authentication

provision of assurance that an *entity* is who or what it claims to be

Note 1 to entry: An entity can amongst others claim to be:

- a specific human, owner of a user account, device, or service; or
- a member of specific groups such as an authorized group to access a specific equipment’s resource; or
- authorized by another entity to access a specific equipment’s resource.

3.3 sensitive assets

data that if revealed can compromise the security properties of the product itself or the stakeholders that are involved with the production and use of the product itself

3.4 audit logging

logs recording user activities, exceptions, and information security events, where logs are kept for an agreed period to assist in future investigations and access control monitoring

generate and preserve tamper-resistant records of security-relevant events;

[SOURCE: [Error! Reference source not found.](#), 3.3]

3.5 Monitoring

continuous or repeated checking, supervising, critically observing, measuring or determining the status of a system to identify variance from an expected performance level or baseline, intended to control the system

Note 1 to entry: *continuously analyze telemetry (including audit logs) to detect and alert on suspected security breaches in time to respond.*

[SOURCE: [Error! Reference source not found.](#), 3.12]

3.6 Confidential cryptographic key

confidential security parameter, excluding passwords, which is used in the operation of a cryptographic algorithm or cryptographic protocol

[SOURCE: [Error! Reference source not found.](#), 3.9]

3.7 User Data

TBD (include data, metadata, and settings) - in relation to DLM-2

4 General

This document uses the concept of mechanisms to instruct the user of this document when to apply certain security measures. Mechanisms address the applicability and appropriateness through a set of requirements including assessment criteria. An applicable/non-applicable decision is taken for each of the items specified. If applicable it is followed by a pass/fail appropriateness decision for each of the items specified. For example, when checking the applicability of a requirement on external interfaces, then the decision whether the requirement needs to be fulfilled is determined for each external interface independently.

The mechanisms and their application are documented using the structure shown in the table below:

NOTE 1 Contributor note: See also Alexej comments in email 3rd June 2025 in 002 Contributions folder on the Portal.

Table 1 — Requirements structure

Table 1

Clause #	Title		Description on how to apply this document
6.x	XXX Mechanism		Mechanism for each specific item (e.g., external interface or security asset)
6.x.1	XXX-1 Applicability of mechanisms		Applicability of the mechanism
6.x.y.1	Requirement		For each specific item for which the mechanism is required as determined by XXX-1. NOTE Some chapters contain multiple requirements, which leads to slight deviations in terms of numbering.
6.x.y.2	Rationale		
6.x.y.3	Guidance		
6.x.y.4	Assessment criteria		
6.x.y.4.1		Assessment objective	
6.x.y.4.2		Implementation categories	
6.x.y.4.3		Required information – Richard proposal: Potential for deletion - Captured in PT1 Architectural Description?	
6.x.y.4.4		Conceptual assessment	
6.x.y.4.2		Functional completeness assessment	
6.x.y.4.3		Implementation functional sufficiency assessment Richard proposal: to delete per proposal slides.	

NOTE 2 Rusne proposal: Alternative structure provided by Rusne:

Table 2

Clause #	Title	Description
6.X	ESR requirement	Essential requirement from the CRA text and Standardization request context
6.X.1	Category of the control	
	Assets	Data, personal data, hardware, software, people, physical security
	Security objectives	The security objectives shall define the scope of the target product or

		service and the security properties it is intended to address, based on the essential requirements		
	Threats			
	Accessibility requirements			
6.x.1.1	Requirement	For each specific item, determine and assess if the mechanism is required using risk assessment methodology (guidance PT1). For each specific item for which the mechanism is required as determined by XXX-1, determine and assess if the supporting requirement needs to be implemented (there might be specific conditions, for instance if the equipment is a toy) and if it needs to be implemented, whether it is implemented properly. NOTE Some chapters contain multiple requirements, leading to slight deviations in numbering.		
	Requirements related to secure software development, if applicable, i.e. software is used			
6.x.1.2	Rationale			
6.x.1.3	Guidance			
6.x.1.4	Assessment objectively verifiable criteria			
	Assessment process: set of evaluation procedures required to assess the target against the technical specification requirements identified previously, the tests and/or assessment methods are reproducible			
6.x.1.4.1				Assessment objective
				Security objective
				Applicable technical specification requirements
				Applicable accessibility requirements
6.x.1.4.2				Implementation categories
6.x.1.4.3				Required information
				Required security level assessment
6.x.1.4.4				Conceptual assessment
6.x.1.4.5				Functional completeness assessment
6.x.1.4.6				Functional sufficiency assessment
		Expected evaluation results		

NOTE 3 Editorial note: suggested required information from Alexej proposal 28th May 2025

Implementation categories

NOTE 4 Meinhard note:

<Specific Technology related assessments Aspects?>

<Example from Meinhard: Impl. Cat. can be useful for specific product types and specific protocols>

(Meinhard) I'm not yet sure if it shall be different. We have discussed that EN18031 is asking much of documentation and may be over the top. On the other hand does it really harm? I would start by copying the EN18031 acceptance criteria and reduce if possible.

The assessments are conducted by examining the documented assessment cases, not all assessment cases might be provided for every mechanism:

- Conceptual assessment

NOTE 5 Editorial note: suggested required information from Alexej proposal 28th May 2025

- <Examine if the provided documentation and rationale provide the required evidence for having or not a certain security control / Security Objective>
- <Review TARA Attack Trees and mitigations decisions related to the security objective in Scope of this chapter (Documented Requirements and Risks Treatment Results)>

NOTE 6 Proposed wording based upon PT1 definition:

Examine if the provided Architectural Description [from PT1] is complete.

- Functional Completeness assessment

Examine if the implementation meets the requirements

NOTE 7 Editorial note: suggested required information from Alexej proposal 28th May 2025

- <Are all risks related to the Threat in scope identified?>
- <Are all risks related to the Threat in scope documented?>
- <Are all risks related to the Threat in scope threatened?>

Required information lists the information to be provided through technical documentation. This document does not require each required information element to be provided as a separate document.

NOTE 8 Editorial note: suggested required information from Alexej proposal 28th May 2025

Information needed to do assessment e.g. Architecture of a product (e.g. Block Diagram, data flow, others), i.e. the architecture description required by PT1 risk assessment.

NOTE 9 Example provided by RM per separate PT Way Forward slides presented 18 and in requirement CRY in this document.

Specification of Acceptance Criteria for assessed product

- List of Assets
- List of Threats
- TARA Results
- Residual Risk Level for the available Threats/Assets

The placeholders are used as follows:

- <Type>: “Info” or “Just” to indicate the kind of required documentation which could be information” or justification.
- <CategoryName>: Name of the category for the required documentation. A <CategoryName> could contain additional Sub-Category-Names divided with ".".
- <ImplementationCategoryName>: Name of the implementation category, which describes the defined implementation.
- <AssessmentUnitName>: Name of the assessment unit for a specific implementation category.

<MechanismAbbreviation-<Nr>>: Abbreviation of the name from the specific requirement which belongs to the assessment criteria.

4.1 How to select appropriate controls

Warning — We need to explain either here or in the introduction, the general approach towards selecting controls based on risk assessment and applicability, where applicability is typically fact-based

5 Essential requirements

Warning — ALL WARNING SECTIONS ARE EDITORIAL NOTES AND WILL BE REMOVED

CREATING THE MAPPING BETWEEN THE ESSENTIAL REQUIREMENT AND THE SECURITY OBJECTIVES ONLY THE TEXT FOR NOW.

5.1 (a) Vulnerability Assessment (M47: Round 1)

Warning — (a) be made available on the market without known exploitable vulnerabilities;

5.1.1 Description

The objective of this requirement is to have in place mechanisms that demonstrate due diligence into the development process of the product itself in order to have evidence that the product was tested for known exploitable vulnerabilities before placing into the market. The European vulnerability database is a way to assist manufacturers in detecting known exploitable vulnerabilities in their products. In a sense this requirement is already part of the Vulnerability handling requirements in which this activity can be intended as a subset of the CRA's Part II Vulnerability handling requirements essential requirement (1) which is related to the identification and documentation of the vulnerabilities contained into the product.

NOTE This is not an activities that is happening one shot but it is recurrent as a best practice and should be part of the regular testing process of the Vulnerability handling.

The reference on EN 40000-1-2 / EN 40000-1-3 it is essential to demonstrate this requirement.

Risk assessment is essential not all the vulnerabilities are exploitable under practical operating conditions - this needs to be justified!

- Please look at the example in the FAQ
- For example, a smartphone may have a vulnerability that would enable an attacker to bypass security (e.g. skipping password checks); but in order to achieve this, the attacker needs physical access to the device and invasive physical tampering (e.g. using of a laser to cause a glitch) to make use of the exploit. On the

basis of its risk assessment, the manufacturer may conclude that this would not be considered an exploitable vulnerability because it could not reasonably be exploited in practical operational conditions.

- **Risks:**
- Intentional or unintentional exploit of known weaknesses/vulnerability: this has various level of criticality that depends on the possible chain of the attack started and criticality of the function exploited or exploitable in operating conditions.
- coming from hardware and software vulnerabilities :
- software bugs
- weak or missing security controls
- configuration exploits
- outdated software
- insecure communication protocols
- legacy software

5.1.2 Mapping threats and security objectives

Table 3

Threats	Security Objectives
Threat.KnownVulnerabilityExploitation: An attacker exploits known, not fixed vulnerabilities in a product. The unavailability of a manufacturer patch, combined with known vulnerability/exploitability, makes this an important attack path in terms of the affected base and ease of vulnerability detection. Warning — Proposal: Threat.Vulnerability.Known.Exploitable	SO.VulnerabilityManagementProcess: All known exploitable vulnerabilities in the product have been addressed/mitigated when making the product available on the market.

Gaps to be solved

EXAMPLE (1)

This essential requirement is covered by the following EN 18031 requirements:

- [GEC-1] Up-to-date software and hardware with no publicly known exploitable vulnerabilities

The majour connection that needs to happen is to link the concept of EN 18031 that is referring to **known exploitable vulnerabilities**, to the one in the CRA definition of exploitable vulnerability:

- ‘vulnerability’ means a weakness, susceptibility or flaw of a product with digital elements that can be exploited by a cyber threat (Article 3(40))
- ‘exploitable vulnerability’ means a vulnerability that has the potential to be effectively used by an adversary under practical operational conditions (Article 3(41))

Please refer to:

- <https://digital-strategy.ec.europa.eu/en/library/cyber-resilience-act-implementation-frequently-asked-questions>
- 4.2.2 How can a manufacturer ensure that a product is free from all vulnerabilities?
- 4.2.3 How should manufacturers deal with known exploitable vulnerabilities discovered after a product has been placed on the market but before reaching its final user?

(2)

Another concern to be solved is the concept of **Known** - Known by who?

- Gabriel and Robert will propose a resolution

(3)

Is **SO.VulnerabilityManagementProcess** still a good name/ for this security objectives considering the scope of this specific essential requirement

Nonetheless, as the CRA also establishes vulnerability handling requirements that apply during a product's support period, manufacturers shall, in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, in accordance with Annex I, Part II, point (2). For example, given the risks posed by the newly discovered exploitable vulnerabilities, the laptop manufacturer establishes that a security update is necessary to address those vulnerabilities. The manufacturer may be required to provide a security update for the laptop, as soon as it is put into operation by its user

(4)

Consider a link to EN 40000-1-3 as prerequisite and the idea is to:

- a) Starts all from the risk assessment to evaluate risk and eventual mitigation controls and factors
 - b) Check the vulnerability or weaknesses on the product to identify vulnerabilities
 - 1) check on a known database on actively exploited (*)
 - i) explicitly reference for Software Composition Analysis activity and Network scanning that are linked with at least the EUVD
 - 2) Demonstrate means that they have in place to mechanism
 - i) Discover with the mean of CVD as in EN 40000-1-3 from external parties
 - ii) Discover internally with regular testing as described in the 40000-1-3
 - 3) Reference EN 40000-1-3 with a close look at: [RCP-2] Monitoring, [RCP-3] Potentially impacted software components, [RCP-4] Potentially impacted hardware components
 - 4) Demonstrate that there is a way to monitor for incidents - demonstrating logging and monitoring capabilities as in this standard.
 - c) Do an analysis as per EN 40000-1-3 that check if the vulnerability of weaknesses can be used in practice and if yes address as established in the risk assessment
 - 1) This phase can be called also **exploitability assessment**
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
 - Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- **EN 304 617 Browser** - makes reference to 5.7 EMB-REQ-9 (JavaScript bridge security review), EXT-REQ-4 (Manifest validation), EXT-REQ-17 (Extension signature validation)
- It is too specific and no direct references to prEN 40000-1-3
- **EN 304 618 Password manager** - There is ANNEX but I cannot find the mapping with Essential requirement (a)
- **EN 304 619 Antivirus software** - I see that everything points back to EN 40000-1-3 in the future
- **EN 304 660 Virtuak Private Networks Part 1** - seems that there is a pointer to NKEV, SSSD, SCUD, NUTI, LOGG, but we have 5.2.2.4 MI-KEVM: Documentation of mitigation of known exploitable vulnerabilities where it referenced to prEN 40000-1-3. there may be some gaps here to be filled - why MI-KEVM not mentioned in the Annex A? and what is the overlap between prEN 40000-1-3 and NKEV, SSSD, SCUD, NUTI, LOGG
- **EN 304 621 Network Management Systems there is an**
- **Annex A (informative):** Mapping with essential requirements of the CRA where can be found a mapping with the essential requirements .
- There is a section hinting to automateable and freely-usable vulnerability scanners.
- **EN 304 622 Security Information and event management:**
- same as EN 304 621
- **EN 304 623 Boot Managers:** has "Annex A (normative): Relationship between the present document and the essential requirements of EU Regulation 2024/2847" the clauses identified are 5.12.1, 5.12.2, 6.1 - essentially pointing back to Vulnerability management. The prEN 40000-1-3 (Vulnerability Handling) is referenced as informative. There are duplications
- **EN 304 624 Public key infrastructure and digital certificate issuance software:** has an annex:: Annex A Mapping with essential requirements of the CRA - point only to EN 40000-1-3.
- **EN 304 625 Network Interfaces:**
- same as EN 304 660 Virtuak Private Networks Part 1
- **EN 304 626 Operating Systems:**
- same as EN 304 660 Virtuak Private Networks Part 1
- **EN 304 627 Routers modems and switches -**
- There is a section 5.3 referring to prEN 40000-1-3 but requirements has been extended with duplication compared to the content already in 40000-1-3
- **EN 304 635 Virtualisation and Container Execution Systems: see annex Annex A (informative):** Relationship between the present document and the requirements of Regulation (EU) 2024/2847. Different correlation of requirements...
- **EN 304 636 Firewalls intrusion detection and prevention systems - no content on gitlab**
- same as EN 304 626 Operating Systems
- EN 4000X Smart card applications of secure elements - no content on gitlab

NOTE M45: Suggestion of improvement

- d) Consider testing before making available: Angelo - make a reference to **PT3**, you can include reference to the regular testing activities that need to be executed - in relation with the specific activity
 - e) Simon: actual exploit is one way to be aware about the known explaintable vulnerability - exploit in the wild - when an incident occurs - we can have more guidance on that
 - f) **Thomas: Standard not already published - voice assistant** In accordance with [ToDo:PT3 Reference] the product shall be tested prior to making available on the market to ensure that there are no insufficiently mitigated known exploitable vulnerabilities.
 - g) The entity of known exploitable vulnerability could be"
 - 1) vulnerability in the EUVD - EU Vulnerability Database
 - 2) an incident occurred
 - 3) a weaknesses - in terms for example of a missing control or similar
 - 4) discovered in internal testing (on hw and sw - eg.)
 - 5) discovered because reported with the CVD
 - h) Can we check if we need an additional SO or specific threat - because in TR we looked only at direct threats - no indirect threats has been investigated
 - i) Alessio and Angelo: we can explicitely mention that as part of the regular test before the placing on the market we need to add a clarification that the manufacturer needs to create a test plan based on the product criticality and the risk as already captured in PT3 - please refer to **[PRE-9] Planning regular test and reviews**
- We expect to discuss the finalized version of this essential requirement on meeting M47 27 January 2026 - will be discussed and ready to be finalized in the morning session.
- Anyone interested to contribute - rmpingel@rockwellautomation.com

5.1.3 Mapping with technical controls**5.1.3.1 SO.VulnerabilityManagementProcess**

The list of technical controls that are applicable:

- 7.13.1 [GEC-1] Up-to-date software and hardware with no known exploitable vulnerabilities (EN 18031)

EXAMPLE

- It is important to consider the process part (Vulnerability management activities) PT1/PT3
- Test for known vulnerabilities
- Regular tests that involves as minimum known vulnerabilities testing / vulnerability assessment

5.2 (b) Secure Configuration

Warning — (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;

5.2.1 Description

The objective of this requirement is to have in place mechanisms that demonstrate due diligence into the making available on the market products with secure by default configuration. This include the possibility to reset the product to its original state.

NOTE ISO-IEC TR 6114

- **Misconfigurations:** Intentional or unintentional introduction of errors or flaws into the system settings or parameters governing the intended function and/or performance of a product.

Final default configuration risks may come from:

- Unwanted exposed interface software and hardware
- The configurations data are not appropriately secured
- Improper permissions and lack of segregation
- Default or weak credentials
- Unsecure protocols
- Unsecure crypto and hashing functions
- Unsecure startup configuration - first time configuration
- Identification of tampering of critical configuration data
- Isolation
- Missing or weak reset functionality
- Missing or insecure deletion mechanisms (part of essential requirement - m)
- outdated and vulnerable firmware or software (part of essential requirement - a)
- Data minimization

5.2.2 Mapping threats and security objectives

Table 4

Threats	Security Objectives
Threat.UnsecureDefaultConfigExploitation: An attacker exploits a weakness in a product's default configuration. The assumption that many users might be permanently operating their unit in this configuration makes weak defaults an important attack path.	SO.SecureDefaultConfiguration: The product is provided with a secure default configuration at the moment that is available on the market.

Threats	Security Objectives
Warning — Proposal: Threat.Configuration.Default.Weak:	
Threat.StartupConfigExploitation: An attacker exploits an insecure configuration during the initial commissioning of the product. Warning — Proposal: Threat.Configuration.InitialCommissioning.Insecure:	SO.SecureStartupConfig: The product provides a secure configuration for the initial commissioning.
Threat.MissingResetFunctionalityConfigExploitation: An attacker exploits a vulnerability in a product introduced by an individual weak configuration due to the missing reset functionality provided by the product that prevents it from reverting to its original secure default configuration. Warning — Proposal: Threat.Configuration.Reset.Missing	SO.FactoryReset: The product can be restored to its original state, including the deletion of all configurations, data, and installed software deviating from the factory default, except deviations due to security updates.
Threat.MissingResetFunctionalityMalwareExploitation: An attacker exploits a vulnerability in a product introduced after it is made available on the market by installing malware that is removable by a factory reset mechanism . Warning — This seems a problem in the deletion phase and that the mechanisms of factory reset is not working properly.	
Threat.MissingResetFunctionalityDataExtraction: An attacker extracts remaining data from a product due to missing possibility to reset the product to its original state (e.g., after disposal of a product). Warning — This seems a problem of secure deletion as it is managed in essential requirement (m).	

Gaps to be solved/notes

EXAMPLE (1)

- “Secure-by-Default” means products are resilient against prevalent exploitation techniques out of the box without additional charge. Software should start in a secure state without requiring extensive user configuration, ensuring the default settings are always the most secure option
- OWASP Top 10 Proactive Controls -
- C5: Secure By Default Configurations
- SA-8(23): Secure Defaults
- Eg. Deactivate insecure protocols / no default passwords / least privilege
- Gitlab: <https://labs.etsi.org/rep/stan4cra>

- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

— EN 304 617 Browser -

- DOM-0-REQ-1 through DOM-0-REQ-6 (**Full isolation by default**), ENC-0-REQ-1 through ENC-0-REQ-23 (**Full encryption by default**), DOM-REQ-5 (**SameSite=Lax default**), DOMREQ-12 (**document.domain restricted by default**), ENC-REQ-16 (**HTTPS-first mode**), UPD0-REQ-1 (**Automatic updates enabled by default**), SYS-0-REQ-1 through SYS-0-REQ-13 (**Sandboxed by default**), EMB-0-REQ-1 through EMB-0-REQ-7 (**Isolated by default**)

— EN 304 618 Password manager -

- MPA-REQ-2; MPA-REQ-6; AFF-REQ-1; AFF-REQ-2;
- MPA-REQ-2 [MPA-0→MPA-T2]: SHALL enforce minimum master password complexity
- MPA-REQ-6 [MPA-0→MPA-T3]: SHALL mask master password entry fields.
- FF-REQ-1 [AFF-0→AFF-T1,AFF-T3]: SHALL validate domain match before auto-fill
- F-REQ-2 [AFF-0→AFF-T1]: MAY suggest credentials for related domains, but filling needs explicit user 1220 interaction in that case

— EN 304 619 Antivirus software -

- 5.2.2 Secure by Default Configuration
- REQ-SDC-01: The product shall implement mechanisms to detect virus and malware contained in the files, label the infected files, and then notify user to delete the infected ones.
- REQ-SDC-02: The product shall implement mechanisms to detect runtime virus and malware, label the infected software and then notify user to uninstall the infected software.
- REQ-SDC-03: The product shall follow the security-by-default principle and be shipped with security hardened default settings, activate minimal security functions including automatic updates and active real-time protection.
- REQ-SDC-04 The product shall detect virus employing signature-based techniques with the possibility to offer more complex and complete technologies based on reliable and updated signature database.
- REQ-SDC-05: The product shall detect malware employing evasion techniques, including code obfuscation, fileless malware, and polymorphic malware.
- REQ-SDC-06: The product shall not modify, affect or change the characteristics and security requirements of the OS hosting it.

— EN 304 660 Virtuak Private Networks Part 1 -

- ROUT, DNSL, EISO, TRAF
- 5.2.5 TR-ROUT VPN traffic routed only through VPN connection during VPN 1067 connection
- 5.2.9 TR-DNSL DNS leak prevention
- 5.2.10 TR-EISO: Endpoint isolation
- 5.2.11 TR-TRAF: No traffic through the node unless explicitly approved

- **EN 304 621 Network Management Systems -**
- 5.2.4 State-of-the-art cryptographic libraries
- **EN 304 622 Security Information and event management:**
- same as EN 304 621
- **EN 304 623 Boot Managers:**
- 5.3 Secure by Default Configuration
- 5.3.1 [RQ-DEFAULT-001] Requirement: The boot manager shall enable cryptographic validation by default.
- 5.3.2 [RQ-DEFAULT-002] Requirement: The boot manager shall not implement unauthorized or undocumented mechanisms that allow bypassing authentication or security controls.
- 5.3.3 [RQ-DEFAULT-003] Requirement: When passwords are used for authentication, the boot manager shall require the credentials to be established during initial deployment.
- 5.3.4 [RQ-DEFAULT-004] Requirement: The boot manager shall prevent automatic fallback to less secure boot modes
- [RQ-DEFAULT-005] Requirement: When a user interface is available, the boot manager shall provide a user-visible indication when a security-relevant protection is reduced or disabled.
- 5.3.6 [RQ-DEFAULT-006] Requirement: The boot manager shall support restoring the system to secure default configuration settings
- **EN 304 624 Public key infrastructure and digital certificate issuance software:**
- Essentially there is an entire section
- 5 Requirements for PKI products
- 31 59 5.1 Auditing
- 31 60 5.2 Secret management
- 33 61 5.3 Certificate issuance
- 34 62 5.4 Certificate status
- 36 63 5.5 Certificate renewal
- 37 64 5.6 Certificate re-key
- 37 65 5.7 Certificate modification
- 37 66 5.8 Certificate suspension and revocation
- 67 5.9 Certificate status services
- 8 5.10 Access control
- 69 5.11 Secure communication with external entities
- **EN 304 625 Network Interfaces: same as EN 304 660 Virtual Private Networks Part 1:**

- 5.2.5 ER-SDEF: Secure by default configuration
- 5.2.5.2 MI-ADEF: Authorization required by default to access security-relevant assets
- 5.2.5.3 MI-DPAH: Documentation of product assets accessible from host
- 5.2.5.4 MI-PDDI-1: Document how to protect access to debug/management interfaces
- 5.2.5.5 MI-PDDI-2: Protect or disable physical access to debug/management interfaces
- 5.2.5.6 MI-PDDI-3: Protect or disable local software access to debug/management interfaces
- 5.2.5.7 MI-PDDI-4: Protect or disable network access to debug/management interfaces
- 5.2.5.8 Mapping of mitigations to risk factors and security profiles
- **EN 304 626 Operating Systems:**
- similar as EN 304 660 Virtual Private Networks Part 1:
- 5.2.8 TR-SDEF: Secure by default configuration
- 5.2.8.2 MI-ADEF: Authorization required by default to access security-relevant assets
- 5.2.8.3 MI-PDDI-1: Document how to protect access to debug and management interfaces
- 5.2.8.4 MI-PDDI-2: Protect or disable physical access to debug and management interfaces
- 5.2.8.4 MI-PDDI-3: Protect or disable local software access to debug and management interfaces
- 5.2.8.5 MI-PDDI-4: Protect or disable network access to debug or management interfaces
- **EN 304 627 Routers modems and switches:**
- 5.4 Secure by default configuration
- 5.4.1 [DEFAULT] Secure by default configuration
- [DEFAULT-1-RQ-1-01] Applicable requirements from the present document may only be disabled in the factory default state when (i) enabled applicable requirements from the present document would render the initial product setup process non-functional, and (ii) omitted applicable requirements from the present document are documented in instructions to the user
- [DEFAULT-1-RQ-1-02] The product, in its factory default state, shall utilize only those network interfaces and services that are necessary for product setup
- [DEFAULT-1-RQ-1-03] The product, during initialization, shall limit access to accounts with initialization permissions.
- [DEFAULT-1-RQ-1-04] The product shall enforce the principle of least privilege during normal operation.
- [DEFAULT-1-RQ-1-05] The product, in its factory default state, shall allow access only using accounts and methods documented in the instructions to the user.
- [DEFAULT-1-RQ-1-06] The product shall protect remote diagnostic interfaces with authentication and authorization controls.

- [DEFAULT-1-RQ-1-07] The product, in its factory default state, shall enforce change of administrative credentials.
- [DEFAULT-1-RQ-1-08] The product, in its factory default state and before initialization, shall have debugging and diagnostic interfaces disabled.
- [DEFAULT-1-RQ-1-09] The product, in its factory default state, shall enable security audit events logging for authentication attempts, configuration changes, and product errors
- [DEFAULT-1-RQ-1-10] The product, in its factory default state, shall configure all cryptographic functions to use algorithms and key lengths that comply with current recognized standards.
- [DEFAULT-1-RQ-1-11] The product, in its factory default state, shall disable any protocols or services that have known exploitable vulnerabilities.
- 5.4.2 [RESET] Factory reset
- [RESET-1-RQ-1-01] The product shall provide a factory reset mechanism that restores the product to its secure-by-default configuration.
- [RESET-1-RQ-1-02] The product shall provide a factory reset mechanism that maintains the currently installed firmware version and all applied security updates.
- [RESET-1-RQ-1-03] The product shall require authentication and authorization at the highest privilege level for any factory reset initiated through software, management interface, or remote command.
- [RESET-1-RQ-1-04] Upon successful factory reset, the product shall not retain any information that could be used to reconstruct previous configuration or compromise user privacy.
- **EN 304 635 Virtualisation and Container Execution Systems:**
- 5.1.1.2 5.1.1.8 5.1.1.9 5.1.1.10
- 5.1.1.2 Integrity Protection
- 5.1.1.8 Patches and Updates
- 5.1.1.9 Secure Configuration and Default
- 5.1.1.10 Data Minimization
- **EN 304 636 Firewalls intrusion detection and prevention systems:**
- similar to EN 304 627 Routers modems and switches:
- 5.4 Secure by default configuration
- 5.4.1 [DEFAULT] Secure by default configuration
- 5.4.2 [RESET] Factory reset
- 5.4.3 [UPDATE] Update mechanisms
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

a) TBD

- We expect to discuss the finalized version of this essential requirement on meeting **MX end January 2026**.
- Anyone interested to contribute - <mailto:riccardo.sirigu@abissi.eu> and <mailto:adicalo@qti.qualcomm.com>

5.2.3 Mapping with technical controls

5.2.3.1 SO.SecureDefaultConfiguration

The list of technical controls that are applicable:

- 7.13.2 [GEC-2] Limit exposure of services via related network interfaces (EN 18031)
- 7.13.3 [GEC-3] Configuration of optional services and the related exposed network interfaces (EN 18031)
- 7.13.4 [GEC-4] Documentation of exposed network interfaces and exposed services via network interfaces (EN 18031)
- 7.13.5 [GEC-5] No unnecessary external interfaces (EN 18031)
- 7.13.7 [GEC-7] Documentation of external sensing capabilities (EN 18031)
- 7.13.12 [GEC-12] No Unneeded Software Components (NEW)
- 7.2.5 [AUM-5] Password strength (EN 18031)
 - [AUM-5-1] Requirement for factory default passwords (EN 18031)

EXAMPLE

- (1)
- [GEC-9] Secure default configuration (NEW) possibly we should change the name or contextualize the reason of having this control and the others along with this.

5.2.3.2 SO.SecureStartupConfig

The list of technical controls that are applicable:

- 7.13.9 [GEC-9] Secure startup configuration (new)
- 7.2.5 [AUM-5] Password strength
 - [AUM-5-2] Requirement for non-factory default passwords

EXAMPLE

- TBD

5.2.3.3 SO.FactoryReset

The list of technical controls that are applicable:

- 7.7.1 [DLM-1] Secure Data deletion mechanisms (Applicability of deletion mechanisms) (EN 18031)

— 7.13.10 [GEC-10] Factory Reset (new)

EXAMPLE

— TBD

5.3 (c) Security Updates

Warning — (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;

5.3.1 Description

[TBD]

5.3.2 Mapping threats and security objectives

Table 5

Threats	Security Objectives
Threat.UnpatchableVulnerabilityExploitation: An attacker exploits a vulnerability in a product for which no security update is available or feasible.	SO.Updateability: The product is able to update all of its software components, where applicable (e.g. excluding components which are immutable due to security reasons).
	SO.AvailabilityOfUpdates: The manufacturer of the product ensures that security updates addressing vulnerabilities are available. M55 - was decided to be removed.
Threat.UnpatchedVulnerabilityExploitation: An attacker exploits a vulnerability in a product for which a security update is available but not (or not yet) installed.	SO.AutomaticUpdates: The product ensures that available security updates can be installed automatically.
	SO.TimelyUpdates: The product ensures that the security updates are installed in a timely manner. NOTE What is the difference with Updateability and automaticupdates ? Proposal to remove buzzword timely updates M55 - was decided to be removed.
Threat.MissingUpdateNotificationExploitation : An attacker exploits a vulnerability in a product for which the update was not installed because the user was not aware about it.	SO.UserUpdateNotification: The product supports (e.g. by notification) the user to install security updates in a timely manner.
PROPOSED NEW: Threat.FunctionalityUpdateInterruption: An attacker (or the automated system) triggers a software update or reboot during a critical operation, causing an unplanned interruption of essential functionality. The lack of user/system control over the update window leads to a temporary Denial of Service (DoS) state.	PROPOSED NEW: SO.PostponeUpdates: The product allows the user (or an authorized process) to postpone or schedule the installation of security updates to ensure they do not interfere with the product's essential operations or safety-critical tasks.

Threats	Security Objectives
PROPOSED NEW: Threat.SoftwareUpdateTampering: An attacker tampers with the software update process or software update package in order to introduce malicious or unauthorized software into the product.	PROSED NEW: SO.SecureUpdate: The product ensures that only authentic and unmodified software updates can be installed.

Gaps to be solved/notes

EXAMPLE (1)

- The challenge is about the Remote Data Processing – could happen that manufacturers are using a silent patching approach for the “cloud component” side.
- How to deal with appropriate timeline and timely updates

(2) M55 Decision:

- We decided to remove [SUM-4] Timely Updates (NEW) along with the SO.TimelyUpdates
- Easy-to-use opt-out mechanism was integrated as a note in SUM-
- To integrate UNM-4 into SUM-4
- To integrate SUM-1 and SUM-2
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- UPD-REQ-1 (Automatic update mechanism), UPD-REQ-2 (Update signature verification), UPD-REQ-3 (HTTPS-only delivery), UPD-REQ-4 (Manifest integrity), UPD-REQ-5 (Rollback protection), UPD-REQ-6 (Channel isolation), UPD-REQ-7 (Component updates), UPD-REQ-8 (Emergency updates), UPD-REQ-9 (Verification before installation), UPDREQ-10 (Failure recovery), UPD-REQ-11 (Transparency logging), UPD-REQ-12 (Delta update security), UPD-REQ-13 (Server authentication), UPD-REQ-14 (Timing jitter), UPDREQ-15 (Background enforcement), UPD-REQ-16 (Notification UI), UPD-REQ-17 (Forced critical updates), UPD-REQ-18 (Verification chain), UPD-REQ-19 (Source pinning), UPDREQ-20 (Integrity verification), UPD-REQ-21 (Staged rollout), UPD-REQ-22 (Domain validation), UPD-REQ-23 (Binary reproducibility), EXT-REQ-10 (Extension update verification)
- EN 304 618 Password manager -
- TBD
- EN 304 619 Antivirus software -
- 5.2.3 Secure updates
- no notifications?
- seems that cover only the signature and not the update of its software

- EN 304 660 Virtual Private Networks Part 1 -
- 5.2.4 TR-SCUD: Secure updates
- 5.2.4.2 MI-SUDC: Documentation of secure update
- 5.2.4.3 MI-SUVP: Secure update via product
- 5.2.4.4 MI-SUAP: Automatic secure update via product
- 5.2.4.5 MI-SUOE: Secure update provided by operational environment
- 5.2.4.6 MI-SUAO: Automatic secure update provided by operational environment
- 5.2.4.7 MI-SUCS: Updates are signed and verified before installation
- 5.2.4.8 MI-SUAU: Only authorized software updates
- 5.2.4.9 MI-SUVH: Secure update has validly signed hash
- 5.2.4.10 MI-SURP: Invalidated update is rejected
- 5.2.4.11 MI-SURC: Signing keys have strictly scoped usage
- 5.2.4.12 MI-SUSR: Signing keys have not been revoked or otherwise marked untrusted
- 5.2.4.13 MI-SUMV: Reject update to current or previous version
- 5.2.4.14 MI-SUED: Updates not applied from expired sources
- EN 304 621 Network Management Systems -
- Requirements: - [REQ-UPDATES-0]: The product shall verify the authenticity and integrity of update packages using a cryptographic digital signature verification prior to installation. - [REQ-UPDATES-1]: The product shall maintain a monotonic version counter or equivalent mechanism to prevent installation of updates with an older vulnerable version. - [REQ-UPDATES-2]: If the product supports intentional rollback, this action shall require explicit authorisation and shall be based on separately versioned and signed rollback metadata. - [REQ-UPDATES-3]: The product shall apply updates in an atomic manner such that incomplete or failed updates do not result in a partially updated state. In the event that an update cannot be completed successfully, the product shall automatically restore a previously operational software state, ensuring the product remains functional.
- EN 304 622 Security Information and event management: same as EN 304 621
- EN 304 623 Boot Managers:
- 5.6.4, 5.12.2, 5.12.8
- 5.6.4 [RQ-INTEGRITY-004]
- 5.12.2 [RQ-VULN-002] Requirement: Where a user interface is available, the boot manager shall provide status indicators for available updates or rely on authorized components to present such indicators.
- 5.12.8 [RQ-VULN-008] Requirement: When hardware security components are available, the boot manager shall store update-verification keys using those components.
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- seems that security updates is missing and there is an assumption that 40000-1-3 maybe better to review

- EN 304 625 Network Interfaces: same as(subset) EN 304 660 Virtual Private Networks Part 1:
- 5.2.6.2 MI-SUDC: Documentation of secure update
- 5.2.6.3 MI-SUVP: Secure update via product
- 5.2.6.4 MI-SUAP: Automatic secure update via product
- 5.2.6.5 MI-SUOE: Secure update provided by operational environment
- 5.2.6.6 MI-SUAO: Automatic secure update provided by operational environment
- EN 304 626 Operating Systems: same as(subset) EN 304 660 Virtual Private Networks Part 1:
- 5.2.9.2 MI-SCHL: Low security updates provided by operational environment
- 5.2.9.3 MI-SCHM: Medium security updates provided by operational environment
- 5.2.9.4 MI-SCHH: High security updates provided by operational environment
- EN 304 627 Routers modems and switches:
- 5.5.1 [UPDATE] Update mechanisms
- [UPDATE-1-RQ-1-01] The product shall provide mechanisms to receive and install remedies throughout the defined support period.
- [UPDATE-1-RQ-1-02] The product shall ensure the update mechanism is automated and activated by default.
- [UPDATE-1-RQ-1-03] The product shall ensure the update mechanism depends on user configurations and operates automatically following the user configuration.
- [UPDATE-1-RQ-1-04] The product shall implement protection preventing unauthorized and unauthenticated installation of remedies.
- [UPDATE-1-RQ-1-05] The product shall implement cryptographic verification of remedy to ensure authenticity and integrity.
- NOTE: For the present context, best practice cryptography covers the standards that are publicly endorsed, accepted and recommended. These standards can be obtained from the European Union Agency for Cybersecurity [ENISA] and are accepted among all EU member states.
- [UPDATE-1-RQ-1-06] The manufacturer shall ensure that any update maintains or improves the product's security properties.
- [UPDATE-1-RQ-1-07] The product shall generate audit events for all update activities including (i) applicable remedy availability, (ii) download initiation and completion; and (iii) installation success or failure. [UPDATE-1-RQ-1-08] The product shall store audit events in persistent memory that survives the reset.
- EN 304 635 Virtualisation and Container Execution Systems:
- 5.1.1.8 Patches and Updates
- EN 304 636 Firewalls intrusion detection and prevention systems (SUBSET OF EN 304 627)
- 5.4.3 [UPDATE] Update mechanisms

- [UPDATE-1-RQ-1-01] The product shall provide mechanisms to receive and install remedies throughout the defined support period.
- [UPDATE-1-RQ-1-02] The product shall ensure the update mechanism is automated and activated by default.
- [UPDATE-1-RQ-1-03] The product shall ensure the update mechanism depends on user configurations and operates automatically following the user configuration.
- [UPDATE-1-RQ-1-04] The product shall implement protection preventing unauthorized and unauthenticated installation of remedies.
- [UPDATE-1-RQ-1-05] The product shall implement cryptographic verification of remedy to ensure authenticity and integrity.
- NOTE: Best practice cryptography comprises standards recommended by the European Union Agency for Cybersecurity (ENISA) in its EUCC Guidelines on Cryptography [2].
- [UPDATE-1-RQ-1-06] The manufacturer shall ensure that any update maintains or improves the product's security properties.
- EN 4000X Smart card applications of secure elements:

NOTE M4X: Suggestion of improvement

- a) **Missing from verticals note M50:** example of gaps Timely updates, updatability, notification of updates
- We expect to discuss the finalized version of this essential requirement on meeting **MX end January 2026**.
- Anyone interested to contribute - <mailto:riccardo.sirigu@abissi.eu> and <mailto:alexej.hensler@aumovio.com>
- Remind that there is a **cross-vertical work** that need to be integrated -
- document: <https://sd.cen.eu/documents/open/e86ba2fe-2218-4acd-bea1-c17f4c4ccdc1>
- contact point: Mohamad Hajj: <mailto:mohamad.hajj@internetoftrust.com>

5.3.3 Mapping with technical controls

5.3.3.1 SO.Updateability

The list of technical controls that are applicable:

- 7.3.1 7.3.1 [SUM-1] Applicability of update mechanisms (EN 18031)
- 7.3.2 7.3.2 [SUM-2] Secure updates (EN 18031)

EXAMPLE

- TBD

5.3.3.2 SO.AutomaticUpdates

The list of technical controls that are applicable:

- 7.3.3 [SUM-3] Automated updates (EN 18031)
- 7.3.5 [SUM-5] Opt-out from automatic software installation (NEW)
- 7.3.6 [SUM-6] Automatic Updates by default (NEW)

EXAMPLE

- TBD

5.3.3.3 SO.UserUpdateNotification

The list of technical controls that are applicable:

- 7.3.7 [SUM-7] User Security Update Notifications (NEW)

EXAMPLE

- TBD

5.3.3.4 SO.PostponeUpdates

The list of technical controls that are applicable:

- 7.3.4 [SUM-4] Postponed Updates [SSU-7] (NEW)

EXAMPLE

- TBD

5.3.3.5 SO.SecureUpdate

The list of technical controls that are applicable:

- 7.3.2 [SUM-2] Secure updates (EN 18031)

EXAMPLE

- TBD

5.4 (d) Access Control

Warning — (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;

5.4.1 Description

[TBD]

5.4.2 Mapping threats and security objectives

Table 6

Threats	Security Objectives
Threat.UnauthorizedAccess: An attacker gains unauthorized access to a product.	SO.AccessControl: The product prevents unauthorised access.
Threat.NotReportedUnauthorizedAccess: An Attacker's unauthorized access cannot be reported by the product.	SO.AccessControlReport: The product provides means to detect and report unauthorized access attempts.

Gaps to be solved/notes

EXAMPLE (1)

- **Authorization:**
- **M44:** Gabriel will align with Samim with the authorization concept and the relation with network asset vs sensitive asset.

(2)

- Missing control: additional **access control reporting**
- (report on possible unauthorised access)
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- DOM-REQ-1 (Process-per-site isolation), DOM-REQ-3 (Cross-origin DOM access prevention), DOM-REQ-4 (CORS preflight), DOM-REQ-5 (SameSite cookies), DOM-REQ6 (Storage isolation), EXT-REQ-1 (Extension permission model), EXT-REQ-3 (Extension API access control), EXT-REQ-7 (Host permissions validation), SYS-REQ-6 (Device API permissions), SYS-REQ-7 (PWA permission management), SYS-REQ-8 through SYSREQ-19 (Device-specific permissions), EMB-REQ-1 (JavaScript bridge API allowlists), EMB-REQ-5 (User consent for sensitive operations), EMB-REQ-11 (Granular capabilitybased permissions), PRO-REQ-2 (User consent for custom protocols), PRO-REQ-3 (Protocol allowlist enforcement)
- EN 304 618 Password manager -
- MPA-REQ-1; MPA-REQ-2; MPA-REQ-3; MPA-REQ-5; MPA-REQ6; ADA-REQ-1; ADA-REQ-2; ADA-REQ-3; ADA-REQ-4; ADAREQ-5; ACC-REQ-1; ACC-REQ-2; ACC-REQ-3; ACC-REQ-4; ACCREQ-5; ACC-REQ-6; ACA-REQ-1; ACA-REQ-2; ACA-REQ-3; ACA-REQ-4; ACA-REQ-7; PKY-REQ-5
- EN 304 619 Antivirus software -
- Clause 5.2.4
- • REQ-AAC-01: Where product can be deactivated, disabled or bypassed, the product shall implement self-protection mechanisms to prevent unauthorized deactivation, disabling or bypassing with robust resistance to configuration tampering and privilege escalation attacks by local or remote actors.
- REQ-AAC-02: The product UI shall not grant system administrator rights, that shall be restricted to back-end APIs to avoid unauthorized deactivation and malicious configuration.

- REQ-AAC-03: The product shall apply read-only actions for detection and write-only actions for updating the system when affecting its signatures and/or heuristics models DB components.
- REQ-AAC-04: Where product has the right to delete the infected files, the product shall only delete the infected files only inside the quarantine directory.
- REQ-AAC-05: Where product supports remote management, the remote management shall be disabled by default, and product shall invoke user authentication functionality provided by OS before activating remote management.
- REQ-AAC-06: The product shall invoke multi-factor authentication (MFA) for administrative access and strict least privilege enforcement mechanism provided by OS.
- REQ-AAC-07: The product shall invoke role-based access control with granular permissions with mandatory MFA, which is provided by OS, for all privileged access and prevent unauthorized access to detection logic, 800 heuristic algorithms and ML models within the product subsystems.
- EN 304 660 Virtuak Private Networks Part 1 -
- link with AUTH - quiet different on how the rother are structuring the standard
- EN 304 621 Network Management Systems -
- 5.2.6 Role based authorisation
- [REQ-AUTH-0]: The product is integrated into a state of the art identity management system.
- [REQ-AUTH-1]: 2-factor authentication is used to confirm the identity of a natural user.
- [REQ-AUTH-2]: Authenticated natural users's authorisation validity is no longer than a two days.
- Why only role based?
- EN 304 622 Security Information and event management: same as EN 304 621
- 5.2.6 Role based authorisation
- [REQ-AUTH-0]: The product is integrated into a state of the art identity management system.
- [REQ-AUTH-1]: 2-factor authentication is used to confirm the identity of a natural user.
- [REQ-AUTH-2]: Authenticated natural users's authorisation validity is no longer than a two days.
- [REQ-AUTH-3]: RBAC design shall follow the best practices of the deployment context.
- [REQ-AUTH-4]: The RBAC design and application in the product shall be documented.
- [REQ-AUTH-5]: All privileged interfaces shall implement RBAC.
- [REQ-AUTH-6]: All access to administrative interfaces, control functions, and sensitive operations shall be subject to strong authentication of users, services, or integrated components.
- [REQ-AUTH-7]: Privileged interfaces shall be protected with 5.2.4 State-of-the-art cryptographic libraries.
- Why only role based?
- EN 304 623 Boot Managers:

- Requirement: The boot manager shall not implement unauthorized or undocumented mechanisms that allow bypassing authentication or security controls.
- 5.4 Authentication and Authorization
- 5.4.1 [RQ-AUTH-001]-[RQ-AUTH-007]
- EN 304 624 Public key infrastructure and digital certificate issuance software:
 - 5.1, 5.3, conformity 6.2 & 6.4
 - 5.1 Auditing
 - 5.3 Certificate issuance
- EN 304 625 Network Interfaces: same as EN 304 660 Virtual Private Networks Part 1:
 - AUTH*
 - 5.2.7 ER-AUTH: Authentication and access control
 - TODO: Fill in very limited authentication requirements (for remote management or self-update) and reference cross-vertical authentication standards when they exist.
- EN 304 626 Operating Systems: same as EN 304 660 Virtual Private Networks Part 1:
 - 5.2.7 TR-AUTH: Authentication and access control
- Editor's Note: We anticipate that future revisions of this document will include state-of-the-art authentication requirements. This section should reference authentication and access control standards.
- EN 304 627 Routers modems and switches:
 - 5.6 Access Control
 - 5.6.1 [AUTH-1] Authentication
 - 5.6.2 [AUTH-2] Authorization
 - 5.6.3 [AUTH-3] Authenticated session lifecycle
 - 5.6.4 [AUTH-4] Protocol access control
- EN 304 635 Virtualisation and Container Execution Systems:
 - Hypervisor: 5.1.1.3 5.1.1.4
 - 5.1.1.3 Authentication
 - 5.1.1.3.2 Administrative Authentication
 - 5.1.1.3.3 Service Authentication
 - 5.1.1.4 Authorization
 - 5.1.1.4.1 Administrative Authorization
 - 5.1.1.4.2 Service Authorization

- EN 304 636 Firewalls intrusion detection and prevention systems: similar as EN 304 627
- 5.5 Access Control
- 5.5.1 [AUTH-1] Authentication
- 5.5.2 [AUTH-2] Authorization
- 5.5.3 [AUTH-3] Authenticated session lifecycle
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

a) TBD

- We expect to discuss the finalized version of this essential requirement on meeting **MX end January 2026** .
- Anyone interested to contribute - <mailto:samim.ahmadi@de.ey.com>
- Remind that there is a **cross-vertical work** that need to be integrated -
- document: <https://sd.cen.eu/documents/open/b153863b-de1e-4457-a432-7e7ad279ce86>
- contact point:
- Kilian Mitterweger: <mailto:kilian.mitterweger@bsi.bund.de>

5.4.3 **Mapping with technical controls**

5.4.3.1 **SO.AccessControl**

The list of technical controls that are applicable:

- 7.1.1 [ACM-1] Applicability of access control mechanisms (EN 18031) (VOID)
- 7.1.2 [ACM-2] Access control mechanisms (Appropriate access control mechanisms)(EN 18031) (MERGE ACM-1 ACM2)
- 7.2.1 [AUM-1] Applicability of authentication mechanisms (EN 18031) (VOID)
 - 7.2.1.1 [AUM-1-1] Requirement network interface (EN 18031) (VOID)
 - 7.2.1.2 [AUM-1-2] Requirement user interface (EN 18031) (VOID)
 - 7.2.1.3 [AUM-1-3] Requirement machine interface (EN 18031) (VOID)
- 7.2.2 [AUM-2] Appropriate authentication mechanisms (EN 18031)
- 7.2.3 [AUM-3] Authenticator validation (EN 18031)
- 7.2.4 [AUM-4] Changing authenticators (EN 18031)
- 7.2.5 [AUM-5] Password strength

- [AUM-5-1] Requirement for factory default passwords
- [AUM-5-2] Requirement for non-factory default passwords
- 7.2.6 [AUM-6] Brute force protection (EN 18031)

EXAMPLE

- TBD

5.4.3.2 SO.AccessControlReport

The list of technical controls that are applicable:

- 7.13.13 [GEC-13] Report on possible unauthorised access and corruption (NEW)

EXAMPLE

- TBD

5.5 (e) Confidentiality protection

Warning — (e) protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;

5.5.1 Description

[TBD]

5.5.2 Mapping threats and security objectives

Table 7

Threats	Security Objectives
Threat.DataAtRestDisclosure: An attacker discloses confidential data stored in a product.	SO.DataStoredConfidentiality: The product protects the confidentiality of persistently stored data.
Threat.DataProcessedDataDisclosure: An attacker discloses confidential data internally processed in a product.	SO.DataProcessedConfidentiality: The product protects the confidentiality of processed data.
Threat.DataInTransitDisclosure: An attacker discloses confidential data transferred to or from a product.	SO.DataTransmittedConfidentiality: The product protects the secrecy of confidential data with secure communication functionality.
	SO.ComAuth: The product authenticates communication partners.

Gaps to be solved/notes

EXAMPLE (1)

- STATE OF THE ART MECHARNISM - ACM FROM ENISA we have discussion going on.

(2)

- Missing control: requirements for protecting data in transit and processed

(3)

- **propose to add a insecure cryptography used = SO.SecureProvisioning (Accepted in M47) - Angelo to reflect this in OSD**

- Gitlab: <https://docbox.etsi.org/CYBER/EUSR/Open>

- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
 - ENC-REQ-1 (TLS 1.3+ support), ENC-REQ-2 (Certificate validation), ENC-REQ-3 (Certificate pinning), ENC-REQ-4 (HSTS enforcement), ENC-REQ-5 (Mixed content blocking), ENC-REQ-6 (Certificate Transparency), ENC-REQ-11 (Web Crypto API), ENCREQ-13 (Subresource Integrity), ENC-REQ-14 (Encrypted SNI/ECH), ENC-REQ-16 (HTTPS-first mode), ENC-REQ-20 (Cryptographic key isolation), ENC-REQ-21 (Certificate store security), DOM-REQ-2 (CORB), DOM-REQ-6 (Storage isolation), EMBREQ-4 (Context isolation), EMB-REQ-8 (Host credential protection), EMB-REQ-12 (Storage isolation from host), EMB-REQ-14 (Encrypted cross-process bridge), EMB-REQ17 (Certificate validation for embedded content), EMB-REQ-21 (Mixed content prevention), EMB-REQ-27 (Network security configuration)
- EN 304 618 Password manager -
 - PDS-REQ-1; PDS-REQ-2; PDS-REQ-5; BAR-REQ-1; DCF-REQ-1; DCF-REQ-2; DCF-REQ-3; IEF-REQ-1; PKY-REQ-3; PKY-REQ-4
 - PDS-REQ-1 [PDS-0→PDS-T1, PDS-T3]: SHALL use approved encryption algorithms as specified within the ENISA ACM [1] to protect the database
 - PDS-REQ-2 [PDS-0→PDS-T1]: SHALL use unique salts per database
 - PDS-REQ-4 [PDS-0→PDS-T1]: SHOULD implement secure key derivation separate from authentication
 - PDS-REQ-5 [PDS-0→PDS-T2]: SHALL use encryption for all network transmissions
 -
- EN 304 619 Antivirus software -
 - 5.2.5 Confidentiality Protection
 - REQ-CON-01: The product shall securely and automatically update antivirus signature databases and detection engines with version checking included to prevent man-in-the-middle (MitM) or unauthorised rollbacks (i.e. downgrade attacks).
 - REQ-CON-02: The product shall, as described in clause 4.4.6, encrypt stored detection, mitigation and quarantine-related data at rest.
 - REQ-CON-03: The product shall inform the user how user data is collected, stored, and processed.
 - REQ-CON-04: The product shall present transparent privacy measures to the user, ensuring that data is not unnecessarily shared with third parties.
- EN 304 660 Virtuak Private Networks Part 1 -
 - AUTH, ROUT, DNSL, EISO, IPV6, CRYPT

- EN 304 621 Network Management Systems -
- 5.3.2 Mitigations for ingested data integrity and confidentiality
- When evaluating the applicability of these requirements, the highest of following risk factors define the category to follow: SRU, Complexity, Segment, NIS2 For medium risk:
- [REQ-INGEST-0] The manufacturer shall protect the system against data poisoning or other adversarial attacks.
- [REQ-INGEST-1] The collected network element monitoring data shall be verifiable.
- EN 304 622 Security Information and event management: same as EN 304 621
- 5.3.2 Mitigations for ingested data integrity and confidentiality 850 When evaluating the applicability of these requirements, the highest of following risk factors define the category to 851 follow: [SRU], [Complexity], [Segment], [NIS2] For medium risk:
- [REQ-INGEST-0] The manufacturer shall protect the system against data poisoning or other adversarial attacks.
- [REQ-INGEST-1] The collected network element monitoring data shall be verifiable.
- EN 304 623 Boot Managers:
- 5.5.1 [RQ-CONFID-001]
- Requirement: The boot manager shall prevent key material from being used for cryptographic purposes other than those for which it was designated.
- 5.5.2 [RQ-CONFID-002]
- Requirement: The boot manager shall prevent sensitive data from being included in crash dumps or logs.
- 5.5.3 [RQ-CONFID-003]
- Requirement: The boot manager shall protect stored credentials using approved mechanisms that prevent recovery of the original credential values.
- 5.5.4 [RQ-CONFID-004]
- Requirement: The boot manager shall protect network boot parameters containing authentication information using approved mechanisms that prevent unauthorized disclosure. Applicability: Applies to all boot managers with configuration capability and network boot.
- 5.5.5 [RQ-CONFID-005]
- Requirement: The boot manager shall cryptographically erase all sensitive data and clear all security-critical configuration during secure disposal, where technically feasible.
- 5.5.6 [RQ-CONFID-006] Requirement: When secure disposal is supported, the boot manager shall provide an indication upon successful completion of the sanitization process.
- 5.5.7 [RQ-CONFID-007] Requirement: The boot manager shall protect the confidentiality and integrity of boot configuration data transmitted over network.
- 5.5.8 [RQ-CONFID-008]

- Requirement: The boot manager shall overwrite confidential or secret data after use, clear from memory temporary data structures and credentials before boot target handoff and not persist authentication credentials or confidential cryptographic material beyond the current boot cycle.
- EN 304 624 Public key infrastructure and digital certificate issuance software:
 - 5.1 5.2, 6.2 & 6.3
 - 5.1 Auditing
 - 5.2 Secret management
- EN 304 625 Network Interfaces: same as EN 304 660 Virtual Private Networks Part 1:
- EN 304 626 Operating Systems: same as EN 304 660 Virtual Private Networks Part 1:
- MISO, LMII, CDST, CDTX, CRYP*
- 5.2.4 TR-MISO: Prevent local unauthorized access of memory-addressable security-relevant data
 - 5.2.4.2 MI-MMAC: Memory access control
 - 5.2.4.3 MI-CCON: Prevent creation of more than one user account
 - 5.2.4.4 MI-UCON: Prevent concurrent user account usage
 - 5.2.4.5 MI-PMSC: Prevent memory leaks through microarchitectural side channels in provided executables
 - 5.2.4.6 MI-TRMD Transfer risk of microarchitectural side channel data leaks to user
- TR-LMII: Limit incident impact
- 5.2.6.3 MI-MZRO-1: Stack memory zeroing
- 5.2.6.4 MI-MZRO-2: Heap memory zeroing
- 5.2.6.5 MI-MRWX-1: Prevent writes to executable and read-only data memory
- 5.2.6.6 MI-MRWX-2: Prevent execution of non-kernel code memory
- 5.2.6.7 MI-ASLR Address space layout randomization
- 5.2.6.8 MI-MRCO: Mitigate reference counter overflow
- 5.2.6.9 MI-NKAM: Prevent unintentional kernel access to userspace memory
- 5.2.6.10 MI-PLLC: Prevent linked list corruption
- 5.2.6.11 MI-CFIN: Control flow integrity
- 5.2.6.12 MI-MPMT: Memory protection using memory tagging
-
- 5.2.9 TR-CRYP: Encryption
- FUTURE ANNEX K
- EN 304 627 Routers modems and switches:

- 5.7 Data Protection
- [DATA-1-RQ-1-1] The product shall implement data protection measures ensuring all sensitive data including passwords, application-level cryptographic keys, and user credentials are encrypted at rest using best practice 1323 cryptographic algorithms.
- [DATA-1-RQ-1-2] The product shall implement data protection measures ensuring all management communications employ encrypted channels providing both confidentiality and integrity protection through best practice cryptography.
- [DATA-1-RQ-1-3] The product shall implement data protection measures ensuring configuration files and firmware images are protected against unauthorized modification.
- [DATA-1-RQ-1-4] The product shall implement data protection measures ensuring the product processes and retains only the minimum data necessary for its intended routing, switching, or modem functions. Any diagnostic or telemetry data collection beyond intended purpose of the product shall require explicit opt-in configuration, with such collection disabled by default.
- EN 304 635 Virtualisation and Container Execution Systems:
- 5.1.1.5 Confidentiality Protection
- REQ-H-CONF-001 (Access control for sensitive data): The Hypervisor shall provide access-control mechanisms to restrict access to sensitive data under its control, including guest VM images, snapshot data, configuration files, credentials, and security-relevant logs. Access to such sensitive data shall be permitted only to authenticated and authorized entities through controlled interfaces.
- REQ-H-CONF-002 (Data at rest): The Hypervisor shall support encryption of sensitive data at rest, including VM images, snapshot data, configuration files, credentials, and security-relevant logs. Encryption keys used for data-at-rest protection shall be stored and managed in a manner that prevents access by guest workloads and other unprivileged components.
- REQ-H-CONF-003 (Data in transit): The Hypervisor shall support the use of encrypted communication for management interfaces, for VM migration traffic, and for inter-VM traffic where such traffic is mediated by Hypervisor-controlled virtual networking components. When these communications are configured to use encrypted transport, the Hypervisor shall prevent fallback to unencrypted or weakly protected channels.
- REQ-H-CONF-004 (Data in use - confidential execution): The Hypervisor shall support provisioning and management of execution environments for guest workloads in which confidential data associated with those workloads is protected, during execution, from observation, inspection, or access through the Hypervisor, the host operating system, and administrative interfaces. On platforms that provide mechanisms for confidential execution, the Hypervisor shall be able to use these mechanisms to enforce the confidentiality of guest memory and associated processor state.
- REQ-H-CONF-005 (Hardware-backed confidentiality): The Hypervisor may support the use of hardware-based security mechanisms to strengthen protection of cryptographic keys and confidential execution state used for data-at-rest, data-in-transit, and data-in-use protection.
- NOTE: Such mechanisms include dedicated secure hardware modules, memory encryption features, or equivalent platform components that provide protected storage for keys and resistance against Unauthorized access to confidential workload data.
- EN 304 636 Firewalls intrusion detection and prevention systems:
- 5.6 Data Protection

- [DATA-1-RQ-1-1] The product shall implement data protection measures ensuring all sensitive data including passwords, application-level cryptographic keys, and user credentials are encrypted at rest using best practice cryptographic algorithms.
- [DATA-1-RQ-1-2] The product shall implement data protection measures ensuring all management communications employ encrypted channels providing both confidentiality and integrity protection through best practice cryptography.
- [DATA-1-RQ-1-3] The product shall implement data protection measures ensuring configuration files and firmware images are protected against unauthorized modification.
- [DATA-1-RQ-1-4] The product shall implement data protection measures ensuring the product processes and retains only the minimum data necessary for its intended firewall, intrusion detection or intrusion prevention functions. Any diagnostic or telemetry data collection beyond intended purpose of the product shall require explicit opt-in configuration, with such collection disabled by default.
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

a) TBD

- We expect to discuss the finalized version of this essential requirement on meeting **MX end January 2026**.
- Anyone interested to contribute - <mailto:meinhard.bohlen@se.com>, <mailto:simon.dunkley@itron.com>, <mailto:alexej.hensler@aumovio.com>
- Remind that there is a **cross-vertical work** that need to be integrated -
- document: Annex K V 04_GM_CommentresolutionV03 <https://sd.cen.eu/documents/open/d614ddc2-eff6-4884-8777-cde1b7b7bb92>
- contact point:
- Gisella Meister: <mailto:giselameister18@googlemail.com>

5.5.3 **Mapping with technical controls**

5.5.3.1 **S0.DataStoredConfidentiality**

The list of technical controls that are applicable:

- 7.4.1 [SSM-1] Applicability of secure storage mechanisms (EN 18031)
- 7.4.3 [SSM-3] Appropriate confidentiality protection for secure storage mechanisms (EN 18031)

EXAMPLE

- TBD

5.5.3.2 **S0.DataProcessedConfidentiality**

The list of technical controls that are applicable:

- 7.13.8 [GEC-8] Product Integrity (EN 18031)
- 7.13.11 [GEC-11] Exploit mitigation mechanisms
- **7.17.1 [SPD-1] Secure Processed Data**

EXAMPLE

- TBD

5.5.3.3 SO.DataTransmittedConfidentiality

The list of technical controls that are applicable:

- 7.5.3 [SCM-3] Secure communication mechanisms with confidentiality protection
- 7.5.4 [SCM-4] Appropriate replay protection for secure communication mechanisms

EXAMPLE

- TBD

5.5.3.4 SO.ComAuth

The list of technical controls that are applicable:

- 7.5.2 [SCM-2] Appropriate integrity and authenticity protection for secure communication mechanisms (EN 18031)
- 7.5.3 [SCM-3] Secure communication mechanisms with confidentiality protection (EN 18031)

EXAMPLE

- TBD

5.5.3.5 SO.SecureProvisioning (new)

The list of technical controls that are applicable:

- 7.12.1 [CCK-1] Appropriate CCKs (EN 18031)
- 7.12.2 [CCK-2] CCK generation mechanisms (EN 18031)
- 7.12.3 [CCK-3] Preventing static default values for preinstalled CCKs (EN 18031)
- 7.14.1 [CRY-1] Best practice cryptography (EN 18031)

EXAMPLE

- TBD

5.6 (f) Integrity protection

Warning — (f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;

5.6.1 Description

[TBD]

5.6.2 Mapping threats and security objectives

Table 8

Threats	Security Objectives
Threat.DataAtRestTampering: An attacker tampers stored data in a product .	SO.DataStoredIntegrity: The product protects the integrity of persistently stored data.
Threat.DataInTransitTampering: An attacker tampers data transferred to or from a product.	SO.DataTransmittedIntegrity: The product protects the integrity of transmitted data with secure communication functionality.
	SO.ComAuth: The product authenticates communication partners.
Threat.ProcessedDataTampering: An attacker tampers data internally processed by the product.	SO.DataProcessedIntegrity: The product protects the integrity of processed data.
Threat.TamperingUndetected: An attacker tampers with data processed by a product and remains undetected.	SO.IntegrityReport: The product detects and reports data tampering.

Gaps to be solved/notes

EXAMPLE (1)

- Missing control: requirements for protecting data processed
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- EN 304 618 Password manager -
- EN 304 619 Antivirus software -
- EN 304 660 Virtuak Private Networks Part 1 -
- EN 304 621 Network Management Systems -
- EN 304 622 Security Information and event management: same as EN 304 621
- EN 304 623 Boot Managers:
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- EN 304 625 Network Interfaces: same as EN 304 660 Virtuak Private Networks Part 1:
- EN 304 626 Operating Systems: same as EN 304 660 Virtuak Private Networks Part 1:
- EN 304 627 Routers modems and switches:

- EN 304 635 Virtualisation and Container Execution Systems:
- EN 304 636 Firewalls intrusion detection and prevention systems:
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

a) TBD

- We expect to discuss the finalized version of this essential requirement on meeting **MX end January 2026**.
- Anyone interested to contribute - <mailto:meinhard.bohlen@se.com>, <mailto:simon.dunkley@itron.com>, <mailto:alexej.hensler@aumovio.com>
- Remind that there is a **cross-vertical work** that need to be integrated -
- document: Annex K V 04_GM_CommentresolutionV03 <https://sd.cen.eu/documents/open/d614ddc2-eff6-4884-8777-cde1b7b7bb92>
- contact point:
- Gisella Meister: <mailto:giselameister18@googlemail.com>

5.6.3 Mapping with technical controls

5.6.3.1 SO.DataStoredIntegrity

The list of technical controls that are applicable:

- 7.4.1 [SSM-1] Applicability of secure storage mechanisms (EN 18031)
- 7.4.2 [SCM-2] Appropriate integrity and authenticity protection for secure communication mechanisms (EN 18031)

EXAMPLE

- TBD

5.6.3.2 SO.DataProcessedIntegrity

The list of technical controls that are applicable:

- 7.13.8 [GEC-8] Product Integrity (EN 18031)
- 7.13.11 [GEC-11] Exploit mitigation mechanisms
- **7.17.1** [SPD-1] Secure Processed Data

EXAMPLE

- TBD

5.6.3.3 SO.DataTransmittedIntegrity

The list of technical controls that are applicable:

- 7.4.2 [SCM-2] Appropriate integrity and authenticity protection for secure communication mechanisms (EN 18031)

EXAMPLE

- TBD

5.6.3.4 SO.ComAuth

The list of technical controls that are applicable:

- 7.5.2 [SCM-2] Appropriate integrity and authenticity protection for secure communication mechanisms (EN 18031)
- 7.5.3 [SCM-3] Secure communication mechanisms with confidentiality protection (EN 18031)

EXAMPLE

- TBD

5.6.3.5 SO.IntegrityReport

The list of technical controls that are applicable:

- 7.13.13 [GEC-13] Report on possible unauthorised access and corruption (NEW)

EXAMPLE

- TBD

5.7 (g) Data minimization

Warning — (g) process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);

5.7.1 Description

The data minimisation requirement under the Cyber Resilience Act aims to ensure that products with digital elements process only data, whether personal or other, that are necessary in relation to their intended purpose, in order to reduce cybersecurity risks associated with excessive, unnecessary, or prolonged data processing.

Note 1: For the purposes of this requirement, “**data**” refers to any digital representation of acts, facts or information and any compilation of such acts, facts or information, including in the form of sound, visual or audio-visual recordings; (see Article 2(1) of Regulation (EU) 2023/2854 (Data Act)). This includes both personal and non-personal data.

5.7.2 Mapping threats and security objectives

Table 9

Threats	Security Objectives
Threat.UnnecessaryDataMisuse: An attacker gains access to data that is not required for the intended purpose of a product.	SO.DataMinimization: The product only collects or processes data necessary for its intended purpose.

Gaps to be solved/notes

EXAMPLE (1)

- Still in the definition phase and considering how to make it a technical requirement and related to the capabilities of the products.
- It is clear that to minimize data relevant to support a functionality of specific use there should be a strong data classification process
- **Reach out to WG5** – Angelo and Ben will reach out to them for help with this topic.
- Maria is assigned to this activity and is already part of WG5, and she is already in contact with Alessandro Guarino – Maria will discuss the draft with the WG5 group.
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- EXT-REQ-16 (Extension telemetry privacy), DOM-REQ-6 (Storage isolation limits data sharing), EMB-REQ-12 (Storage isolation from host), PRO-REQ-5 (Protocol parameter sanitisation to prevent data leakage)
- EN 304 618 Password manager -
- PGN-REQ-5;
- PGN-REQ-5 [PGN-0→PGN-T3]: SHOULD implement constant-time generation to prevent timing analysis
- EN 304 619 Antivirus software -
- Clause 5.2.7
- REQ-DM-01: The product shall not collect or transmit PII without **user consent** except to the degree required to ensure manufacturer compliance with other existing regulatory requirements.
- REQ-DM-02: The product shall follow a "**Privacy by Design**" approach including elements such as conduct formal PIAs on data collected, provide public-facing privacy datasheets/reports that clearly explain the data management (what data is collected, why it is necessary, and how it is used).
- REQ-DM-03: The product shall ensure that any data processing for "purpose independent of the instructions of the cloud service customer" (e.g. for marketing or advertising) requires explicit consent and is not a condition for receiving the service
- EN 304 660 Virtual Private Networks Part 1 -

- 5.2.12.2 MI-NPII-1: No PII collected without authorization
- The product shall not collect PII without explicit authorization.
- MI-NPII-2: No PII sent outside endpoint
- VPN shall not send PII outside of the endpoint at all.
- 5.2.12.4 MI-NPII-3: No PII required for use or payment
- The VPN shall not require PII for use of the product, including for payment.
- 5.2.12.5 MI-NPII-4: No PII stored on remote data processing systems
- The VPN shall not store any PII of the user on remote data processing systems
- EN 304 621 Network Management Systems -
- These requirements are generally binding, and there is no low-medium-high tiering available.
- [REQ-MINIMI-0] Metrics name, purpose, and value interpretation shall be described for the user.
- [REQ-MINIMI-1] Metrics cadence, accuracy and storage time shall be described for the user.
- EN 304 622 Security Information and event management: **same as EN 304 621**
- EN 304 623 Boot Managers:
- [RQ-MINIMAL-001] Requirement: The boot manager shall minimize disclosure of information to network infrastructure by limiting transmitted data to what is necessary for boot operations.
- [RQ-MINIMAL-002] Requirement: The boot manager shall prevent disclosure of sensitive device information and shall ensure that temporary network credentials are not retained beyond their required use.
- [RQ-MINIMAL-003] Requirement: The boot manager shall limit configuration storage to information necessary for boot and security-related operations.
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- ???????
- EN 304 625 Network Interfaces: same as EN 304 660 VirtuaK Private Networks Part 1:
- ER-DMIN: Data Minimization
- 5.2.12.1 Requirement -The product shall minimize the data processed
- EN 304 626 Operating Systems: **same as EN 304 660 VirtuaK Private Networks Part 1:**
- EN 304 627 Routers modems and switches:
- 5.7 Data Protection
- [DATA-1-RQ-1-1] The product shall implement data protection measures ensuring all sensitive data including passwords, application-level cryptographic keys, and user credentials are encrypted at rest using best practice cryptographic algorithms.
- [DATA-1-RQ-1-2] The product shall implement data protection measures ensuring all management communications employ encrypted channels providing both confidentiality and integrity protection through best practice cryptography.

- [DATA-1-RQ-1-3] The product shall implement data protection measures ensuring configuration files and firmware images are protected against unauthorized modification.
- [DATA-1-RQ-1-4] The product shall implement data protection measures ensuring the product processes and retains only the minimum data necessary for its intended routing, switching, or modem functions. Any diagnostic or telemetry data collection beyond intended purpose of the product shall require explicit opt-in configuration, with such collection disabled by default.
- EN 304 635 Virtualisation and Container Execution Systems:
- Hypervisor: 5.1.1.10 CRS: 5.2.1.10
- REQ-H-DM-001: The Hypervisor shall limit log content, telemetry, and diagnostic data to information required for operation, troubleshooting, and security monitoring. Logs, telemetry, and diagnostic outputs produced by the Hypervisor shall not include sensitive security material such as plaintext authentication credentials, full cryptographic keys, or complete virtual machine memory contents. Payload or application data originating from guest workloads shall not be included in Hypervisor logs, telemetry, or diagnostic outputs by default. Where the Hypervisor supports inclusion of such payload content for debugging purposes, this behaviour shall only be enabled through explicit administrative configuration and shall be clearly indicated to the administrator.
- REQ-H-DM-002: The Hypervisor shall provide administrative controls to restrict and, where necessary, disable the collection of specific categories of log, telemetry, and diagnostic data, including the ability to disable collection of particular log types, telemetry streams, metrics, or debug payload capture.
- EN 304 636 Firewalls intrusion detection and prevention systems:
- **same as EN 304 627 Routers modems and switches**
- EN 4000X Smart card applications of secure elements:

NOTE M49: Suggestion of improvement (3 Feb 2026)

- a) **Maria:** `Not approached as GDPR - different scope - to be kept different from the data controller
- b) **Alessio:** Concern DTM-2 in relation to silicon vendor - minimize by default the logging in relation to the intended process - but a chipset is delivered in a configuration with all the log are available so then is up to integrator to do the job - can be problematic
 - 1) Maria: the intended purpose can be that it should be used in a final product
 - 2) **M49 - Action:** Alessio to draft an example
 - i) Where a product with digital elements is intended to be integrated into another product, such as a microprocessor or a modem used as a component, its intended purpose includes integration into a larger system and operation within a final product defined by an integrator. In such cases, the default configuration of the component may enable certain data processing functions, such as security logging, diagnostics, analytics or telemetry, where these are necessary to support integration, testing, validation, secure operation, or troubleshooting during development and system integration. The component manufacturer provides clear and effective technical means allowing integrators to identify, configure, limit or disable logging, analytics, telemetry or similar data processing mechanisms that are not required in the final integrated product. The determination of which data processing functions are enabled in the final product forms part of the intended purpose of the component as realised through integration. The responsibility of the component manufacturer is to ensure that unnecessary data processing is not mandated by default and that appropriate configuration controls are available to prevent unnecessary data processing in the deployed system.
- c) **Gabriel:** to propose addition to the text

- d) **Meinhard:** Not sure if we need to include the **intended purpose** because it is related to all the requirements - DTM-2 it is very similar to the GEC-2 that is disabling services - We should link with it.
 - 1) There is an issue to refer to reasonable foreseeable use/misuse
 - i) **Angelo:** pointed back that in the scope of CRA text is referenced only reasonable foreseeable use
- e) **Ioannis:** to provide contribution - **on disable** action that is not appropriate - will provide alternative text to maria

NEXT STEPS:

- All to collect feedback and contributions address the points into the note.
- After loaded there will be the adaptation to the template:
<https://sd.cen.eu/documents/open/14aa2fa9-1cd9-4136-a2d3-903fb2e5c842>

SUMMARY:

- f) We expect to discuss the finalized version of this essential requirement on meeting **MX end February 2026**.
 - 1) Maria volunteered to run this activity and she is already part of WG5, and she is already in contact with Alessandro Guarino – Maria will discuss the draft with the WG5 group and provide a preliminary contribution
- g) Anyone interested to contribute please reach out maria@raphael.legal or maria@privacyminders.com

5.7.3 Mapping with technical controls

5.7.3.1 SO.DataMinimization

The list of technical controls that are applicable:

- 7.8.1 [UNM-1] Applicability of user notification mechanisms (EN 18031)
- 7.8.2 [UNM-2] Appropriate user notification content (EN 18031)
- 7.15.1 [DTM-1] Data minimisation in relation to intended purpose (NEW)
- 7.15.2 [DTM-2] Default Data Processing Minimisation (NEW)
- 7.15.3 [DTM-3] Configurable Controls for Optional Data Processing (NEW)
- Suggestions it should include things such as:
 - Minimize the collection only on relevant information - as we minimize the interfaces exposed I would expect the same for data too
 - User notification if something changes with an update or any other change in policy
 - Privacy impact analysis on data linked to the use of the product
 - Telemetry data that should collect only data related to the service itself

- User consent

EXAMPLE Note

- It involve the process - and documentation of data collected

5.8 (h) Availability

Warning — (h) protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;

5.8.1 Description

[TBD]

5.8.2 Mapping threats and security objectives

Table 10

Threats	Security Objectives
Threat.AvailabilityDegradationAfterIncident: An attacker impacts the availability of basic or essential functions of the product after an incident, e.g. a denial-of-service attack. M49: new title AvailabilityDegradationAfterIncident	SO.IncidentRecovery: The product recovers from incidents, e.g. denial-of-service attacks.
Threat.AvailabilityDegradationDuringIncident: An attacker impacts the availability of basic or essential functions of the product during an incident, e.g. a denial-of-service attack. M49: new title AvailabilityDegradationDuringIncident	SO.IncidentResilience: The product provides basic and essential functions during incidents , e.g. denial-of-service attacks.

Gaps to be solved/notes

EXAMPLE (1)

- This requirement may be address by asking to the manufacturers to document the essential and basic functions and to define the related security controls
- Define and verity the fault tollerant mechanisms implemented from a product pererspective if applicable

(2)

- **Consider**
- backup - as a way to restore functionality
- brute-force protection
- hardening
- implement redundancy - fault tollerant mechanism

- least privileged
- Authorization we can point back to AUM ACM
- here we can have SECURE BOOT - Product integrity
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- SYS-REQ-20 (Hardware resource limits), SYS-REQ-21 (Memory isolation), SYS-REQ-22 (CPU quotas), SYS-REQ-23 (Network bandwidth limits), SYS-REQ-24 (Storage quotas), SYS-REQ-25 (Process priority management), EMB-REQ-10 (Bridge API rate limiting), EXT-REQ-5 (Extension sandboxing to prevent interference)
- EN 304 618 Password manager -
- BAR-REQ-1; BAR-REQ-2; BAR-REQ-3; BAR-REQ-4; BAR-REQ-5; BAR-REQ-6;
- BAR-REQ-1 [BAR-0→BAR-T2]: SHALL encrypt all backup data with same standards as primary database
- BAR-REQ-2 [BAR-0→BAR-T1, BAR-T3]: SHALL implement multi-factor recovery process
- BAR-REQ-3 [BAR-0→BAR-T1]: SHALL implement time-delayed recovery with notification period
- BAR-REQ-4 [BAR-1→BAR-T4]: SHALL generate cryptographically random recovery codes / SHALL not be brute forceable
- BAR-REQ-5 [BAR-0→BAR-T1, BAR-T3]: SHALL notify users of all recovery attempts
- BAR-REQ-6 [BAR-0→BAR-T1, BAR-T4]: SHALL limit recovery code usage attempts
- EN 304 619 Antivirus software -
- 5.2.8 Availability Protection
- REQ-AP-01: The product shall maintain minimum viable protection levels during degraded operational conditions, such as partial system failure or incomplete updates.
- REQ-AP-02: The product shall include redundancy mechanisms for critical components in case of partial system failure
- EN 304 660 Virtual Private Networks Part 1 -
- Exploit mitigation by limiting incident impact SSD, EISO, NUTI
- TR-SSDD: Secure design and development
- EISO - MI-EISO: No route between different endpoints
- TR-NUTI No untrusted traffic in the VPN connection
- 5.2.7.2 MI-NUTI-1 Policy-driven traffic exclusion

- **5.2.7.3 MI-NUTI-2 Protocol validity checks**
- EN 304 621 Network Management Systems -
- 5.2.6 Role based authorisation
- EN 304 622 Security Information and event management:
- same as EN 304 621 -
- EN 304 623 Boot Managers:
- 5.8 Availability and Resilience
- 5.8.0 Introduction to availability and resilience requirements This clause addresses CRA requirements for availability and resilience. Boot managers shall maintain availability during failures or attacks through recovery mechanisms, failsafe operations, and resistance to denial-of-service conditions.
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- 5.1 5.2, 6.2 & 6.3
- 5.1 Auditing
- 5.2 Secret management
- EN 304 625 Network Interfaces: same as EN 304 660 VirtuaK Private Networks Part 1:
- Map risk with requirement
- AVAI, LMII
- AVAI, LMII, LMAS, LOGG, VULH
- 5.2.3 ER-LMII: Limit incident impact
- MI-MSAF-1: Stack exhaustion detection
- MI-MSAF-2: Stack linear buffer overflow detection
- MI-MSAF-3: Array bounds checking
- MI-MZRO-1: Stack memory zeroing
- MI-MZRO-2: Heap memory zeroing
- 5.2.13 ER-AVAI: Availability
- 5.2.13.2 MI-WDOG: Watchdog and self-initiated reset
- 5.2.13.3 MI-NTFY: Watchdog and notification of host
- MI-FDRP: Fast packet drop
- ,,,
- EN 304 626 Operating Systems: same as EN 304 660 VirtuaK Private Networks Part 1:
- AVAI, LMII

- 5.2.13 TR-AVAL: Availability
- 5.2.13.2 MI-AVNT: Availability of network services
- 5.2.13.3 MI-WDOG: Watchdog and self-initiated reset
- 5.2.13.4 MI-FDRP: Fast packet drop
- 5.2.13.5 MI-LMEM: Limit memory usage
- 5.2.13.6 MI-FAIR: Fair resource usage and prioritization
- 5.2.13.7 MI-DOST: Document risk transfer to operational environment for denial of service
- 5.2.6 TR-LMII: Limit incident impact
- 5.2.6.3 MI-MZRO-1: Stack memory zeroing
- 5.2.6.4 MI-MZRO-2: Heap memory zeroing
- 5.2.6.5 MI-MRWX-1: Prevent writes to executable and read-only data memory
- 5.2.6.6 MI-MRWX-2: Prevent execution of non-kernel code memory
- 5.2.6.7 MI-ASLR Address space layout randomization
-
- EN 304 627 Routers modems and switches:
- 5.8 Availability and Resilience
- [AVAIL-1-RQ-1-1] The product shall maintain resilience against denial-of-service attacks using appropriate techniques which include but are not limited to: (i) rate limiting and (ii) connection throttling for supported network protocols.
- [AVAIL-1-RQ-1-2] The product shall automatically recover to normal operational state when denial-of-service conditions cease, without requiring manual intervention.
- [AVAIL-1-RQ-1-3] The product shall generate audit events when: (i) it detects high resource utilisation (e.g., sustained high CPU utilisation, memory exhaustion, high packet drop count and similar); and (ii) when resource utilisation returns to levels designated by the manufacturer as “normal”.
- [AVAIL-1-RQ-1-4] The product shall store audit events in persistent memory that survives the reset.
- EN 304 635 Virtualisation and Container Execution Systems:
- Basic
- REQ-H-AVAIL-001: The Hypervisor shall detect failures of internal management and control-plane components and shall support recovery of these components without requiring a full host reboot, in order to maintain availability of running guest virtual machines.
- Elevated
- REQ-H-AVAIL-002: The Hypervisor shall provide mechanisms to support high availability of guest virtual machines, including automatic detection of host or Hypervisor service failure and automatic restart or migration of affected guest virtual machines to another available host, using native clustering capabilities or integration with external clustering or orchestration systems.

- REQ-H-AVAIL-003: The Hypervisor shall implement and enforce resource scheduling mechanisms that support configuration of minimum resource allocations for its security and management functions, covering at least CPU, 1934 memory, and I/O resources. These mechanisms shall protect the Hypervisor's control plane from resource exhaustion caused by guest workloads or 1936 external resource contention, ensuring that security and management functions remain able to operate under load.
- Advanced
- REQ-H-AVAIL-004: The Hypervisor shall support replication of the runtime state of selected guest virtual machines, including CPU and memory state and associated I/O buffers, to standby instances in order to enable failover with minimal interruption to workload execution in the event of host or Hypervisor service failure.
- EN 304 636 Firewalls intrusion detection and prevention systems:
- 5.7 Availability and Resilience
- [AVAIL-1-RQ-1-1] The product shall maintain resilience against denial-of-service attacks using appropriate techniques which include but are not limited to:
 - i) rate limiting; and
 - ii) connection throttling for supported network protocols.
- [AVAIL-1-RQ-1-2] The product shall automatically recover to normal operational state when denial-of-service conditions cease, without requiring manual intervention.
- [AVAIL-1-RQ-1-3] The product shall generate audit events when:
 - i) it detects high resource utilization (e.g. sustained high CPU utilization, memory exhaustion, high packet drop count and similar); and
 - ii) when resource utilization returns to levels designated by the manufacturer as "normal".
- [AVAIL-1-RQ-1-4] The product shall store audit events in persistent memory that survives the reboot
- EN 4000X Smart card applications of secure elements:

NOTE M4X: Suggestion of improvement

- a) This requirement may be address by asking to the manufacturers to document the essential and basic functions and to define the related security controls
- b) Define and verity the fault tollerant mechanisms implemented from a product pererspective if applicable
- We expect to discuss the finalized version of this essential requirement on meeting **MX end January 2026** .
- Anyone interested to contribute - <mailto:meinhard.bohlen@se.com>, <mailto:kai.fischer@siemens.com>, <mailto:rainer.becker3@de.bosch.com>

5.8.3 Mapping with technical controls

5.8.3.1 SO.IncidentRecovery

The list of technical controls that are applicable:

- 7.9.2 [RLM-2] Recovery from incidents (NEW)
- 7.9.6 [RLM-6] Control system backup (NEW)

EXAMPLE

- TBD

5.8.3.2 SO.IncidentResilience

The list of technical controls that are applicable:

- 7.9.1 [RLM-1] Applicability and appropriateness of resilience mechanisms (EN 18031)
- 7.9.3 [RLM-3] Network prioritization (NEW)
- 7.9.4 [RLM-4] Resource prioritization (NEW)
- 7.9.5 [RLM-5] Resource management (NEW)
- 7.9.6 [RLM-6] Control system backup (NEW)

EXAMPLE

- ~~[RLM-3] Resilience — Provide basic and essential functions (NEW) may be removed because a duplicate of RLM-1~~

5.9 (i) External impact protection

Warning — (i) minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;

5.9.1 Description

[TBD]

5.9.2 Mapping threats and security objectives

Table 11

Threats	Security Objectives
Threat.ExtServiceAvailabilityDegradation: An attacker uses the product to negatively impact the availability of services provided by other devices or networks.	SO.LimitExternalImpact: The product protects its network functions and other functions, that may negatively impact the availability of services provided by other devices or networks, <u>against known exploits</u> . NOTE 1 Concerns: Are we limiting if we only speak about known exploits? The scope is wider than known exploits!

Threats	Security Objectives
	M55: decided to remove the phrase known exploit,
	SO.PreventAttackPropagation: The product prevents the propagation of attacks resulting in a negative impact on the availability of services provided by other devices or networks.
	Warning — Can be this an overlap in monitoring objective (1) for SO.MonitorSecurityRelevantActivities?
	SO.MonitorExternalImpact: The product monitors its network functions and the functions of other connected devices for the protection against attacks, e.g. DoS attacks and known exploits, that may negatively impact the availability of services provided by other devices or networks. NOTE 2 The network functions of other connected devices are only to be monitored if the product is in control of those functions or uses those functions. NOTE 3 Attacks include also unintentional attacks.

Gaps to be solved/notes

EXAMPLE (1)

- Still in definition phase in how to details this requirement from a product capability perspective
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- EN 304 618 Password manager -
- EN 304 619 Antivirus software -
- EN 304 660 Virtuak Private Networks Part 1 -
- EN 304 621 Network Management Systems -
- EN 304 622 Security Information and event management: same as EN 304 621
- EN 304 623 Boot Managers:
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- EN 304 625 Network Interfaces: same as EN 304 660 Virtuak Private Networks Part 1:

- EN 304 626 Operating Systems: same as EN 304 660 Virtual Private Networks Part 1:
- EN 304 627 Routers modems and switches:
- EN 304 635 Virtualisation and Container Execution Systems:
- EN 304 636 Firewalls intrusion detection and prevention systems:
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

- a) TBD
- b) We expect to discuss the finalized version of this essential requirement on meeting **MX end January/beg February 2026**.
- c) Anyone interested to contribute - <mailto:simon.dunkley@itron.com>

5.9.3 Mapping with technical controls

5.9.3.1 SO.LimitExternalImpact

The list of technical controls that are applicable:

- 7.13.8 [GEC-8] Product Integrity (EN 18031)
- 7.11.1 [TCM-1] Applicability of and appropriate traffic control mechanisms (EN 18031)
- 7.18 [LIM] Limitation of Negative Impact on External Systems

EXAMPLE

- TBD

5.9.3.1.1 PROPOSAL: SO.LimitExternalImpact

The list of technical controls that are applicable:

- 7.13.8 [GEC-8] Product Integrity (EN 18031)
- 7.11.1 [TCM-1] Applicability of and appropriate traffic control mechanisms (EN 18031)
- [NLM-1]

5.9.3.2 SO.PreventAttackPropagation

The list of technical controls that are applicable:

- 7.11.1 [TCM-1] Applicability of and appropriate traffic control mechanisms (EN 18031)
- [LIM-]

EXAMPLE

— TBD

5.9.3.2.1 PROPOSAL: SO.PreventAttackPropagation

The list of technical controls that are applicable:

- 7.11.1 [TCM-1] Applicability of and appropriate traffic control mechanisms (EN 18031)
- [NLM-1]

5.9.3.3 SO.MonitorExternalImpact (new)

The list of technical controls that are applicable:

- 7.10.1 [NMM-1] Applicability and appropriateness of network monitoring mechanisms (EN 18031)

EXAMPLE

— TBD

5.10 (j) Attack surface minimization

Warning — (j) be designed, developed and produced to limit attack surfaces, including external interfaces;

5.10.1 Description

[TBD]

5.10.2 Mapping threats and security objectives

Table 12

Threats	Security Objectives
Threat.UnnecessaryFunctionalityExploitation: An attacker exploits vulnerabilities in a functionality of the product that is not required for its intended use or core functionality.	SO.ReduceAttackSurface: The product only exposes interfaces (or services), that are necessary for its intended purpose.

Gaps to be solved/notes

EXAMPLE (1)

- Still in definition phase but for sure we will include
- hardening mechanisms
- Documentation
- Input verification
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- EN 304 618 Password manager -
- EN 304 619 Antivirus software -
- EN 304 660 Virtual Private Networks Part 1 -
- EN 304 621 Network Management Systems -
- EN 304 622 Security Information and event management: same as EN 304 621
- EN 304 623 Boot Managers:
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- EN 304 625 Network Interfaces: same as EN 304 660 Virtual Private Networks Part 1:
- EN 304 626 Operating Systems: same as EN 304 660 Virtual Private Networks Part 1:
- EN 304 627 Routers modems and switches:
- EN 304 635 Virtualisation and Container Execution Systems:
- EN 304 636 Firewalls intrusion detection and prevention systems:
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

a) TBD

- We expect to discuss the finalized version of this essential requirement on meeting **MX end January/beg February 2026**.
- Anyone interested to contribute - <mailto:riccardo.sirigu@abissi.eu>, <mailto:laurent.tailleu@idemia.com>

5.10.3 Mapping with technical controls

5.10.3.1 SO.ReduceAttackSurface

The list of technical controls that are applicable:

- 7.13.2 [GEC-2] Limit exposure of services via related network interfaces (EN 18031)
- 7.13.3 [GEC-3] Configuration of optional services and the related exposed network interfaces (EN 18031)
- 7.13.4 [GEC-4] Documentation of exposed network interfaces and exposed services via network interfaces (EN 18031)
- 7.13.5 [GEC-5] No unnecessary external interfaces (EN 18031)
- 7.13.6 [GEC-6] Input validation (EN 18031)

- 7.13.7 [GEC-7] Documentation of external sensing capabilities (EN 18031)
- 7.13.12 [GEC-12] No Unneeded Software Components (NEW)

5.11 (k) Reduce impact of incident

Warning — (k) be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;

5.11.1 Description

[TBD]

5.11.2 Mapping threats and security objectives

Table 13

Threats	Security Objectives
Threat.ExploitationMitigationFailure: An attacker, after compromising a product, causes an impact that is higher than necessary due to missing or bypass of exploitation mitigation mechanism. NOTE 1 Unnecessary functionalities or unnecessary data involvement can lead to a higher attack surface that could have been avoided.	SO.ReduceImpactOfIncident: The product reduces the impact of an incident by exploiting mitigation mechanisms and techniques. NOTE 2 This also includes the goal to minimise escalation, e.g., privilege escalation.

Gaps to be solved/notes

EXAMPLE (1)

- Still in definition phase: this requirement is clearly a process driven requirement but we will focus also in this case on the product capabilities and exploitation mitigation mechanisms and techniques. There is an overlap that need to be still formalize with the aim of minimizing negative impact
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- EN 304 618 Password manager -
- EN 304 619 Antivirus software -
- EN 304 660 Virtuak Private Networks Part 1 -
- EN 304 621 Network Management Systems -
- EN 304 622 Security Information and event management: same as EN 304 621
- EN 304 623 Boot Managers:
- EN 304 624 Public key infrastructure and digital certificate issuance software:

- EN 304 625 Network Interfaces: same as EN 304 660 Virtual Private Networks Part 1:
- EN 304 626 Operating Systems: same as EN 304 660 Virtual Private Networks Part 1:
- EN 304 627 Routers modems and switches:
- EN 304 635 Virtualisation and Container Execution Systems:
- EN 304 636 Firewalls intrusion detection and prevention systems:
- EN 4000X Smart card applications of secure elements:

NOTE **M4X: Suggestion of improvement**

- a) Gabriel: Concern - this essential requirement is not addressed in the vertical - we can provide guidance in PT2.
- c) We expect to discuss the finalized version of this essential requirement on meeting **MX end January/beg February 2026**.
- d) Anyone interested to contribute - <mailto:riccardo.sirigu@abissi.eu>, <mailto:laurent.tailleu@idemia.com>

5.11.3 Mapping with technical controls

5.11.3.1 SO.ReduceImpactOfIncident

The list of technical controls that are applicable:

- 7.13.11 [GEC-11] Exploit mitigation mechanisms (NEW)

EXAMPLE

5.12 (I) Logging and Monitoring

Warning — (I) provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;

5.12.1 Description

[TBD]

5.12.2 Mapping threats and security objectives

Table 14

Threats	Security Objectives
Threat.NotRecordedSecurityActivity: An attacker performs a security relevant activity / change / operation / attack / malicious action that is not logged by the product.	SO.LogSecurityRelevantActivities: The product, by default, provides security related information of detected security anomalies in its recorded internal activity.

Threats	Security Objectives
Threat.NotMonitoredSecurityActivity: An attacker performs a security relevant activity / change / operation / attack / malicious action that is not monitored by the product.	SO.MonitorSecurityRelevantActivities: The product, by default, monitors recorded internal activity for security relevant anomalies.
Threat.UnnecessaryDataLogging: An attacker gains access to data that is not required to be recorded for the intended purpose of a product.	SO.OptionDisableDataLogging: The product provides opt-out and configuration mechanisms for disabling the logging of security relevant internal activity.
Threat.UnnecessaryDataMonitoring: An attacker gains access to data that is not required to be monitored for the intended purpose of a product.	SO.OptionDisableDataMonitoring: The product provides opt-out and configuration mechanisms for the monitoring of security relevant internal activity.

5.12.3 Mapping with technical controls

5.12.3.1 SO.LogSecurityRelevantActivities

The list of technical controls that are applicable:

- 7.6.1 [LGM-1] Logging mechanisms (EN 18031)
- 7.6.2 [LGM-2] Persistent storage of log data (EN 18031)
- 7.6.3 [LGM-3] Minimum number of persistently stored events (EN 18031)
- 7.6.4 [LGM-4] Time-related information of persistently stored log data (EN 18031)
- 7.6.6 [LGM-6] Exclude sensitive personal information (NEW)

EXAMPLE (1)

- TBD

5.12.3.2 SO.MonitorSecurityRelevantActivities

The list of technical controls that are applicable:

- 7.10.1 [NMM-1] Network monitoring mechanisms (EN 18031)
- 7.16.1 [MON-1] Monitor security relevant activities (NEW)

EXAMPLE

- TBD

5.12.3.3 SO.OptionDisableDataLogging

The list of technical controls that are applicable:

- 7.6.5 [LGM-5] Disabling logging (NEW)

EXAMPLE

— TBD

5.12.3.4 SO.OptionDisableDataMonitoring

The list of technical controls that are applicable:

— 7.16.2 [MON-2] Disable monitoring (NEW)

EXAMPLE

— TBD

5.13 (m) Data Deletion

Warning — (m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.

5.13.1 Description

Deletion functionality is intended especially for situations involving a transfer of ownership, disposal, or third-party device maintenance.

This functionality is also important when a device is used by multiple users (e.g., an infotainment system in a car rental situation). The ideal scenario is that the user should be able to delete all their data and configuration, leaving the system ready for the next user.

Due to its nature a deletion functionality can potentially present an **attack vector** and therefore it is important that only authorized users are allowed to execute this function.

5.13.2 Mapping threats and security objectives

Table 15

Threats	Security Objectives
Threat.DeletedDataDisclosure: An attacker extracts deleted data and/or settings.	SO.SecureDataDeletion: The product provides to the user easy-to-use function to permanently (and securely) remove all user-related data and settings from the product, especially during the disposal and decommissioning process.
	SO.SecureDisposalByUser: The product provides an easy-to-use function to the user. Proposal - This SO doesn't add anything to what is already captured by previous threat. Proposal to be removed. M55: — decided to remove
Refer to ECR ANNEX I Part I (2) (e) of (EU) 2024/2847 Threat.DataInTransitDisclosure: An attacker discloses confidential data transferred to or from a product.	SO.DataTransmittedConfidentiality: The product protects the secrecy of confidential data with secure communication functionality.
	SO.ComAuth: The product authenticates communication partners.

Threats	Security Objectives
Refer to ECR ANNEX I Part I (2) (f) of (EU) 2024/2847 Threat.DataInTransitTampering: An attacker tampers data transferred to or from a product.	SO.DataTransmittedIntegrity: The product protects the integrity of transmitted data with secure communication functionality.
	SO.ComAuth: The product authenticates communication partners.

Gaps to be solved/notes

EXAMPLE (1)

- How to take in consideration the data deletion for data in transit – this can be done on a communication level (SCM)
- Having a SO.ComAuth maybe redundant or not contextualize for data deletion but of course you expect that only the authorized entity could execute this function
- Gitlab: <https://labs.etsi.org/rep/stan4cra>
- Latest standard: <https://docbox.etsi.org/CYBER/EUSR/Open>

Warning — Vertical analysis and highlights:

- EN 304 617 Browser -
- DOM-REQ-6 (Storage isolation enables secure per-origin deletion),
- ENC-REQ-1 (TLS 1.3+ for secure transfer),
- ENC-REQ-3 (Certificate pinning for critical transfers),
- ENC-REQ-5 (Mixed content blocking),
- EMB-REQ-17 (Certificate validation for embedded content transfers),
- EMB-REQ-21 (Mixed content prevention),
- EMB-REQ-27 (Network security configuration),
- SYS-REQ-24 (Storage quotas with cleanup mechanisms),
- EXT-REQ-11 (Extension storage isolation enables clean uninstall)
- EN 304 618 Password manager -
- IEF-REQ-1; IEF-REQ-5; PKY-REQ-9; PKY-REQ-11
- IEF-REQ-1 [IEF-0→IEF-T1]: SHALL provide encrypted export option as default
- IEF-REQ-5 [IEF-0→IEF-T1,IEF-T4]: SHALL require user verification for export operations
- PKY-REQ-9 [PKY-0→PKY-T1]: SHOULD support migration of passkeys in encrypted format (e.g., FIDO Credential Exchange Protocol)

- PKY-REQ-11 [PKY-0→PKY-T2]: MAY support WebAuthn Signal API for receiving passkey management 1412 information from services
- EN 304 619 Antivirus software -
- 5.2.13 Data Removal and Transference Mechanisms
- REQ-DRT-01: The product shall provide a fallback behaviour mechanism if update procedures fail.
- EN 304 660 Virtual Private Networks Part 1 -
- SCDL, SDTR
- 5.2.16 TR-SCDL: Secure deletion
- 5.2.16.2 MI-RSET: Secure deletion via reset
- 5.2.16.3 MI-INST: Secure deletion via reinstallation
- 5.2.16.4 MI-DELE: Secure deletion via secure deletion function
- 5.2.17 TR-SDTR: Secure data read and transfer
- 5.2.17.2 MI-SDRF: Secure data read from product
- 5.2.17.3 MI-SDTR: Secure data transfer to another product
- EN 304 621 Network Management Systems -
- [REQ-METRICS-3], 5.2.1 Secure channel definition
- Not sure I even understand the mapping in this case.....
- EN 304 622 Security Information and event management: same as EN 304 621
- [REQ-METRICS-3], 5.2.1 Secure channel
- Not sure I even understand the mapping in this case.....
- EN 304 623 Boot Managers:
- 5.5.7, 5.5.8
- 5.5.7
- [RQ-CONFID-007] Requirement: The boot manager shall protect the confidentiality and integrity of boot configuration data transmitted over network.
- 5.5.8
- [RQ-CONFID-008] Requirement: The boot manager shall overwrite confidential or secret data after use, clear from memory temporary data structures and credentials before boot target handoff and not persist authentication credentials or confidential cryptographic material beyond the current boot cycle.
- EN 304 624 Public key infrastructure and digital certificate issuance software:
- 5.8 Certificate suspension and revocation

- REFERENCE: REQ-5.8-01 - REQUIREMENT: Once a certificate is revoked, it shall not be reinstated.
NOTE: Revocation is intended to be a definitive action, from which this requirement stems.
- REFERENCE: REQ-5.8-02 953 - REQUIREMENT: Requirements CSS-6.3.9-06, CSS-6.3.9-08, CSS-6.3.9-12 and CSS-6.3.9-13 954 contained in ETSI EN 319 411-1 [6] shall apply.
- EN 304 625 Network Interfaces: same as EN 304 660 Virtual Private Networks Part 1:
- SCDL, SDTR
- EN 304 626 Operating Systems: same as EN 304 660 Virtual Private Networks Part 1:
- SCDL, SDTR
- EN 304 627 Routers modems and switches:
- Clauses 5.4.2 and 5.11
- 5.4.2 [RESET] Factory reset
- 5.4.2.1 General
- Factory reset mechanisms shall remove all data and user configurations while leaving the current running software and the firmware versions in place. The factory reset deletes also the user login credentials leading to the initial setup procedures.
- [RESET-1-RQ-1-01] The product shall provide a factory reset mechanism that restores the product to its secure-by- default configuration.
- [RESET-1-RQ-1-02] The product shall provide a factory reset mechanism that maintains the currently installed firmware version and all applied security updates.
- [RESET-1-RQ-1-03] The product shall require authentication and authorization at the highest privilege level for any factory reset initiated through software, management interface, or remote command.
- [RESET-1-RQ-1-04] Upon successful factory reset, the product shall not retain any information that could be used to reconstruct previous configuration or compromise user privacy.
- 5.11 Data management
- 5.11.1 [TRANSFER] Secure data export and transfer
- 5.11.1.1 General This subclause addresses the requirement for secure data portability between products, enabling users to migrate configurations, operational data, and system state without compromising security. Configuration files for routers, modems intended for connection to the internet, and switches contain sensitive information including credentials, cryptographic keys, network topology details, and security policies that require protection during export and transfer. The transfer mechanism ensures data exports are encrypted to maintain confidentiality even if transfer media is compromised or intercepted, while preventing unauthorized modification that could compromise the target system upon import.
- 5.11.1.2 Requirements [TRANSFER-1-RQ-1-01] The product shall support secure data export, allowing users to transfer the exported data over encrypted channel.
- [TRANSFER-1-RQ-1-02] The product shall support secure data import, allowing users to import data in the product 1444 over encrypted channel.
- [TRANSFER-1-RQ-1-03] The product shall provide capability to encrypt exported data using best practice encryption algorithms, with encryption applied based on user preference during export.
- [TRANSFER-1-RQ-1-04] The product shall require administrative access for export operations.
- [TRANSFER-1-RQ-1-05] The product shall require administrative access for import operations.

- [TRANSFER-1-RQ-1-06] The product shall generate audit events for all export and import operations.
- [TRANSFER-1-RQ-1-07] The product shall store audit events in persistent memory that survives the reset.
- EN 304 635 Virtualisation and Container Execution Systems:
- Hypervisor: 5.1.1.5 5.1.1.9
- 5.1.1.5 Confidentiality Protection .
- 5.1.1.9 Secure Configuration and Default
- EN 304 636 Firewalls intrusion detection and prevention systems:
- Clause 5.4.3 ?????? Update ? instead of deletion
- EN 4000X Smart card applications of secure elements:

5.13.3 Mapping with technical controls

5.13.3.1 SO.SecureDataDeletion

The list of technical controls that are applicable:

- 7.7.1 [DLM-1] Secure Data deletion mechanisms (Applicability of deletion mechanisms) (EN 18031)
- [DLM-2] Confidential export of user data (NEW)
- [DLM-3] Integrity protected of exported data (NEW)
- [DLM-4] Authenticity of the communication partner for export of data (NEW)

EXAMPLE

- TBD

5.13.3.2 SO.DataTransmittedConfidentiality

Warning — is covered in *ECR ANNEX I Part I (2) (e) of (EU) 2024/2847*

5.13.3.3 SO.ComAuth

Warning — is covered in *ECR ANNEX I Part I (2) (e) and Part I (2) (f) of (EU) 2024/2847*

5.13.3.4 SO.DataTransmittedIntegrity

Warning — is covered in *ECR ANNEX I Part I (2) (f) of (EU) 2024/2847*

6 TO BE DELETED

Security objectives and their mappings to threats were moved into clause 5 specific sections.

7 Technical Controls

7.1 [ACM] Access control mechanism

EXAMPLE (d) ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;

7.1.1 [ACM-1] Void

NOTE This requirement is a placeholder to maintain the numbering of RED

[ACM-1] and [ACM-2] were merged into [ACM-2]

7.1.2 [ACM-2] Access control mechanisms (Appropriate access control mechanisms)(EN 18031) (MERGE ACM-1 ACM2)

7.1.2.1 Requirement

The product shall use access control mechanisms to manage entities' access to assets, ensuring that only authorized entities have access to the protected assets.

7.1.2.2 Rationale

The aim of this requirement is to limit the ability of any unauthorized entity to access these assets, ensuring that these assets are protected from unauthorized access.

This requirement is necessary as assets might be exposed to unauthorized access attempts.

NOTE THIS NOTE WILL BE REMOVED WHEN THE SECTION 5 WILL BE FINALIZED.

This requirement is necessary to meet the essential cybersecurity requirement (d) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnauthorizedAccess and to meet the corresponding security objective **SO.AccessControl** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.1.2.3 Guidance

Access control mechanisms need properties to tie access rights to. Such properties can amongst others be:

- verified claims of entities (for instance being owner of a user account, member of specific group, authorized by another entity);
- certain states of the equipment or the equipment's environment (for instance an electronic flight bag might have different access rights for a local user when it is operated in the air, than when it is stored at the ground);
- the external interface an access is performed from (for instance a local access, where physical access control is obviously in place, might have different access rights than a remote access);
- various combinations of the properties mentioned, as well as additional ones.

This requirement is intended to ensure that the access control mechanisms used to protect the assets are chosen and configured such that unauthorized access is denied. With a variety of asset access methods and control mechanisms (for instance display on a wearable's screen), equipment

use-cases and operational environments, it is difficult to specify a generic model for entities and associated access rights.

Whether an access control mechanism can deny unauthorized access, always depends on external assumptions that need to be fulfilled. For example, that the sharing of passwords or unauthorized physical access are not permitted.

Depending on the product's technical properties, intended operational environment of use, the access control mechanisms use appropriate properties to tie access rights to and that all involved entities are provided with authorization information.

When access control mechanisms rely on authentication mechanisms, see AUM, for example:

- an authorized entity, e.g., specific human, owner of a user account, device, or service, can after authentication access their asset, such as changing security configuration; or
- a member of specific authorized groups can after authentication access an asset; or
- an entity, authorized by another entity to do so, can access a specific asset.

For the determination of the appropriate access control mechanisms on assets the following aspects are important:

- the risk associated with an entity's access to an asset,
- the form of access an equipment's functionality allows to an asset,
- the external interface the asset is accessed through and
- the impact of access control provided by the intended operational environment of use.

For the determination of entities' access rights on assets (authorized entities for certain access on assets), the following aspects are important:

- the risk associated with an entity's access to an asset,
- the "need-to-know principle": Does an entity need to obtain some information to an asset,
- the "need-to-use principle": Does an entity have a valid need to use a functionality based on an asset,
- the "least privileges principle": everything is forbidden unless permitted,
- the equipment's clearly advertised functionality, e.g., concerning accessibility of assets or interoperability with components of an existing infrastructure.

Common access control mechanisms as declared in the implementation categories of the EN 18031 series [i.x] are the following: role-based access control (RBAC), discretionary access control (DAC) and mandatory access control (MAC).

Assessments based on RBAC may include to functionally confirm that:

- roles are assigned to each user with associated authorization; and
- least privileges are associated with the roles; and

- the asset is only accessible by authorized users given by their role; and
- changes in roles can only be performed by authorized users.

Assessments based on DAC may include to functionally confirm that:

- identities are assigned to each user with associated authorization; and
- least privileges are associated with the identities; and
- the asset is only accessible by authorized users given by their identity; and
- changes in identities can only be performed by authorized users.

Assessments based on MAC may include to functionally confirm that:

- the asset is only accessible by authorized users after clearance was issued by the operating system and/or system administrator; and
- the issuance of clearance is associated with the principle of least privileges; and
- changing the operating system and/or system administrator that is responsible for the issuance of clearance to the user can only be performed by the authorized system administrator.

Assessments based on other access control mechanism may include to functionally confirm that:

- the asset is only accessible by authorized users; and
- the principle of least privileges for users is followed; and
- changing settings related to the access control mechanism or changes of privileges of users are only allowed to be performed by authorized users.

7.1.2.4 Assessment

7.1.2.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.1.2.4.2 Conceptual assessment

7.1.2.4.2.1 Assessment purpose

7.1.2.4.2.2 Assignment of verdict

7.1.2.4.3 Functional sufficiency assessment

7.1.2.4.3.1 Assessment purpose

7.1.2.4.3.2 Assignment of verdict

7.2 [AUM] Authentication mechanism

7.2.1 [AUM-1] Authentication mechanisms (EN 18031) (VOID)

7.2.1.1 [AUM-1-1] Requirement network interface (EN 18031) (VOID)

void

7.2.1.2 [AUM-1-2] Requirement user interface (EN 18031) (VOID)

void

7.2.1.3 [AUM-1-3] Requirement machine interface (EN 18031) (VOID)

void

7.2.2 [AUM-2] Appropriate authentication mechanisms (EN 18031)

7.2.2.1 [AUM-2-1] Requirement one-factor authentication (EN 18031)

The product shall use authentication mechanisms for access to assets by verifying an entity's claim based on evidence from at least one element of the categories knowledge, possession and inference (one-factor authentication).

7.2.2.2 [AUM-2-2] Requirement multi-factor authentication (EN 18031)

The product shall use authentication mechanisms for access to assets by verifying an entity's claim based on evidence from at least two different elements of the categories knowledge, possession and inference (multi-factor authentication).

7.2.2.3 Rationale

The aim of the requirements is that the product needs to provide an authentication mechanism for the identification and authentication of entities such that the corresponding access control mechanism prevents unauthorized access to assets that can be used for fraud from entities which are not who or what they claim to be.

The requirements are necessary as authentication is suitable to prevent unauthorized access to assets that can be used for fraud from entities which are not who or what they claim to be. The management of associated access rights for entities is addressed by access control mechanisms. For instance, the ability to perform financial transactions over a network needs strong user authentication to deny fraudulent transactions over the network, e.g., based on weak user passwords. Therefore at least two factor authentication is required in this case.

NOTE THIS NOTE WILL BE REMOVED WHEN THE SECTION 5 WILL BE FINALIZED.

The requirements are necessary to meet the essential cybersecurity requirement (d) of Regulation 2024/2847. They are also necessary to cover the threat `Threat.UnauthorizedAccess` and to meet the corresponding security objective **SO.AccessControl** as described in the PT2 TR. They might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.2.2.4 Guidance

Authentication mechanisms might use different layers (e.g., application or network layer) for verifying the validity of entities' claims. The management of associated access rights for entities are addressed by access control mechanisms.

There are different kinds of entities that can interact with the product, e.g.:

- a specific human, owner of a user account, device or service; or
- a member of specific groups such as an authorized group to access a specific product's resource; or
- authorised by another entity to access a specific product's resource.

Typically, the verification of an entity is based on examining evidence from one or more elements of the categories:

- knowledge (something you know); and
- possession (something you have); and
- inherence (something you are).

A trust relation to a network (e.g., an entity owns a shared secret like Wi-Fi credentials) could be used to authenticate an entity.

Authentication might not be needed for all accesses to assets.

Examples of access where authentication might not be mandatory are amongst others:

- reading information which is clearly advertised as publicly accessible information related to the intended product functionality; or
- reading a public key.

Examples of physical or logical measures in the targeted environment that provide confidence in the correctness of an entity's claim might be amongst others:

- physical access control that only allows authorized access to the inside of personal road vehicles or watercrafts; or
- physical access control that only allows authorized access e.g., to a WPS button of a home gateway to attach other devices to a Wi-Fi network within a private house.

Examples for a verification of an entity's claim based on examining evidence from one element of the categories, knowledge, possession and inherence, are:

- PIN-Code used for user interface
- 1-Factor (e.g., password based) of each incoming connection on a user or network interface
- fingerprint biometrics or face recognition for a user interface
- verifying the possession of a private key that matches to a trusted certificate
- trust relation to a network (e.g., based on a common secret) established at on-boarding.

Examples for a verification of an entity's claim based on evidence derived from at least two different elements of the categories, knowledge, possession and inherence, are:

- Password + OTP
- PIN + Smartcard
- Password + Token

If a user is accessing the product through a software application running on another device, such as a maintenance application running on a server or laptop, this can, depending on the architecture, be considered a software process accessing the product. Hence, the authentication for software processes can apply. Strong authentication, including possibly multi-factor authentication, can be used for the user to authenticate to the external software application. It is also possible to use cryptographic measures to create a trust relationship between the product and another device such that the possession of the other device can be considered as one authentication factor. The two-factor authentication to access the product might be ensured through another device in the operational environment of the product.

Here, the primary product's intended functionality for specifically processing personal information of special categories means that product cannot be used for its intended functionality without processing personal information of special categories. It is therefore specifically designed to process such data.

Product whose intended functionality is to process any data which only could possibly include personal information of special categories such as desktop pcs, smartphones, cameras or printers needs only foresee protection for personal data. Generally, when designing product to store personal data, it is reasonable to consider providing multifactor authentication.

Considering possible constraints of human users with disabilities is an important aspect for implementing appropriate authentication mechanisms. Examples of considerations when selecting authentication mechanisms include:

- transferring the authentication information to and from a relevant assistive technology,
- enabling a dual or shared use when the product is in use by a user and a support worker (and/or parent and child),
- offering alternative authentication mechanisms so that they are useable by a user with specific learning impairments (including dyslexia) and do not trigger negative feelings (e.g., by avoiding specifying family or personal information which may be distressing or not relevant for the end user).

At the time of publishing the present document long passwords like "WeihnachtsmarkTElephanTCarpeT2023@Bon(n)" are considered stronger passwords than

short passwords like “P@ssw0rd!” and more guidance on current best practice on passwords can be found in NIST Special Publication 800-63B [i.x], ISO/IEC EN 27002:2022 [i.x], ISO/IEC EN 24760 [i.x], IEC EN 62443-4-2 [i.x] and ETSI EN 303 645 [i.x].

7.2.2.5 Assessment

7.2.2.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.2.2.5.2 Conceptual assessment

tbd

7.2.2.5.2.1 Assessment purpose

tbd

7.2.2.5.2.2 Assignment of verdict

tbd

7.2.2.5.3 Functional sufficiency assessment

tbd

7.2.2.5.3.1 Assessment purpose

tbd

7.2.2.5.3.2 Assignment of verdict

tbd

7.2.3 [AUM-3] Authenticator validation (EN 18031)

7.2.3.1 Requirement

Authentication mechanisms shall validate all relevant properties of the used authenticators, dependent on the available information of the authenticator in the operational environment of use.

7.2.3.2 Rationale

Even when the product provides an authentication mechanism, the risk is given that an attacker uses typical design weaknesses to overcome it.

The aim of this requirement is that authentication mechanisms implemented in the product resist the usage of forged or partially forged authenticators which are often used for an attack against such a mechanism. Therefore, the security design of the mechanisms needs techniques to resist forged authenticators, for example manipulated PKI certificates, here needs the content and the signature of the certificate to be validated.

This requirement is necessary because attackers may exploit common design weaknesses to overcome an authentication mechanism, e.g. by using forged or partially forged authenticators.

NOTE THIS NOTE WILL BE REMOVED WHEN THE SECTION 5 WILL BE FINALIZED.

This requirement is necessary to meet the essential cybersecurity requirement (d) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnauthorizedAccess and to meet the corresponding security objective **SO.AccessControl** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.2.3.3 Guidance

The authenticator and its attributes vary depending on the authentication mechanism. For the validation of the authenticator, best practice ought to be applied for the corresponding authentication mechanism. This is necessary in order to detect and prevent the use of an authenticator that is invalid. For example, if the product only validates the common name of a PKI certificate without further validation of the complete certificate information, then a correspondingly forged authenticator would be accepted. In this example, the relevant properties of the authenticator are the signatures and public keys of the trust chain, the revocation status and in many cases also the validity of the certificate. The set of relevant properties can differ depending on whether the product is actually internet connected or not. For example, offline product probably does not have access to a reliable time source or to certificate revocation information.

Another example for insufficient validation of authenticators is, if only parts of the password is checked. This would weaken the strength of the password, facilitating brute force attacks on the corresponding authentication mechanism.

Editor's note: implementation categories have not been added yet as described in the template as PT2 has still to decide on how to deal with the assessment criteria.

7.2.3.4 Assessment

7.2.3.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.2.3.4.2 Conceptual assessment

tbd

7.2.3.4.2.1 Assessment purpose

tbd

7.2.3.4.2.2 Assignment of verdict

tbd

7.2.3.4.3 Functional sufficiency assessment

tbd

7.2.3.4.3.1 Assessment purpose

tbd

7.2.3.4.3.2 Assignment of verdict

tbd

7.2.4 [AUM-4] Changing authenticators (EN 18031)

7.2.4.1 Requirement

Authentication mechanisms shall allow for changing the authenticator except for authenticators where conflicting security goals do not allow for a change.

7.2.4.2 Rationale

The aim of this requirement is the support for changing authenticators on the product as it is needed as a countermeasure. Moreover, for password-based authentication the changing of passwords in a regular interval has proven to increase the security.

This requirement is necessary because Static authenticators can be a security risk for the product, e.g., increased vulnerability to brute force and eavesdropping attacks.

A static authenticator can be part of the security design of a product, e.g. a static root key for secure booting. Therefore, it is not possible to change the authenticator in such a case.

NOTE THIS NOTE WILL BE REMOVED WHEN THE SECTION 5 WILL BE FINALIZED.

This requirement is necessary to meet the essential cybersecurity requirement (d) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnauthorizedAccess and to meet the corresponding security objective **SO.AccessControl** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.2.4.3 Guidance

An authorised entity needs the possibility to change the authenticator. The procedure can vary depending on the authentication mechanism used.

- The product provides a functionality to the authorised entity, e.g., user, to change the authenticator on the product.
- The authenticator, e.g., token, is renewed or changed by the manufacturer and the product accepts the changed authenticator because the trust chain is still valid.
- The authenticator is updated using a secure update mechanism.

In case of machine interfaces new pairing can be necessary. The integration of the change of the authenticator in the normal workflow simplifies the procedure for the user. This procedure depends on the selected authenticator (e.g., fingerprint, password or token).

There can be use cases where a static authenticator is acceptable, such as a root of trust where the confidentiality of the corresponding cryptographic key is ensured by the manufacturer. In such an example the manufacturer typically provides tokens to authorized entities that are all linked to the same root of trust.

There can also be exceptions, where the overall risk of changing an authenticator, e.g., due to complexity, outweighs the risk associated with the assets when using static authenticators. In such cases, it's important to consider best practice security design principles to minimize the risk associated with the static authenticator, for example, by avoiding the use of global authenticators.

Depending on the intended product functionality it might be needed to ensure the availability of the product functionality due a deferral option, e.g. not forcing the update of a password whilst driving a car.

NOTE Editor's note: implementation categories have not been added yet as described in the template as PT2 has still to decide on how to deal with the assessment criteria.

7.2.4.4 Assessment

7.2.4.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.2.4.4.2 Conceptual assessment

tbd

7.2.4.4.2.1 Assessment purpose

tbd

7.2.4.4.2.2 Assignment of verdict

tbd

7.2.4.4.3 Functional sufficiency assessment

tbd

7.2.4.4.3.1 Assessment purpose

tbd

7.2.4.4.3.2 Assignment of verdict

tbd

7.2.5 [AUM-5] Password strength (EN 18031)

7.2.5.1 [AUM 5-1] Requirement for factory default passwords (EN 18031)

If factory default passwords are used by an authentication mechanism they shall:

- be unique per product; and
- follow best practice concerning strength; or
- be enforced to be changed by the user before or on first use.

7.2.5.2 [AUM 5-2] Requirement for password handling (EN 18031)

If passwords, other than factory default passwords, are used by an authentication mechanism they shall:

- be enforced to be set by the user before or on first use and before the product is logically connected to a network; or
- be defined by an authorized entity within a network where access is limited to authorised entities; or
- be generated by the product using best practice concerning strength and only communicated to an authorized entity within a network where access is limited to authorised entities.

7.2.5.3 Rationale

The aim of this requirement is to enforce distinct passwords when set at the factory or user/entity defined passwords for each piece of product during their initial setup.

This requirement is necessary because weak passwords like universal passwords represent one of the most exploited attack vectors for product. There is a wide range of malware that uses such passwords to automatically compromise product.

NOTE THIS NOTE WILL BE REMOVED WHEN THE SECTION 5 WILL BE FINALIZED.

This requirement is necessary to meet the essential cybersecurity requirement (d) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnauthorizedAccess and to meet the corresponding security objective **SO.AccessControl** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.2.5.4 Guidance

There is a variety of techniques to avoid universal passwords, examples are:

- The product password for the factory default state is printed on a sticker under the product casing. The password is created by using a True Random Number Generator or another cryptographically secure pseudorandom number generator (CSPRNG) implementation.
- The product prompts a user to create a password on the first use.

It is highly recommended to follow well established standards for the secure generation of random numbers used to generate secure passwords. There are numerous well-recognised publicly available standards for random number generation mechanisms which have undergone peer review. Well established examples for such standards are NIST SP 800-90A Rev.1 [x], NIST SP 800-90B[x], NIST SP 800-90C[x], BSI AIS31[x].

Guidance on best practice on passwords can be found in NIST SP 800-63B [0](#), ISO/IEC EN 27002:2022 [x], ISO/IEC EN 24760 [x], IEC EN 62443-4-2 [x] and ETSI EN 303 645 [x]

Unique relates to not systematically reused or deducible for another product of the same product type and cannot be easily derived from product properties (e.g., manufacturer name, model name or Media Access Control (MAC) address). Established random generator can be used to generate practically unique passwords.

When enforcing a password change, safety aspects are also relevant, such as not forcing a password change while driving a car.

NOTE Editor's note: implementation categories have not been added yet as described in the template as PT2 has still to decide on how to deal with the assessment criteria.

7.2.5.5 Assessment

7.2.5.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.2.5.5.2 Conceptual assessment

tbd

7.2.5.5.2.1 Assessment purpose

tbd

7.2.5.5.2.2 Assignment of verdict

tbd

7.2.5.5.3 Functional sufficiency assessment

tbd

7.2.5.5.3.1 Assessment purpose

tbd

7.2.5.5.3.2 Assignment of verdict

tbd

7.2.6 [AUM-6] Brute force protection (EN 18031)

7.2.6.1 Requirement

Authentication mechanisms shall be resilient against brute force attacks.

7.2.6.2 Rationale

The aim of this requirement is that a design of the mechanism is required to mitigate the impact of brute force attacks.

This requirement is necessary as an attacker can try to use mass authentication attempts to overcome an authentication mechanism or to impact product availability.

NOTE THIS NOTE WILL BE REMOVED WHEN THE SECTION 5 WILL BE FINALIZED.

This requirement is necessary to meet the essential cybersecurity requirement (d) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnauthorizedAccess and to meet the corresponding security objective **SO.AccessControl** as described in the PT2 TR. It might also help to meet

other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.2.6.3 Guidance

Techniques for brute force protection of authentication mechanisms include e.g.:

- Time delays between consecutive failed attempts to authenticate;
- A limited number of failed authentication attempts followed by a suspension period where no login is allowed;
- Multi-factor authentication;
- Appropriate strength for authentication values based on best practice cryptography;
- Machine-to-machine authentication might implement mitigation measures such as:
 - long password (more than 16 characters and high complexity);
 - list of allowed IP addresses;
 - warning/logging mechanism in machine-to-machine interface.
- Depending on the implemented techniques, related risks concerning "resource exhaustion" and "denial of service" need to be considered.

Consideration is to be given to mitigating the impact of repeated attempts to gain illegitimate authentication and mitigate the blocking of legitimate access by triggering the preceding defence mechanism.

See NIST 800-63 series [i.x]

NOTE Editor's note: implementation categories have not been added yet as described in the template as PT2 has still to decide on how to deal with the assessment criteria.

7.2.6.4 Assessment

7.2.6.4.1 Assessment objective

tbd

7.2.6.4.2 Conceptual assessment

tbd

7.2.6.4.2.1 Assessment purpose

tbd

7.2.6.4.2.2 Assignment of verdict

tbd

7.2.6.4.3 Functional sufficiency assessment

tbd

7.2.6.4.3.1 Assessment purpose

tbd

7.2.6.4.3.2 Assignment of verdict

tbd

7.3 [SUM] Secure Update Mechanism (EN 18031)

7.3.1 [SUM-1] Updateability

7.3.1.1 Requirement

The product shall support the ability to update all non-immutable software components.

7.3.1.2 Rationale

Having the ability to provide and deploy software updates through an update mechanism is an essential capability. It helps in maintaining product, addressing security vulnerabilities, and preventing potential exploitation that could compromise the product. Such compromises can pose risks to the network, disrupt its functioning, or lead to the misuse of network resources, resulting in an unacceptable degradation of service.

However, some parts of the software might be immutable and therefore not updatable for technology reasons or functional safety implications do not allow their updatability. Vulnerabilities might also be mitigated by alternative measures, such as exchanging vulnerable product throughout the entire life cycle or being securely mitigated by other product that ensures the protection of the security assets and privacy assets.

NOTE 1 Modification provided by Riccardo:

Components of a product with digital elements can be expected, over their installed lifetime, to require updates and upgrades. Supporting measures for this purpose may be provided, for example, by an underlying operating system or other supporting components. In this context, the ability to provide and deploy software updates through a reliable update mechanism is an essential capability.

Such a mechanism ensures the continued and secure operation of the product by addressing security vulnerabilities and preventing their potential exploitation. If left unmitigated, these vulnerabilities may compromise the product, pose risks to the network, disrupt its functioning, or lead to the misuse of network resources, ultimately resulting in unacceptable service degradation.

However, certain components of a product may be immutable due to technological constraints or functional safety considerations that prevent their modification. In such cases, vulnerabilities may need to be addressed through alternative mitigation measures, such as replacing the affected components or products during their lifecycle, or relying on other components that ensure the protection of the product's assets.

The aim of this requirement is to ensure that the product maintains an effective capability to address security vulnerabilities throughout its life cycle by means of a software update mechanism, while recognising that technical or safety constraints may limit the updatability of certain components.

This requirement is necessary because the absence of an update capability may prevent timely remediation of vulnerabilities, thereby increasing the risk of exploitation and potential compromise of the product, the network, and associated assets.

NOTE 2 This section can be deleted once there will be alignment with section 5

This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (c) of Regulation 2024/2847. It is also necessary to cover the threats [Threat.UnpatchableVulnerabilityExploitation] and to meet the corresponding security objective **[SO.Updateability]** as described in the [4]. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the [4].

7.3.1.3 Guidance

There might be more than one update mechanism for different parts of the software. However, this requirement demands at least one update mechanism for each software of the product **where no except criteria applies**.

NOTE Doubts:

1. We remove the exception criteria so this I believe should go away
2. In the proposal from riccardo in the requirement the affecting the assets was removed - this is the reason why is important to bring it back in

Not all software on the product can be updatable. This can include software stored in non-updatable memory due to the technology or to satisfy functional safety requirements or legal requirements.

There are cases where alternative measures exist to prevent harm from potential known exploitable vulnerabilities in parts of the software or where an exploitable vulnerability in its software might not endanger the assets of the product to be protected. For instance:

- products having a replacement strategy, e.g., for products with limited resources such as sensors that would have to work on battery for many years; or
- products or parts of the software, which can and are foreseen to be securely isolated; or
- the system of which the product is part of mitigates the exploit of any vulnerability.

Where it is possible, it is good practice to implement a software update mechanism that allows for separate security related software updates and application software updates.

7.3.1.4 Assessment

NOTE Insert abbreviated assessment process after PoC Draft release, unless convenient to add notes whilst drafting the requirement.

7.3.1.4.1 Assessment objective

The assessment addresses the requirement SSU.

7.3.1.4.2 Required Information

[E.Info.SSU-1.PartOfSoftw]: Description of each part of the software affecting the assets of the product including:

- (if the part of the software is not updatable for functional safety implications) [E.Info.SSU-1.PartOfSoftw.FuncSaftyImp]: Description of:
 - the functional safety requirements and their source; and
 - the software's function relation to the functional safety requirements
- (if the part of the software is not updatable because it is immutable) [E.Info.SSU-1.PartOfSoftw.Immutable]: Description of the methods that ensure that the part of the software is immutable; and
- (if the part of the software is not updatable because alternative measures exist) [E.Info.SSU-1.PartOfSoftw.AltMeasures]: Description of:
 - the assets the part of the software affects; and
 - the alternative measures that protect the affected assets esp. in case of a known exploitable vulnerability affecting the assets; and
 - the expected life cycle of the equipment
- (if the part of the software is updatable) [E.Info.SSU-1.PartOfSoftw.SSU]: Description of the update mechanisms that can update the part of the software.

[E.Just.SSU-1]: Justification for applicability or non-applicability of the requirement SSU. In case the requirement is not fulfilled but applicable, an additional justification is to be provided to explain why the requirement is not fulfilled.

7.3.1.4.3 Conceptual assessment

7.3.1.4.3.1 Assessment purpose

The purpose of this assessment case is the conceptual assessment whether an update mechanism is implemented when it is required per SSU-1.

7.3.1.4.3.2 Preconditions

None

7.3.1.4.3.3 Assessment Units

For each software affecting the product's assets as documented in [E.Info.SSU-1.PartOfSoftw], determine whether at least one of the following conditions is appropriately claimed and supported:

- the software is not updateable due to functional safety reasons;
- the software is immutable;
- the software is not updateable because alternative measures exists;
- the software is updateable, in which case confirm that at least one update mechanism for updating the part of the software exist;

In addition, examine the justification documented in [E.Just.SSU-1]

7.3.1.4.3.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- For **each** software affecting the product's assets as documented in [E.Info.SSU-1.PartOfSoftw] at least one of the following conditions applies:
- the software is not updateable due to functional safety reasons;
- the software is immutable;
- the software is not updateable because alternative measures exist;
- the software is updateable, and at least one update mechanism exists for updating the part of the software;
- The justifications provided in [E.Just.SSU-1] are correct for all documented cases.

The verdict FAIL for the assessment case is assigned if:

- For **any** software affecting the product's assets as documented in [E.Info.SSU-1.PartOfSoftw] none of the following conditions apply:
- the software is not updateable due to functional safety reasons;
- the software is immutable;
- the software is not updateable because alternative measures exists;
- the software is updateable, and at least one update mechanism exists for updating the part of the software;
- The justifications provided in [E.Just.SSU-1] are invalid for at least one documented case.

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

7.3.1.4.4 Functional assessment

7.3.1.4.4.1 Assessment purpose

The purpose of the functional assessment is to

- verify that each part of the software affecting the product's assets is documented in [E.Info.SSU-1.PartOfSoftw];
- verify whether an update mechanism is implemented when required per SSU-1.

7.3.1.4.4.2 Preconditions

The equipment is in an operational state.

For each update mechanism described in [E.Info.SSU-1.PartOfSoftw.SSU], the manufacturer provides an updated software package (hereafter referred to as SW-a) intended to be applied using that mechanism.

7.3.1.4.4.3 Assessment Units

Functionally assess whether for each software affecting the product's assets as documented in [E.Info.SSU-1.PartOfSoftw], at least one of the following conditions applies:

- the software is not updateable due to functional safety reasons;
- the software is immutable;
- the software is not updateable because alternative measures exists, and those measures are implemented and effective;
- the software is updateable, and at least one update mechanism for updating the part of the software is implemented;

7.3.1.4.4.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- all software affecting the product's assets are documented in [E.Info.SSU-1.PartOfSoftw],
- for each software component documented, there is no evidence that contradicts the claimed condition (i.e., non-updateable due to functional safety, immutable, non-updateable due to alternative measures, or updateable with at least one functional update mechanism);
- for each updateable software component, the corresponding update mechanism is functional and allows applying SW-a as intended.

The verdict FAIL for the assessment case is assigned if:

- any software affecting the product's assets is not documented in [E.Info.SSU-1.PartOfSoftw],
- for any software component, the claimed condition is contradicted by functional testing (i.e., a component claimed to be immutable is actually updateable); or
- an updateable software component doesn't have at least one functional update mechanism allowing the installation of SW-a.

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

7.3.2 [SUM-2] Secure updates Integrity and Authenticity (EN 18031)

7.3.2.1 Requirement

The integrity and authenticity of any software update or upgrade prior to installation shall be validated either directly by the product or by supporting measures.

NOTE Supporting measures can be that the validation is done by other means, for instance the authenticity of an update is checked by the installer application on the operating system and not by the low level device (e.g., a driver chip) in the product.

7.3.2.2 Rationale

A secure software update mechanism ensures that the software that controls the product cannot be tampered with through attacks on the update mechanism. Without appropriate security measures, attackers may exploit the update mechanism to inject malicious code, compromise system integrity, or gain unauthorized control over the product.

The aim of this requirement is to ensure that the software update mechanism protects the authenticity and integrity of software updates and prevents unauthorised modification of the product's software.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (c) of Regulation 2024/2847. It is also necessary to cover the threat **Threat.SoftwareUpdateTampering** and to meet the corresponding security objective **SO.SecureUpdate** as described in the [4]. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the [4].

Doubts:

1. Why don't you think that we can create a new **SO.SecureUpdate**?

I am including for now under updatability and then we will discuss

7.3.2.3 Guidance

A common approach for confirming that an update is valid is to verify, cryptographically, its integrity and authenticity based on a trust anchor. This verification can be performed directly on the product or by a trusted component. For the latter the verified update is typically sent over a secure channel to the equipment, securely installed on the equipment.

NOTE A "Secure channel" typically preserves the security properties of the communicated information and can also include authorized and authenticated personnel providing the validated software update locally (example of technical or organisational measures).

A manufacturer can provide a secure method to install alternative software not provided by the manufacturer themselves, for example allowing a user to install alternative software on a home router.

It is a security best practice to prevent downgrading the software to an older version.

Due to some security update the product might return to default setting requiring to re-enter credentials and configuration data.

The use of SCM-3 is appropriate when a software update contains confidential cryptographic keys.

7.3.2.4 Assessment

7.3.2.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.3.2.4.2 Conceptual assessment

7.3.2.4.2.1 Assessment purpose

7.3.2.4.2.2 Assignment of verdict

7.3.2.4.3 Functional sufficiency assessment

7.3.2.4.3.1 Assessment purpose

7.3.2.4.3.2 Assignment of verdict

7.3.3 [SUM-3] Automated updates (EN 18031)

7.3.3.1 Requirement

The product shall be capable of updating the software through one or more of the following methods:

- without human intervention; or
- via scheduling the installation of an update under human approval; or
- via triggering the installation of an update under human approval or supervision

7.3.3.2 Rationale

In the presence of vulnerabilities in the product that may compromise its assets, delayed application of security updates increases the window of opportunity for exploitation. Automated update capabilities can support the timely installation of available security updates with limited or no human intervention.

The aim of this requirement is to ensure that the product supports automated or semi-automated installation of security updates in order to reduce delays in vulnerability remediation.

This requirement is necessary because reliance solely on manual update processes may result in delayed or missed installation of security updates, thereby increasing the likelihood of exploitation of known vulnerabilities and compromising the confidentiality, integrity or availability of the product and its assets.

NOTE This section will be removed after the allignment with section 5

This requirement is necessary to meet the essential cybersecurity requirement (c) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnpatchedVulnerabilityExploitation and to meet the corresponding security objective SO AutomaticUpdates.

7.3.3.3 Guidance

This requirement demands at least one automated update mechanism for each software where SUM-1 requires an update mechanism.

NOTE 1 One automated update mechanism can be used to update multiple parts of the software.

Automated updates are carried out by machines without needing or with minimal human control or intervention.

Automatic updates are a step further where the equipment makes decisions and executes updates on its own without human intervention.

NOTE 2 Proposal from Riccardo

Depending on the product context, automated update mechanisms may be implemented through different means, including:

- local update mechanisms within the product;
- platform or operating system services;
- remote or backend-controlled deployment mechanisms.

For remote data processing solutions, automated updates may be implemented through controlled deployment mechanisms such as continuous integration and continuous deployment pipelines, orchestration systems, or managed platform services.

In specific cases involving safety or time-critical aspects, or dependency on compatibility of the updates in a network, the update can require some precautions and/or on-site verifications before it is initiated and therefore cannot be performed in an automatic way so that the operation of the application is not affected. In such cases, human intervention to trigger or schedule the update is needed.

In case the installation of the new software version fails, e.g., validation of the software image(s) is unsuccessful, a best practice is to apply a roll-back policy to re-activate the previous software version, unless not enough memory is available to store the update.

Triggering the installation of an update under human approval can for example consist of displaying a notification that an update is available and prompting the user to install the update via a secure update mechanism.

Simple automated updates from a user's perspective improve the distribution rate of security updates.

NOTE 3 "Simple from a user's perspective" can include:

- simple configuration of notifications related to the secure update mechanism,
- simple configuration of the update mechanism
- simple provision of a consent to fully automatic updates

Where fully automatic update mechanisms are possible, asking for user's consent to activate it when putting the equipment into service, improves the distribution rate of security updates.

Checking the availability of new security updates after initialization and regularly improves the distribution rate of security updates.

7.3.3.4 Assessment

7.3.3.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.3.3.4.2 Conceptual assessment

7.3.3.4.2.1 Assessment purpose

7.3.3.4.2.2 Assignment of verdict

7.3.3.4.3 Functional sufficiency assessment

7.3.3.4.3.1 Assessment purpose

7.3.3.4.3.2 Assignment of verdict

7.3.4 [SUM-4] Postponement of Software Updates (NEW)

7.3.4.1 Requirement

The product shall be capable of allowing the user to postpone the installation of a security update for a limited and controlled period of time.

7.3.4.2 Rationale

From a consumer rights and ownership perspective, it is important that users retain control over when they apply a security update. There are valid reasons why a user may choose not to update immediately after receiving a security update notification, including concerns related to product availability.

For example, applying a security update may require the product to reboot or temporarily become unavailable, which could disrupt critical operations or services. In such cases, users may delay the update to preserve availability. Additionally, if an update is deployed and subsequently found to cause issues, manufacturers may advise users not to upgrade their software to prevent those consumer products from experiencing those issues.

The aim of this requirement is to allow users to postpone the installation of a security update for a limited period of time in order to manage availability and operational considerations.

This requirement is necessary because immediate installation of a security update may temporarily affect product availability or service continuity, and users may require flexibility in determining the appropriate time for installation.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (c) of Regulation 2024/2847. It is also necessary to cover the threatThreat.FunctionalityUpdateInterruption and to meet the corresponding security objective SO.PostponeUpdates.

7.3.4.3 Guidance

The postponement capability may allow the user to delay the installation of a security update for a defined and limited period of time.

This requirement applies when the product includes a user interface or supporting measures (e.g. operating system) enabling direct user interaction with the update installation process. Such interfaces include, but are not limited to, embedded displays, control panels, voice interfaces, web portals and mobile applications.

Such limits may include maximum postponement periods, restricted numbers of deferrals, or mechanisms ensuring that security updates are eventually applied.

In environments where availability and operational continuity are critical, postponement may support scheduling updates during planned maintenance windows or according to defined operational policies.

The postponement mechanism should prevent indefinite deferral of security updates, while allowing updates to be applied in a manner consistent with operational, safety, and availability requirements.

7.3.4.4 Assessment

7.3.4.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.3.4.4.2 Conceptual assessment

7.3.4.4.2.1 Assessment purpose

7.3.4.4.2.2 Assignment of verdict

7.3.4.4.3 Functional sufficiency assessment

7.3.4.4.3.1 Assessment purpose

7.3.4.4.3.2 Assignment of verdict

7.3.5 [SUM-5] Opt-out from automatic software installation(NEW)

7.3.5.1 Applicability criteria

This requirement applies where the product supports automatic installation of software updates without human intervention, either directly or through supporting measures.

7.3.5.2 Requirement

Where automatic installation is supported and operationally appropriate, the product shall allow the user to disable the automatic installation feature.

7.3.5.3 Rationale

Automatic installation of software updates reduces the window of exposure to known vulnerabilities, while in certain operational contexts uncontrolled automatic updates may interfere with system availability, compatibility, or safety.

The aim of this requirement is to ensure that automatic updates are enabled by default to support timely vulnerability remediation, while allowing users to retain control over update behaviour when necessary.

This requirement is necessary because, although automatic updates improve security by reducing reliance on user action, users may need to adjust update behaviour to accommodate operational, compatibility, or safety constraints.

This requirement is necessary to meet the essential cybersecurity requirement (c) of Regulation 2024/2847. It is also necessary to cover the threatThreat.UnpatchedVulnerabilityExploitation and to meet the corresponding security objective SO.AutomaticUpdates.

7.3.5.4 Guidance

The mechanism to disable automatic installation should be readily accessible to the user within the product's interface or configuration settings. For software products and mobile applications, this setting is typically exposed through the application settings or the platform's update management interface. For products where the update mechanism is managed at platform or ecosystem level (e.g. mobile operating systems, app stores), compliance may be achieved through the controls provided by that platform, provided those controls are accessible to the user.

Disabling automatic installation does not exempt the product from the obligation to notify the user of available updates.

7.3.5.5 Assessment

7.3.5.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.3.5.5.2 Conceptual assessment

7.3.5.5.2.1 Assessment purpose**7.3.5.5.2.2 Assignment of verdict****7.3.5.5.3 Functional sufficiency assessment****7.3.5.5.3.1 Assessment purpose****7.3.5.5.3.2 Assignment of verdict****7.3.6 [SUM-6] Automatic Updates by default (NEW)****7.3.6.1 Applicability criteria**

This requirement applies where the product supports automatic installation of security updates, either directly or via supporting measures, and where such automatic installation is operationally appropriate.

7.3.6.2 Requirement

Where automatic installation of security updates is supported and operationally appropriate, it shall be enabled by default, either by the product or via supporting measures.

7.3.6.3 Rationale

Enabling automatic updates by default reduces reliance on user action and supports the timely remediation of vulnerabilities.

The aim of this requirement is to ensure that security updates are applied without requiring user intervention in typical use cases.

This requirement is necessary because users may not consistently install updates manually, which can increase the exposure of the product to known vulnerabilities.

This requirement is necessary to meet the essential cybersecurity requirement (c) of Regulation 2024/2847. It is also necessary to cover the threatThreat.UnpatchedVulnerabilityExploitation and to meet the corresponding security objective SO.AutomaticUpdates.

7.3.6.4 Guidance

Automatic updates should be enabled by default in a manner that:

- minimises disruption to the user or to the operation of the product;
- is consistent with user expectations for the product type and context of use;

- takes into account constraints imposed by the operating environment or supporting measures.

Where appropriate, the product should:

- perform updates at suitable times (e.g. when the product is idle);
- provide prior notice of updates that may impact functionality or availability;
- ensure that users are informed of changes resulting from installed updates.

For remote data processing solutions, this may include automated deployment mechanisms such as continuous integration and continuous deployment pipelines, orchestration systems, or managed platform services.

In cases where automatic updates are managed by supporting measures, the product may rely on those mechanisms to fulfil this requirement.

7.3.6.5 Assessment

7.3.6.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.3.6.5.2 Conceptual assessment

7.3.6.5.2.1 Assessment purpose

7.3.6.5.2.2 Assignment of verdict

7.3.6.5.3 Functional sufficiency assessment

7.3.6.5.3.1 Assessment purpose

7.3.6.5.3.2 Assignment of verdict

7.3.7 [SUM-7] User Security Update Notification(NEW)

7.3.7.1 Applicability criteria

This requirement applies where the product supports automatic installation of security updates, either directly or via supporting measures, and where such automatic installation is operationally appropriate.

7.3.7.2 Requirement

A notification mechanism shall be provided by the product or through other means to inform the user, in a timely manner, about the availability of security updates.

7.3.7.3 Rationale

Security updates may affect the protection of the assets of the product. If users are not informed about the availability and relevance of such updates, they may not take appropriate action, potentially increasing the risk to the product and its environment. Transparency towards the user supports informed decision-making regarding the application of security updates.

The aim of this requirement is to ensure that users are informed, in a timely and understandable way, about security updates that may affect the protection of the assets of the product.

This requirement is necessary because the absence of user notification about security updates may result in updates not being applied, leaving known vulnerabilities unmitigated and increasing the risk of exploitation.

This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (c) of Regulation 2024/2847. It is also necessary to cover the threats [Threat.MissingUpdateNotificationExploitation] and to meet the corresponding security objective [SO.UserUpdateNotification] as described in the [4]. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the [4].

7.3.7.4 Guidance

The notification mechanism may be implemented through appropriate communication channels depending on the nature of the product and its intended use, including via the product itself or through other reliable means.

“Timely manner” should be understood as without undue delay after the security update becomes available.

The information provided should be sufficient to enable the user to understand the relevance of the update and the potential impact of not applying it, taking into account the expected knowledge of the intended user.

Where notification is provided through means not involving the product, the manufacturer should ensure that the communication channel can reasonably be expected to reach the user.

7.3.7.5 Assessment

7.3.7.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.3.7.5.2 Conceptual assessment

7.3.7.5.2.1 Assessment purpose

7.3.7.5.2.2 Assignment of verdict

7.3.7.5.3 Functional sufficiency assessment

7.3.7.5.3.1 Assessment purpose

7.3.7.5.3.2 Assignment of verdict

7.4 [SSM] Secure storage mechanism (EN 18031)

7.4.1 [SSM-1] Secure storage mechanisms (EN 18031)

7.4.1.1 Requirement

The product shall use secure storage mechanisms for protecting persistently stored assets.

7.4.1.2 Proposal to delete requirement

void

and delete all sub clauses as proposal is to merge with SSM-2

7.4.1.3 Rationale

Secure storage mechanisms protect assets from unauthorized access. If assets are not appropriately secured, an attacker can access, tamper, or delete the assets and compromise the assets, which might lead to malicious activities.

7.4.1.4 Guidance

The assets can be protected by e.g.:

- cryptographic measures like encryption to ensure confidentiality
- cryptographic measures like digital signatures to ensure integrity and authenticity
- access control using authentication or authorization
- hardware protection measures
- physical protection measures

The appropriate protection mechanism depends on the risks associated with the assets to be stored and this might depend on:

- the criticality of the security assets or network assets;
- the amount of security assets or network assets;

- the duration for which the security assets or network assets need to be stored;
- the intended operational environment of use.

Removable storage that is not part of the product at the moment of placement on the market is not considered to be persistent storage but a storage that is meant to be used to move sensitive assets between different products. Physical access to the product is required to remove such a storage from the products itself. This ensures access to the stored assets is only available to authorized entities having physical access to the equipment.

Persistently stored data, not listed as assets, may be protected by the secured storage mechanism but they are out of scope of this requirement.

7.4.1.4.1 PROPOSAL: Guidance

TODO: Reword the removable media part, which could be in scope of the risk assessment doen for the CRA. Point to SSM-4 for removable media.

7.4.1.5 Assessment

7.4.1.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.4.1.5.2 Conceptual assessment

7.4.1.5.2.1 Assessment purpose

7.4.1.5.2.2 Assignment of verdict

7.4.1.5.3 Functional sufficiency assessment

7.4.1.5.3.1 Assessment purpose

7.4.1.5.3.2 Assignment of verdict

7.4.2 [SSM-2] Integrity protection for secure storage mechanisms (EN 18031)

7.4.2.1 Requirement

The product shall use secure storage mechanisms for protecting the integrity of assets persistently stored.

7.4.2.2 Rationale

When stored, assets require protection against tampering. If the integrity of the assets stored is not appropriately secured, an attacker can manipulate those assets, which might endanger network resources.

The integrity protection applies for encrypted as well as for unencrypted storage.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (f) of Regulation 2024/2847.

(f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;

It is also necessary to cover the threats [Threat.DataAtRestTampering], and to meet the corresponding security objective [SO.DataStoredIntegrity], as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.4.2.3 Proposal for Rationale

The aim of this requirement is that secure storage mechanisms protect assets from unauthorized access. If assets are not appropriately secured, an attacker can access, tamper, or delete the assets and compromise the assets, which might lead to malicious activities.

This requirement is necessary because when stored, assets require protection against tampering. If the integrity of the assets stored is not appropriately secured, an attacker can manipulate those assets, which might endanger network resources.

The integrity protection applies for encrypted as well as for unencrypted storage.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (f) of Regulation 2024/2847.

(f) protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;

It is also necessary to cover the threats [Threat.DataAtRestTampering], and to meet the corresponding security objective [SO.DataStoredIntegrity], as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.4.2.4 Guidance

Data can be protected from tampering by for instance:

- cryptographic measures like digital signatures,
- access control,
- hardware protection measures,
- physical protection measures.

7.4.2.5 Proposal for Guidance

The assets can be protected by e.g.:

- cryptographic measures like digital signatures to ensure integrity and authenticity
- access control using authentication or authorization
- hardware protection measures
- physical protection measures

The appropriate protection mechanism depends on the risks associated with the assets to be stored and this might depend on:

- the criticality of the security assets or network assets;
- the amount of security assets or network assets;
- the duration for which the security assets or network assets need to be stored;
- the intended operational environment of use.

Persistently stored data, not listed as assets, may be protected by the secured storage mechanism but they are out of scope of this requirement.

For removable storage media (e.g. USB flash drives, removable memory cards, external storage devices, which may leave the device's trusted boundary and operational environment, should be protected against unauthorized access, loss, and tampering, as they may be more exposed to physical access and uncontrolled environments. Encryption, for removable storage it is often the only effective control once physical possession is lost.

Assets can be protected from tampering by for instance:

- cryptographic measures like digital signatures,
- access control,
- hardware protection measures,
- physical protection measures.

7.4.2.6 Assessment

NOTE Note to be deleted

- Evaluator should see that security storage mechanisms and related assets protected are appropriately documented along with the related risks
- Integrity mechanisms related to the security storage mechanisms should be declared
- Create a test plan to test the integrity mechanisms and tampering attacks.

7.4.2.6.1 Assessment objective

7.4.2.6.2 Assessment preparation

7.4.2.6.2.1 Assessment activities

7.4.2.6.2.2 Assignment of verdict

7.4.2.6.3 Supporting evidence

7.4.3 [SSM-3] Confidentiality protection for secure storage mechanisms (EN 18031)

7.4.3.1 Requirement

The product shall use secure storage mechanisms for protecting the confidentiality of assets persistently stored.

7.4.3.2 Rationale

When stored, assets can require protection from exposure. If assets are not appropriately secured, an attacker can access and misuse the product and stored assets, which can lead to the misuse of product related resources or exposure of personal data, financial data or other security relevant data at rest.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (e) of Regulation 2024/2847.

(e) **protect the confidentiality of stored**, transmitted or otherwise processed **data, personal or other, such as by encrypting relevant data at rest** or in transit by state of the art mechanisms, and by using other technical means;

It is also necessary to cover the threat [Threat.DataAtRestDisclosure] and to meet the corresponding security objective [SO. DataStoredConfidentiality] as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.4.3.3 Proposal for Rationale

The aim of this requirement is that secure storage mechanisms protect assets from unauthorized access. If assets are not appropriately secured, an attacker can access, tamper, or delete the assets and compromise the assets, which might lead to malicious activities.

This requirement is necessary because when stored, assets can require protection from exposure. If assets are not appropriately secured, an attacker can access and misuse the product and stored assets, which can lead to the misuse of product related resources or exposure of assets at rest.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (e) of Regulation 2024/2847.

(e) **protect the confidentiality of stored**, transmitted or otherwise processed **data, personal or other, such as by encrypting relevant data at rest** or in transit by state of the art mechanisms, and by using other technical means;

It is also necessary to cover the threat [Threat.DataAtRestDisclosure] and to meet the corresponding security objective [SO. DataStoredConfidentiality] as described in the PT2 TR. It might also help to meet

other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.4.3.4 Guidance

Data can be protected from exposure by e.g.:

- cryptographic measures like encryption,
- access control,
- hardware protection measures.

7.4.3.5 Proposal for Guidance

- cryptographic measures like encryption to ensure confidentiality
- access control using authentication or authorization
- hardware protection measures
- physical protection measures

The appropriate protection mechanism depends on the risks associated with the assets to be stored and this might depend on:

- the criticality of the security assets or network assets;
- the amount of security assets or network assets;
- the duration for which the security assets or network assets need to be stored;
- the intended operational environment of use.

Persistently stored data, not listed as assets, may be protected by the secured storage mechanism but they are out of scope of this requirement.

For removable storage media (e.g. USB flash drives, removable memory cards, external storage devices, which may leave the device's trusted boundary and operational environment, should be protected against unauthorized access, loss, and tampering, as they may be more exposed to physical access and uncontrolled environments. Encryption, for removable storage it is often the only effective control once physical possession is lost.

Assets can be protected from exposure by e.g.:

- cryptographic measures like encryption,
- access control,
- hardware protection measures.

7.4.3.6 Assessment

NOTE Note to be deleted

- Evaluator should see that security storage mechanisms and related sensitive assets protected are appropriately documented along with the related risks
- Confidentiality mechanisms related to the security storage mechanisms should be declared
- Create a test plan to test the Confidentiality mechanisms and tampering attacks.

7.4.3.6.1 Assessment objective

7.4.3.6.2 Assessment preparation

7.4.3.6.3 Assignment of verdict

7.4.3.6.4 Supporting evidence

7.4.4 PROPOSAL: [SSM-4] Authenticity of data on removable media

7.5 [SCM] Secure communication mechanism

7.5.1 [SCM-1] *Applicability of secure communication mechanisms* (EN 18031) VOID

NOTE This section is left void as a placeholder and maintaining the compatibility with EN 18031 and integrated in SCM-2

7.5.2 [SCM-2] Appropriate integrity and authenticity protection for secure communication mechanisms (EN 18031)

7.5.2.1 Requirement

The product shall use secure communication mechanisms that apply best practices to protect the integrity and the authenticity of assets communicated via network interfaces.

7.5.2.2 Rationale

The assets of the product may be communicated to other communication partners for example when using web services. Ongoing communication potentially enables an attacker having access to the communication to eavesdrop, manipulate or replay the communication, especially when using wireless technologies. The equipment needs to ensure that the communication is protected against those attacks using secure communication mechanisms. The protection could be realized by the protocol used to communicate the assets or by an additional protocol/additional measures.

The integrity and authenticity protection applies for encrypted as well as for unencrypted communications.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (f) of Regulation 2024/2847. It is also necessary to cover the threat Threat.DataInTransitTampering, as described in the PT2 TR and to meet the corresponding security objectives SO.DataTransmittedIntegrity, SO.ComAuth, SO.IntegrityReport. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.5.2.3 Proposal for Rational

The aim of this requirement is to protect the integrity and the authenticity of assets when in transit. The assets of the product may be communicated to other communication partners for example when using web services. Ongoing communication potentially enables an attacker having access to the communication to eavesdrop, manipulate or replay the communication, especially when using wireless technologies.

This requirement is necessary to product ensure that the communication is protected against those attacks using secure communication mechanisms. The protection could be realized by the protocol used to communicate the assets or by an additional protocol/additional measures.

The integrity and authenticity protection applies for encrypted as well as for unencrypted communications.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (f) of Regulation 2024/2847. It is also necessary to cover the threat Threat.DataInTransitTampering, as described in the PT2 TR and to meet the corresponding security objectives SO.DataTransmittedIntegrity, SO.ComAuth, SO.IntegrityReport. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.5.2.4 Guidance

There are various technologies that can be applied to secure the communication (see also CRY-1) of the product. Best practice communication protocols with corresponding configuration ought to be applied to protect the communication against eavesdropping, manipulation and replay. Typical measures therefore are a combination of authentication, integrity protection, encryption and replay protection. The measures can for example be applied to the communication channel or used for end-to-end protection.

The product needs to offer best practice communication protocols to other communication partners by default. The way in which the initial relationship of trust is established between the product and another entity is crucial for the security of the subsequent communication.

It is strongly advised not to use protocols without or with weak security functionality for communication.

In some cases, a deviation from this might be necessary especially for supporting interoperability. For the usage of such protocols, it needs to be foreseeable for the manufacturer that additional security measures are applied for example:

- The target environment of the product is an area which is only accessible for authorized persons and the radio communication range is short enough to render connection attempts from outside the building impractical. Typical examples for such areas are industrial sites or locked building service rooms in tenements.
- The target environment of the equipment is a specific network infrastructure using a virtual private network which tunnels the insecure protocol of the equipment.

Generally, it is recommended that the equipment notifies the user when an insecure communication is performed.

For product in local or personal networks (e.g., wearables) with limited user interface which does not allow to perform more complex pairing procedures, pairing protocols might be vulnerable to man-in-the-middle attacks. Here the attack vector needs to be reduced with additional measures

(possession, knowledge or inherence) for the establishment of a connection, e.g., a limited time slot for a user interaction which is necessary to complete the pairing.

In the context of secure communication, “best practice” addresses that approved protocols with corresponding configuration (see also CRY-1) are used and that the implementation of the protocol is regularly reviewed for vulnerabilities (see GEC-1).

The aim is to protect the communication against manipulation. Typical measures are a combination of authentication and integrity protection. The way in which the initial relationship of trust is established between the equipment and another entity is crucial for the security of the communication. The measures can for example be applied to the communication channel or used for “end-to-end” protection. Further, integrity and authenticity protection of communicated is typically realized by using Cipher-based Message Authentication Code (MAC) techniques.

A deviation from best practice is only possible for interoperability reasons within the intended equipment functionality. In this case compensating logical or physical measures need to be considered to ensure a comparable level of security.

The product needs to offer best practice protocols to other communication partners by default, even if other protocols might also be needed for interoperability reasons. Appropriate measures may differ between the underlying use cases of the communication to fulfil the equipment’s intended equipment functionality.

Examples for approved protocols which can be used to implement secure communication when best practice configuration (see also CRY-1) is applied are:

- *Transport Layer Security (TLS)*
- *Wi-Fi Protected Access (WPA)*
- *Password Authenticated Connection Establishment (PACE)*
- *Symmetrical Cipher Methods (e.g., Advanced Encryption Standard - AES)*

Insecure communication is often not caused by flaws in the protocol but by errors in its implementation. Therefore, requirement GEC-1 is important.

7.5.2.5 Proposal for Guidance (equipment -> product)

There are various technologies that can be applied to secure the communication (see also CRY-1) of the product. Best practice communication protocols with corresponding configuration ought to be applied to protect the communication against eavesdropping, manipulation and replay. Typical measures therefore are a combination of authentication, integrity protection, encryption and replay protection. The measures can for example be applied to the communication channel or used for end-to-end protection.

The product needs to offer best practice communication protocols to other communication partners by default. The way in which the initial relationship of trust is established between the product and another entity is crucial for the security of the subsequent communication.

It is strongly advised not to use protocols without or with weak security functionality for communication.

In some cases, a deviation from this might be necessary especially for supporting interoperability. For the usage of such protocols, it needs to be foreseeable for the manufacturer that additional security measures are applied for example:

- The target environment of the product is an area which is only accessible for authorized persons and the radio communication range is short enough to render connection attempts from outside the building impractical. Typical examples for such areas are industrial sites or locked building service rooms in tenements.
- The target environment of the product is a specific network infrastructure using a virtual private network which tunnels the insecure protocol of the product.

Generally, it is recommended that the product notifies the user when an insecure communication is performed.

For product in local or personal networks (e.g., wearables) with limited user interface which does not allow to perform more complex pairing procedures, pairing protocols might be vulnerable to man-in-the-middle attacks. Here the attack vector needs to be reduced with additional measures (possession, knowledge or inherence) for the establishment of a connection, e.g., a limited time slot for a user interaction which is necessary to complete the pairing.

In the context of secure communication, “best practice” addresses that approved protocols with corresponding configuration (see also CRY-1) are used and that the implementation of the protocol is regularly reviewed for vulnerabilities (see GEC-1).

The aim is to protect the communication against manipulation. Typical measures are a combination of authentication and integrity protection. The way in which the initial relationship of trust is established between the product and another entity is crucial for the security of the communication. The measures can for example be applied to the communication channel or used for “end-to-end” protection. Further, integrity and authenticity protection of communicated is typically realized by using Cipher-based Message Authentication Code (MAC) techniques.

A deviation from best practice is only possible for interoperability reasons within the intended product functionality. In this case compensating logical or physical measures need to be considered to ensure a comparable level of security.

The product needs to offer best practice protocols to other communication partners by default, even if other protocols might also be needed for interoperability reasons. Appropriate measures may differ between the underlying use cases of the communication to fulfil the product’s intended product functionality.

Examples for approved protocols which can be used to implement secure communication when best practice configuration (see also CRY-1) is applied are:

- *Transport Layer Security (TLS)*
- *Wi-Fi Protected Access (WPA)*
- *Password Authenticated Connection Establishment (PACE)*
- *Symmetrical Cipher Methods (e.g., Advanced Encryption Standard - AES)*

Insecure communication is often not caused by flaws in the protocol but by errors in its implementation. Therefore, requirement GEC-1 is important.

7.5.2.6 Assessment

NOTE Note to be removed

Insert abbreviated assessment process after PoC Draft release, unless convenient to add notes whilst drafting the requirement.

Contributor's note: See also assessment proposal from Samim "CEN-CLC-JTC 13-WG 9_20241031 Technical Controls PT 2 - Confidentiality Requirement.docx".

7.5.2.6.1 Assessment objective

The assessment covers a:

- conceptual assessment of [SCM-2],
- functional completeness assessment on the product capabilities that are addressed by [SCM-2],
- functional sufficiency assessment of each mechanism used by the product to fulfil [SCM-2] based on the default configuration from clause 'secure by default configuration'.

7.5.2.6.2 Assessment preparation

The following documentation for the product shall be complete:

- a list and description of [secure communication mechanisms ensuring integrity and authenticity protection] and where they are used to [ensure integrity and authenticity of communicated security assets and privacy assets],
- [description of communication protocols, cryptographic measures and configuration used to ensure integrity and authenticity protection]

The following test setups shall be prepared:

- [tests to verify that integrity protection mechanisms detect manipulated communication]
- [tests to verify that authenticity protection mechanisms reject unauthorized entities]
- [tests to verify that implemented mechanisms prevent man-in-the-middle attacks]

7.5.2.6.3 Assessment activities

The product's conformity to [SCM-2] shall be validated based on the documentation. The correctness and completeness of the documentation shall be verified by:

- [verification that all secure communication mechanisms defined for integrity and authenticity protection are documented for each relevant communication interface]
- [verification of implementation properties, configuration and cryptographic mechanisms used for integrity and authenticity protection]
- [verification that communication scenarios and security objectives for integrity and authenticity protection are documented]

For each [secure communication mechanism ensuring integrity and authenticity protection], its correct implementation shall be verified by:

- [test verifying that integrity protection detects any manipulation of transmitted data]
- [test verifying that authenticity protection ensures that only authorized entities are accepted]
- [test verifying that unauthorized or spoofed messages are rejected]
- [test verifying that man-in-the-middle attacks are not successful]

7.5.2.6.4 Assignment of verdict

The verdict PASS shall be assigned if:

- the documentation indicates the product's conformity to [SCM-2]; and
- the verification of the correctness and completeness of the documentation was successful by verifying that every documented [secure communication mechanism ensuring integrity and authenticity protection] exists in the product and shows the expected behavior; and

The verification of the correct implementation of each [secure communication mechanism ensuring integrity and authenticity protection] is successful by verifying:

- [that manipulated communication is detected and rejected];
- [that unauthorized entities cannot successfully authenticate communication];
- [that spoofed messages are not accepted as authentic];
- [that man-in-the-middle attacks are prevented].

The verdict FAIL shall be assigned otherwise.

7.5.2.6.5 Supporting evidence

- records of the validation of the documentation
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation
- descriptions of the performed tests and records of performed tests to verify the correct implementation of each [secure communication mechanism ensuring integrity and authenticity protection]

7.5.3 [SCM-3] Secure communication mechanisms with confidentiality protection (EN 18031)

7.5.3.1 Requirement

The product shall use secure communication mechanisms that apply best practices to protect the confidentiality of assets communicated via network interfaces.

7.5.3.2 Rationale

The product's assets may be communicated to other communication partners, such as through web services. Ongoing communication exposes the risk of eavesdropping by attackers with

network access. To mitigate this, assets require protection against eavesdropping. An attacker having gained access to the network over which the product communicates assets might monitor the communication. The equipment needs to ensure that the communication is protected against those attacks by providing confidentiality.

During communication, generally assets require protection against eavesdropping. An attacker having gained access to the network over which the product communicates assets might monitor the communication. The product needs to ensure that the communication is protected against those attacks by providing confidentiality.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (e) of Regulation 2024/2847. It is also necessary to cover the threat Threat.DataInTransitDisclosure, as described in the PT2 TR and to meet the corresponding security objectives SO.DataTransmittedConfidentiality. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.5.3.3 Proposal for Rationale

The aim of this requirement is to protect the confidentiality of assets when in transit The product's assets may be communicated to other communication partners, such as through web services. Ongoing communication exposes the risk of eavesdropping by attackers with network access. To mitigate this, assets require protection against eavesdropping. An attacker having gained access to the network over which the product communicates assets might monitor the communication.

This requirement is necessary to productensure that the communication is protected against those attacks by providing confidentiality.

During communication, generally assets require protection against eavesdropping. An attacker having gained access to the network over which the product communicates assets might monitor the communication. The product needs to ensure that the communication is protected against those attacks by providing confidentiality.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (e) of Regulation 2024/2847. It is also necessary to cover the threat Threat.DataInTransitDisclosure, as described in the PT2 TR and to meet the corresponding security objectives SO.DataTransmittedConfidentiality. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.5.3.4 Guidance

In the context of secure communication, “best practice” addresses that approved protocols withcorresponding configuration (especially concerning the integrated cryptography, see CRY-1) are used and that the implementation of the protocol is regularly reviewed for vulnerabilities (see GEC-1).

There are various security mechanisms that can be applied to secure the confidentiality of the communication (see also CRY-1). Best practice configuration ought to be applied to protect thecommunication from eavesdropping. This is typically achieved by symmetric encryption schemes. Those schemes can be applied to the communication channel or used for “end-to-end” protection. It is recommended to provide confidentiality by default between the communicating entities and to use best practice cryptography. If there is the necessity for deviating from best practices (e.g., due to interoperability reasons) the resulting risks towards “best practice security” ought to be assessed.

Appropriate measures may differ between the underlying use cases of the communication to fulfil the product's intended equipment functionality.

A deviation from best practice is only possible for interoperability reasons within the intended equipment functionality. In this case compensating logical or physical measures need to be considered to ensure a comparable level of security.

If confidentiality needs to be preserved for a long period of time it is recommended to use cryptography and cryptographic protocols best practices which enforce perfect forward secrecy for the assets communicated.

The cryptographic schemes used to protect the confidentiality of the data communicated is determined in the requirement CRY-1.

NOTE Authenticated encryption (AE) can be used to assure data confidentiality and authenticity in one cryptographic scheme. Those schemes can be used to address the requirement in SCM-2 as well.

7.5.3.5 Proposal for Guidance (equipment -> product)

In the context of secure communication, "best practice" addresses that approved protocols with corresponding configuration (especially concerning the integrated cryptography, see CRY-1) are used and that the implementation of the protocol is regularly reviewed for vulnerabilities (see GEC-1).

There are various security mechanisms that can be applied to secure the confidentiality of the communication (see also CRY-1). Best practice configuration ought to be applied to protect the communication from eavesdropping. This is typically achieved by symmetric encryption schemes. Those schemes can be applied to the communication channel or used for "end-to-end" protection. It is recommended to provide confidentiality by default between the communicating entities and to use best practice cryptography. If there is the necessity for deviating from best practices (e.g., due to interoperability reasons) the resulting risks towards "best practice security" ought to be assessed.

Appropriate measures may differ between the underlying use cases of the communication to fulfil the product's intended product functionality.

A deviation from best practice is only possible for interoperability reasons within the intended product functionality. In this case compensating logical or physical measures need to be considered to ensure a comparable level of security.

If confidentiality needs to be preserved for a long period of time it is recommended to use cryptography and cryptographic protocols best practices which enforce perfect forward secrecy for the assets communicated.

The cryptographic schemes used to protect the confidentiality of the data communicated is determined in the requirement CRY-1.

NOTE Authenticated encryption (AE) can be used to assure data confidentiality and authenticity in one cryptographic scheme. Those schemes can be used to address the requirement in SCM-2 as well.

7.5.3.6 Assessment

7.5.3.6.1 Assessment objective

The assessment covers a:

- conceptual assessment of [SCM-3],
- functional completeness assessment on the product capabilities that are addressed by [SCM-3],
- functional sufficiency assessment of each mechanism used by the product to fulfil [SCM-3] based on the default configuration from clause 'secure by default configuration'.

7.5.3.6.2 Assessment preparation

The following documentation for the product shall be complete:

- a list and description of [secure communication mechanisms ensuring confidentiality protection] and where they are used to [protect confidentiality of communicated security assets and privacy assets],
- [description of communication protocols, encryption mechanisms and configuration used to ensure confidentiality protection]

The following test setups shall be prepared:

- [tests to verify that communication is encrypted when confidentiality is required]
- [tests to verify that confidential data cannot be read by unauthorized entities during transmission]
- [tests to verify resistance against eavesdropping attacks]

7.5.3.6.3 Assessment activities

The product's conformity to [SCM-3] shall be validated based on the documentation. The correctness and completeness of the documentation shall be verified by:

- [verification that all secure communication mechanisms defined for confidentiality protection are documented for each relevant communication interface]
- [verification of encryption mechanisms, cryptographic configuration and protocol usage]
- [verification that communication scenarios requiring confidentiality are documented]

For each [secure communication mechanism ensuring confidentiality protection], its correct implementation shall be verified by:

- [test verifying that confidential communication is encrypted]
- [test verifying that unauthorized entities cannot read transmitted data]
- [test verifying that intercepted communication cannot be interpreted without decryption keys]
- [test verifying resistance against eavesdropping attacks]

7.5.3.6.4 Assignment of verdict

The verdict PASS shall be assigned if:

- the documentation indicates the product's conformity to [SCM-3]; and
- the verification of the correctness and completeness of the documentation was successful by verifying that every documented [secure communication mechanism ensuring confidentiality protection] exists in the product and shows the expected behavior; and

The verification of the correct implementation of each [secure communication mechanism ensuring confidentiality protection] is successful by verifying:

- [that communication requiring confidentiality is encrypted];
- [that unauthorized entities cannot read transmitted data];
- [that intercepted communication cannot be interpreted without decryption keys];
- [that eavesdropping attacks do not reveal confidential information].

The verdict FAIL shall be assigned otherwise.

7.5.3.6.5 Supporting evidence

- records of the validation of the documentation
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation
- descriptions of the performed tests and records of performed tests to verify the correct implementation of each [secure communication mechanism ensuring confidentiality protection]

7.5.4 [SCM-4] Replay protection for secure communication mechanisms (EN 18031)

7.5.4.1 Requirement

The product shall apply best practices to protect assets in transit against replay attacks.

7.5.4.2 Rationale

A replay attack is a form of [network](#) attack in which valid data transmission is maliciously repeated. An attacker having gained access to the network might record the communication and replay it unchanged, causing undesired effects at the receiving entity. A replay attack poses a threat in particular if authentication can be undermined or unauthorized control commands can be submitted.

For example, if, during a login process of a user the password is communicated encrypted, but without replay protection (especially session hijacking protection), an attacker may be able to replay the encrypted login part of the communication, and thus gain maliciously authorized access to the system. A session hijacking attack consists of the exploitation of the web session control mechanism, which is normally managed for a session token. The equipment needs to protect the communication against that class of attacks.

Based on a risk assessment use cases might be identified for which a replay protection might not be needed, e.g., when the data communicated does not lead to a state change at the receiving

entity. For example, the request to retrieve an X.509 certificate from a server might not pose a risk for a replay attack.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (e) of Regulation 2024/2847. It is also necessary to cover the threat Threat.DataInTransitDisclosure, as described in the PT2 TR and to meet the corresponding security objectives SO.DataTransmittedConfidentiality. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.5.4.3 Proposal for Rationale

The aim of this requirement is to ensure that assets transmitted by the product cannot be maliciously reused or replayed to gain unauthorized access, trigger unintended actions, or undermine the integrity and authenticity of communications.

This requirement is necessary because replay attacks allow an attacker to capture legitimate data transmitted over a network and retransmit it without modification, causing the receiving party to accept it as valid. Such attacks can occur even when communications are encrypted and may lead to unauthorized access, repeated transactions, or manipulation of system behavior. Applying best practices to protect assets in transit against replay attacks helps ensure that each exchange is unique and context-bound, thereby supporting the integrity, authenticity, and secure operation of the product during network communication.

A replay attack is a form of [network](#) attack in which valid data transmission is maliciously repeated. An attacker having gained access to the network might record the communication and replay it unchanged, causing undesired effects at the receiving entity. A replay attack poses a threat in particular if authentication can be undermined or unauthorized control commands can be submitted.

For example, if, during a login process of a user the password is communicated encrypted, but without replay protection (especially session hijacking protection), an attacker may be able to replay the encrypted login part of the communication, and thus gain maliciously authorized access to the system. A session hijacking attack consists of the exploitation of the web session control mechanism, which is normally managed for a session token. The equipment needs to protect the communication against that class of attacks.

Based on a risk assessment use cases might be identified for which a replay protection might not be needed, e.g., when the data communicated does not lead to a state change at the receiving entity. For example, the request to retrieve an X.509 certificate from a server might not pose a risk for a replay attack.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (e) of Regulation 2024/2847. It is also necessary to cover the threat Threat.DataInTransitDisclosure, as described in the PT2 TR and to meet the corresponding security objectives SO.DataTransmittedConfidentiality. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.5.4.4 Guidance

Replay attacks can typically be prevented by tagging each message of a communication session with a session ID and a counter. The session ID prevents replay attacks of the complete communication, while the counter prevents the replay of a specific messages within a communication session. Further timestamps or a one-time encryption technique can be used to prevent replay attacks. Nevertheless, the implementation of replay attack protection is complex. Therefore, the usage of approved protocols which provide already replay attack protection needs

to be considered first. Examples for approved protocols which can be used to implement secure communication when best practice configuration (see also CRY-1) is applied are:

- Transport Layer Security (TLS)
- Secure Socket Shell (SSH)
- Internet Protocol Security (IPsec)

7.5.4.5 Assessment

NOTE Insert abbreviated assessment process after PoC Draft release, unless convenient to add notes whilst drafting the requirement.

Contributor's note: See also assessment proposal from Samim "CEN-CLC-JTC 13-WG 9_20241031 Technical Controls PT 2 - Confidentiality Requirement.docx".

7.5.4.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.5.4.5.2 Conceptual assessment

7.5.4.5.2.1 Assessment purpose

7.5.4.5.2.2 Assignment of verdict

7.5.4.5.3 Functional sufficiency assessment

7.5.4.5.3.1 Assessment purpose

7.5.4.5.3.2 Assignment of verdict

7.6 [LGM] Logging mechanism (18031)

7.6.1 [LGM-1] Logging mechanisms (18031)

7.6.1.1 Requirement

The product shall use logging mechanism for logging security relevant internal activities (referred to as events) that are relevant to assets and their protection, including unauthorized access attempts and tampering attempts, such as modification of assets such as data, services or functions.

NOTE Events include anomalies, which are events or pattern of events that deviate from what is standard, normal or expected.

7.6.1.2 Rationale

The aim of this requirement is that the product will generate relevant logs, to provide information about such events.

This requirement is necessary as such log information can be of support to help to identify security/data breaches, e.g. potential unusual product behaviour.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.1.3 Guidance

The manufacturer determines the purpose (and audience) for which logs might be created, what data might be collected and logged, and any log-specific requirements for protecting and handling the log data, e.g. provide the data to a SIEM (Security information and event management).

A subset of the events identified is typically configured to be collected by default. The manufacturer can allow the end user to change this logging configuration.

The following are typical examples of events to be logged:

- activities on the privacy assets such as adding, editing, combining, removing/archiving, deleting, changing of password, permitted or denied access attempts,
- change on settings which can lessen or improve data protection,
- activation or deactivation of security relevant sensors.

Examples of logging events are:

- activities on the privacy assets such as access, add, edit, remove/archive, delete,
- unauthorized access attempts.

Personal data captured in the logs are to be minimised to those absolutely necessary to support investigators investigating security breaches.

Products might be designed to prevent an attempt by an attacker to execute an unauthorized physical action. Nevertheless, detection, tamper logging and response are essential in the event of a tampering Event occurring.

Further details on logging can be seen in standards such as ISO/IEC27002 [3], Third edition, 2022-02, section 8.15.

NOTE 1 the following events might be logged: successful and rejected system access events; changes to personal data, traffic data or location data; files accessed and the type of access, including deletion of important data files.

NOTE 2 event logs might include, where applicable, user IDs, system activities, time stamp and details of relevant Events, equipment identity, system identifier and locations, network addresses and protocols.

7.6.1.4 Assessment

7.6.1.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.6.1.4.2 Conceptual assessment

7.6.1.4.2.1 Assessment purpose

7.6.1.4.2.2 Assignment of verdict

7.6.1.4.3 Functional sufficiency assessment

7.6.1.4.3.1 Assessment purpose

7.6.1.4.3.2 Assignment of verdict

7.6.2 [LGM-2] Persistent storage of log data (18031)

7.6.2.1 Requirement

Logging mechanisms shall store log data for related events in the product's internal storage or related software service outside the product.

All log data stored by logging mechanisms shall include an indication if an event represents a security relevant activity, including access to or modification of data, services or functions.

NOTE Events include anomalies, which are events or pattern of events that deviate from what is standard, normal or expected.

7.6.2.2 Proposal for Requirement

[LGM-2-1] Logging mechanisms shall **persistently** store log data for related events in the product's internal storage or related software service outside the product.

[LGM-2-2] All log data stored by logging mechanisms shall include an indication if an event represents a security relevant activity, including access to or modification of data, services or functions.

NOTE Events include anomalies, which are events or pattern of events that deviate from what is standard, normal or expected.

7.6.2.3 Rationale

The aim of this requirement is that event logs have to be persistent after power cycling of the equipment to prevent their accidental or deliberate erasure.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.2.4 Proposal for Rationale

The aim of [LGM-2-1] is that event logs have to be persistent after power cycling of the product to prevent their accidental or deliberate erasure.

The aim of [LGM-2-2] is to ensure that security-relevant events can be reliably recorded and distinguished from non-security events, enabling effective monitoring, detection, investigation, and response to security incidents throughout the product lifecycle.

This requirement is necessary to support accountability, incident analysis, and compliance with cybersecurity obligations by ensuring that log data is retained in a controlled storage environment and that events involving access to or modification of data, services, or functions can be clearly identified as security-relevant activities.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.2.5 Guidance

None.

7.6.2.6 Assessment

7.6.2.6.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.6.2.6.2 Conceptual assessment

7.6.2.6.2.1 Assessment purpose

7.6.2.6.2.2 Assignment of verdict

7.6.2.6.3 Functional sufficiency assessment

7.6.2.6.3.1 Assessment purpose

7.6.2.6.3.2 Assignment of verdict

7.6.3 [LGM-3] Minimum number of persistently stored events (18031)

7.6.3.1 Requirement

All log data stored in the persistent storage by logging mechanisms shall always include:

- a minimum number of the latest events; and
- the latest event.

7.6.3.2 Rationale

The aim of this requirement is that a minimum number of events to be retained is required to ensure that sufficient audit trail exists for investigations to be carried out effectively.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.3.3 Proposal for Rationale

The aim of this requirement is to ensure that logging mechanisms provide a continuous and usable record of recent events, such that the most up-to-date security-relevant information is always available for monitoring and analysis.

This requirement is necessary to ensure that, even in the presence of limited storage capacity or log rotation, essential information about recent and current security-relevant activities is retained, supporting effective incident detection, investigation, and accountability.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.3.4 Guidance

According to the intended functionality of the product, the minimum number of Events that are stored on the equipment is typically found in user documentation.

Legal obligations regarding retention times and minimum number of stored events have to be followed.

7.6.3.5 Assessment

7.6.3.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.6.3.5.2 Conceptual assessment

7.6.3.5.2.1 Assessment purpose

7.6.3.5.2.2 Assignment of verdict

7.6.3.5.3 Functional sufficiency assessment

7.6.3.5.3.1 Assessment purpose

7.6.3.5.3.2 Assignment of verdict

7.6.4 [LGM-4] Time-related information of persistently stored log data (18031)

7.6.4.1 Requirement

All log data stored in the persistent storage by logging mechanisms shall include:

- a timestamp if real time is available on the product; and
- time-related information if real time is not available on the product.

7.6.4.2 Rationale

The aim of this requirement is that a timestamp or time-related information incorporating the time of occurrence of each event is needed to aid investigations to understand the temporal order of the events and to compare with logs on other product.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.4.3 Proposal for Rationale

The aim of this requirement is to ensure that log data contains sufficient temporal information to allow events to be ordered and correlated, irrespective of whether the product has access to real-time information.

This requirement is necessary to support effective monitoring, incident investigation, and analysis by enabling the reconstruction of the sequence and timing of events, even on products that do not provide a real-time clock, and to facilitate correlation with other security-relevant information sources.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.4.4 Guidance

Time-related information might be the period of time, in seconds, since power up of the equipment, or simply the sequence of events.

7.6.4.5 Assessment

7.6.4.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.6.4.5.2 Conceptual assessment

7.6.4.5.2.1 Assessment purpose

7.6.4.5.2.2 Assignment of verdict

7.6.4.5.3 Functional sufficiency assessment

7.6.4.5.3.1 Assessment purpose

7.6.4.5.3.2 Assignment of verdict

7.6.5 [LGM-5] Disabling logging (NEW)

7.6.5.1 Requirement

The product shall provide a mechanism to disable logging.

7.6.5.2 Rationale

The aim of this requirement is that the product is providing an opt-out mechanism for the logging of security relevant internal activity in a product. This allows user to make a nuanced decision to log data. to:

- Protect system stability
- Preserve performance
- Safeguard privacy
- Support maintenance
- Handle failures in the logging subsystem

When appropriate the opt-out must be supervised by authorised entity, because disabling logs weakens visibility and can hide attacks.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat. LoggingDataDisclosure]** and to meet the corresponding security objective **[SO. OptionDisableDataLogging]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.5.3 Proposal for Rationale

The aim of this requirement is to allow authorized operators or users to temporarily suspend logging where this is necessary for legitimate operational reasons, such as maintenance, troubleshooting, protection of system stability, or management of limited storage or processing resources.

This allows user to make a nuanced decision to log data. to:

- Protect system stability
- Preserve performance
- Safeguard privacy
- Support maintenance
- Handle failures in the logging subsystem

This requirement is necessary to ensure that logging mechanisms can be managed in a controlled and proportionate manner, taking into account operational, performance, or privacy considerations, while allowing products to remain usable and maintain integrity during exceptional or constrained operating conditions.

When appropriate the opt-out must be supervised by authorised entity, because disabling logs weakens visibility and can hide attacks.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat. LoggingDataDisclosure]** and to meet the corresponding security objective **[SO. OptionDisableDataLogging]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.6.5.4 Guidance

A mechanism that allows event logging to be disabled must be designed with strict safeguards to prevent misuse and maintain security assurance. Only highly trusted administrative roles should have the ability to deactivate logging, and this action must always require strong authentication such as MFA. Even when internal logging is turned off, the system must still record the fact that logging was disabled, capturing who performed the action, when it occurred, and the stated reason. This meta-event must be written to a protected or external audit log so that it cannot be erased or modified.

Such a mechanism should always operate on a temporary basis. It is important that logging automatically reactivates after a defined period unless an authorized user explicitly re-extends the window with justification. The mechanism should also allow disabling only the minimum necessary categories of logs rather than shutting off all event recording, ensuring essential security-relevant events remain captured. To further reduce risk, the system should rely on an out-of-band logging path or hardware-secured audit trail so that critical oversight continues even when internal logging is limited.

The intended purposes for disabling logging—such as maintenance, troubleshooting, or preventing system overload—must be clearly documented and communicated. Disabling logging must never be used to obscure user activity or hide system behavior. Finally, security monitoring must track any occurrence of logging deactivation, issuing alerts to the responsible security team, which should review each instance to ensure it aligns with legitimate operational needs.

7.6.5.5 Assessment

7.6.5.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.6.5.5.2 Conceptual assessment

7.6.5.5.2.1 Assessment purpose

7.6.5.5.2.2 Assignment of verdict

7.6.5.5.3 Functional sufficiency assessment

7.6.5.5.3.1 Assessment purpose

7.6.5.5.3.2 Assignment of verdict

7.6.6 [LGM-6] Exclude sensitive personal information (NEW)

7.6.6.1 Requirement

The log messages shall not include any sensitive personal information such as personal identifiable information, secrets, or credentials, or any information which might reasonably be expected to include such items.

7.6.6.2 Rationale

The aim of this requirement is to ensure that log messages do not reveal sensitive information, such as personal identifiable information, secrets, credentials, or any other data that could reasonably be expected to contain sensitive content.

By preventing such information from being written to logs, the product reduces the risk that unauthorized individuals or processes could misuse the data, whether through accidental exposure, system misconfiguration, or deliberate attacks.

This requirement is necessary because logs are often widely accessible for debugging, monitoring, and maintenance purposes, which makes them a frequent target for attackers seeking easy access to sensitive information. If confidential data is stored in logs, it can bypass other protection mechanisms, undermine data-protection obligations, and significantly increase the impact of a security breach. Furthermore, keeping sensitive information out of logs supports compliance with privacy regulations and cybersecurity best practices, ensures that secrets and credentials cannot be harvested for lateral movement or privilege escalation, and contributes to maintaining the overall confidentiality and integrity of the system.

7.6.6.3 Guidance

One type of event whose log message must take care to not accidentally include a secret is failed password authentication attempts. Since people often type their password into the username field, including the username field in the log message may result in including a secret in the log message.

7.6.6.4 Assessment

7.6.6.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.6.6.4.2 Conceptual assessment

7.6.6.4.2.1 Assessment purpose

7.6.6.4.2.2 Assignment of verdict

7.6.6.4.3 Functional sufficiency assessment

7.6.6.4.3.1 Assessment purpose

7.6.6.4.3.2 Assignment of verdict

7.7 [DLM] Deletion mechanism (EN 18031)

7.7.1 [DLM-1] Secure Data deletion mechanisms

7.7.1.1 Requirement

The product shall provide an easy to use deletion mechanism that allows a user to permanently delete their data and settings .

Warning — Consider to append the requirement with " , including where applicable, subsets of those"

(m) provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner ==> Maps in Annex # to DLM, SCM and SSM

7.7.1.2 Rationale

This requirement is needed to prevent the risk of exposing user data and settings regarding disposal or replacement of the product. In multi-user systems this should related to the data and settings in scope of the user role.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (m) of Regulation 2024/2847.

TBD THE ALIGNMENT WITH SECURITY OBJECTIVES,.

7.7.1.3

7.7.1.4 Guidance

The user is generally the individual who uses the product. A user deletes his/her own personal data.

An authorized user is someone who's been granted access to the equipment by a user. An authorized user deletes personal data to which he/she has access.

However, there are cases where another user with administrator rights, separate from the user whose personal data is stored on the product, is responsible for the user management of the product. In such cases, the user with administrator rights has supervisory responsibility to delete the personal information of the user on behalf of the user. A user with administrator rights deletes personal data to which he/she has access.

In some cases the user with administrator rights is not the user, however the user with administrator rights will have the responsibility of ensuring the protection of the user's personal information. In these cases, the deletion mechanism ought to be implemented in such a way that only the user with administrator rights is able to use the deletion mechanism.

If there are multiple users, a user can delete their own data and a user with administrator rights can delete data of all users.

A power up cycle may be used to assure that personal data is persistently deleted.

NOTE 1 Proposal from Simon:

Easy to use is generally understood to mean the functionality is well documented and easily accessible.

Any undue delay in deletion, or completion of partial (e.g., previously interrupted) erasure, could leave user's personal information at risk of being recoverable.

In the context of this provision the expression "delete" means that depending on the risks there can be different technical solutions to appropriately render the personal information permanently unrecoverable.

NOTE 2 This could be a software function that resets the device to its factory settings and erases securely by default the encryption key and generates a new one ensuring that it deletes all this personal information.

The aim of the deletion mechanism is that it:

- is resilient against interruptions; and

NOTE 3 Resilience means that the equipment's deletion mechanism completes when resuming after the interruption.

- is resistant to tampering, such as unauthorised attempt to trigger unauthorised deletion, or such as unauthorised attempt to prevent the authorised deletion; and
- protects against unintentional triggering by the user; and
- is appropriately simple for the user to find and activate.

EXAMPLE 1 Examples of use cases where a user with administrator rights, other than a user of an equipment, is required:

- a separate entity might need to be involved in the launch of the requested deletion of the user's personal information;
- the deletion might require that the approval of the deletion is contingent on the authorisation of the owner of the equipment;
- use cases where special authorisation is needed to delete personal data;
- use cases where the deletion is not be permitted to be performed by the owner of personal data when this data is essential for operational reasons (e.g., industrial context).

EXAMPLE 2 Examples of other standards:

ETSI EN 303 645 [6] and ETSI TS 103 701 [7] refer to simple deletion / delete data easily, whereby TS 103 701 describes "simple" as "in a manner that is understandable for a user with limited technical knowledge".

NOTE 4 Appropriately refers to the level of expertise of the user, the sensitivity of the data, and other factors affecting the access to the triggering of the deletion mechanism.

NOTE 5 [Error! Reference source not found.](#) Guidelines on personally identifiable information deletion (Project 1.27.142) may include useful additional information.

7.7.1.4.1 PROPOSAL: Guidance

TODO: Rework guidance to address user data and settings, and check for SOFTWARE products.

7.7.1.5 Assessment

NOTE Insert abbreviated assessment process after PoC Draft release, unless convenient to add notes whilst drafting the requirement.

7.7.1.5.1 Assessment objective

The assessment addresses the requirement DLM-1.

7.7.1.5.2 Conceptual assessment

7.7.1.5.2.1 Assessment purpose

7.7.1.5.2.2 Assignment of verdict

7.7.1.5.3 Functional sufficiency assessment

7.7.1.5.3.1 Assessment purpose

7.7.1.5.3.2 Assignment of verdict

7.8 [UNM] User notification mechanism

7.8.1 [UNM-1] User notification mechanisms (EN 18031-2)

7.8.1.1 Requirement

The product shall provide user notification mechanism(s) for informing the user of the product about changes affecting the protection or privacy of personal information.

7.8.1.2 Rationale

The objective is to ensure transparency to the user of the product if changes occur that may affect the protection and privacy of personal information, which is collected, stored, or processed by the product.

The transparency allows the user of the product to consider further actions or updates.

Notifying a user in a timely manner allows them to make an informed decision how to handle those changes.

7.8.1.3 Proposal for Rationale

The aim of this requirement is to ensure that users are informed in a timely manner about changes that may affect the protection or privacy of their personal information, enabling awareness and appropriate response to such changes.

This requirement is necessary to support transparency, trust, and effective risk mitigation by allowing users to take informed actions (such as reviewing settings, applying updates, or limiting use) when the protection or privacy of personal information may be impacted, and to support compliance with cybersecurity and data-protection obligations by ensuring that relevant changes are communicated to the user.

The transparency allows the user of the product to consider further actions or updates.

Notifying a user in a timely manner allows them to make an informed decision how to handle those changes.

7.8.1.4 Guidance

The user is generally the individual who uses the product.

A notification sent or displayed by the notification mechanism may be a text message, vocal message, links or any other equivalent communication to the user, the information on notification policy could be also provided in advance in user documentation.

In the context of this requirement, a user is a natural person who may be either the operator or owner of the product.

Changes that may affect data protection and privacy could be:

- the collection and processing of additional categories of personal information prior to the state of the change,
- additional processing operation involving personal information,
- deactivation or major changes of security controls or logging settings intended for the protection of the personal information,
- changes to the types and parameters of processing of personal information, when they impact the level of privacy protection afforded by said processing and parameters.

Providing notification in timely manner depends on the capabilities and status of the product, where the meaning of “timely” varies depending on the importance of the change and product notification mechanism as well as other factors. For example, if the equipment is offline, it may not be able to provide notification to a remote user and the notification would be sent on a best effort basis.

7.8.1.5 Assessment

7.8.1.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.8.1.5.2 Conceptual assessment

7.8.1.5.2.1 Assessment purpose

7.8.1.5.2.2 Assignment of verdict

7.8.1.5.3 Functional sufficiency assessment

7.8.1.5.3.1 Assessment purpose

7.8.1.5.3.2 Assignment of verdict

7.8.2 [UNM-2] Appropriate user notification content (EN 18031-2)

NOTE In EN 18031-2 the name of the section was [UNM-2] Appropriate user notification content

7.8.2.1 Requirement

The content of a notification provided by a user notification mechanism that is required per UNM-1 shall include at least:

- a description of a change; and
- a description of how a change will affect the protection and privacy of personal information.

7.8.2.2 Rationale

Transparent and comprehensible information allows the user of the product to understand what the changes are that affect data protection and privacy of the asset.

NOTE Editorial - Insert abbreviated assessment process after PoC Draft release.

This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (d) and (f) of Regulation 2024/2847. It is also necessary to cover the threats [Threat.NotReportedUnauthorizedAccess], [Threat.**TamperingUndetected**] and to meet the corresponding security objective [SO. AccessControlReport],[SO. **IntegrityReport**] as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

Editors Note:

This is just for indication of the related ER, Threat and Security objective may frim the TR. This may be used in a mapping table.

ER

Associated with: ECR ANNEX I Part I (2) (d) of (EU) 2024/2847

Threat

Threat.NotReportedUnauthorizedAccess:

An Attacker's unauthorized access cannot be reported by the PwDE.**Security objective**

SO.AccessControlReport: The PwDE provides means to detect and report unauthorized access attempts.

ER

Associated with: ECR ANNEX I Part I (2) (f) of (EU) 2024/2847

Threat

Threat.TamperingUndetected: An attacker tampers with data processed by a PwDE and remains undetected.

Security objective

SO.IntegrityReport: The PwDE detects and reports data tampering.

7.8.2.3 Proposal for Rationale

The aim of this requirement is to ensure that users are informed in a clear and transparent manner about changes introduced by the product and to enable them to understand whether and how such changes may impact the protection and privacy of their personal information.

This requirement is necessary because changes to a product, including software updates, configuration changes, or modifications of functionality, may alter how personal information is processed, protected, or exposed. Providing users with a description of the change and its effects

on protection and privacy supports informed user decisions, maintains trust, and reduces the risk of unintended adverse impacts on personal information due to insufficient awareness of security- or privacy-relevant changes.

NOTE Editorial - Insert abbreviated assessment process after PoC Draft release.

This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (d) and (f) of Regulation 2024/2847. It is also necessary to cover the threats [Threat. NotReportedUnauthorizedAccess], [Threat. **TamperingUndetected**] and to meet the corresponding security objective [SO. AccessControlReport], [SO. **IntegrityReport**] as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.8.2.4 Guidance

Reflection of the content of a notification is an explanation to the user of the product that describes how the changes affect data protection and privacy of personal information.

The content of a notification needs to be in a precise, transparent, comprehensible and easily accessible form.

Any information for children needs to be provided concisely, prominently, and using clear language suited to the age of children.

7.8.2.5 Assessment

7.8.2.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.8.2.5.2 Conceptual assessment

7.8.2.5.2.1 Assessment purpose

7.8.2.5.2.2 Assignment of verdict

7.8.2.5.3 Functional sufficiency assessment

7.8.2.5.3.1 Assessment purpose

7.8.2.5.3.2 Assignment of verdict

7.9 [RLM] Resilience mechanism

7.9.1 [RLM-1] Resilience mechanism

7.9.1.1 Requirement

The product shall use resilience mechanisms to mitigate the effects of incidents, e.g. Denial-of-Service (DoS) attacks on interfaces, and return to a defined state after the attack.

The product's resilience mechanisms shall include maintaining basic and essential functions during incidents, e.g. denial-of-service attacks.

7.9.1.2 Proposal for Requirement

[RLM-1-1] The product shall use resilience mechanisms to mitigate the effects of incidents, e.g. Denial-of-Service (DoS) attacks on interfaces, and return to a defined state after the attack.

[RLM-1-2] The product's resilience mechanisms shall include maintaining basic and essential functions during incidents, e.g. denial-of-service attacks.

7.9.1.3 Rationale

The aim of this requirement is the availability of product's basic and essential functions during and after incidents.

This requirement is necessary as incidents, e.g. Denial of Service attacks, can be disruptive to the availability of resources and may cause permanent disruption to functions of the product if the attacked product is not recovering from an incident, e.g. DoS attack, properly.

Some industrial products require very high availability to operate continuously. Mechanisms such as rate limiting could restrict unauthorized as well as authorized access to critical functions. Hence, resilience mechanisms on industrial product can be implemented in the environment of the product and not embedded in the product itself to avoid impact on its continuous operation.

Many products support critical functions, e.g. functions that are related to safety. Even during an attack, the product needs to continue to perform its critical functions to avoid severe consequences. Instead of failing entirely, the product degrades gracefully, dropping non-essential functionalities to preserve the basic and essential functions. This allows the product to remain partially operational rather than completely unresponsive.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (h) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.AvailabilityDegradationAfterIncident]**, **[Threat.AvailabilityDegradationDuringIncident]** and to meet the corresponding security objectives **[SO.IncidentRecovery]**, **[SO.IncidentResilience]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.9.1.4 Guidance

To reduce the impact of attacks targeting network interfaces, the product typically is designed to employ functions that mitigate the effects of such attacks on network services and internal resources. When subjected to Denial-of-Service (DoS) conditions, the product is recommended to transition into a defined state that preserves its essential functions and safeguards system stability. This defined state, determined by the manufacturer based on the intended product functionality, may include resilience mechanisms that enable continued operation even while network interfaces are overloaded, malformed traffic is received, or resources are under

pressure. Once the disruptive condition ceases, the product is recommended to automatically recover to a defined operational state without requiring manual intervention, ensuring that normal functionality resumes safely and predictably.

The objective of these resilience mechanisms is to ensure that the product remains operational during an ongoing attack, rather than becoming unresponsive or unstable. Depending on the nature and purpose of the product, such mechanisms may include network storm protection, packet filtering, and rate-limiting techniques that restrict excessive traffic loads. Additional strategies may involve reserving internal system resources such as CPU cycles, memory, or queue capacity to prevent exhaustion caused by malicious traffic patterns. These mechanisms must be implemented with care to avoid impairing the product's intended functionality or reducing the availability of important or essential services.

If the system becomes compromised, overloaded, or unstable, it may intentionally transition into a restricted, minimal-functioning secure state to maintain critical services while preventing additional damage. In this degraded mode, the system focuses on maintaining continuity of essential operations, limiting the spread of corruption or attacks, protecting sensitive data, and enabling diagnosis and recovery. Degradation may take several forms, such as prioritizing only essential functions, limiting throughput or transactions, disabling non-critical services or background tasks, reducing performance parameters like bandwidth or parallel connections, or temporarily strengthening security controls including stricter authentication requirements or limited network access. Additional measures may involve isolating vulnerable components, activating fallback mechanisms, or increasing monitoring and logging activities to support later analysis.

Throughout both the attack and recovery phases, the product must ensure that resilience measures do not conflict with its operational purpose. All mechanisms are recommended to be documented by the manufacturer and must not impair essential functionality, system safety, or the availability of critical services. The overall goal is to provide robust and predictable behavior under attack conditions, maintain essential capabilities during disruptions, and restore full functionality automatically when normal conditions return.

7.9.1.5 Assessment

7.9.1.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.9.1.5.2 Conceptual assessment

7.9.1.5.2.1 Assessment purpose

7.9.1.5.2.2 Assignment of verdict

7.9.1.5.3 Functional sufficiency assessment

7.9.1.5.3.1 Assessment purpose

7.9.1.5.3.2 Assignment of verdict

7.9.2 [RLM-2] Recovery from incidents

7.9.2.1 Requirement

The product shall automatically recover to a normal and secure operational state when denial-of-service conditions cease or when other disruptive incidents (such as temporary network outages, resource-exhaustion events, failed communication attempts, transient hardware faults, or incomplete/corrupted data exchanges) are resolved, without requiring manual intervention.

7.9.2.2 Rationale

The aim of this requirement is to ensure that the product can reliably and automatically return to a normal operational state after temporary disruptions—such as denial-of-service conditions, transient network outages, resource-exhaustion events, temporary hardware faults, or corrupted/incomplete communication sequences, power loss—have ceased. The purpose is to maintain system availability, reduce downtime, and restore secure functionality without requiring human interaction. This supports resilience and ensures that the product behaves predictably even after stressful or abnormal events.

Attacks (in particular Denial of Service attacks) are disruptive to the availability of basic and essential functions of the product including network resources and may cause permanent disruption if the attacked product is not recovering from an attack properly.

This requirement is necessary because many operational or cybersecurity disruptions are temporary in nature and do not justify a manual recovery process. If the product cannot recover autonomously, it may remain in a degraded or nonfunctional state, even though the triggering condition has already ended. This exposes the system to unnecessary downtime, increases the operational burden on users or administrators, and can create opportunities for further exploitation. Automatic recovery also helps prevent persistent malfunction after denial-of-service attempts, protects against resource starvation side effects, and ensures the device can reestablish secure operation following transient failures. By recovering automatically, the product improves resilience, reduces system maintenance requirements, and supports secure and continuous operation under a broad range of real-world conditions.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (h) of Regulation 2024/2847. It is also necessary to cover the threats [Threat.LongTermAvailabilityDegradation] and to meet the corresponding security objective [SO.IncidentRecovery] as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.9.2.3 Guidance

To implement this requirement, the product integrates typically mechanisms that continuously monitor its operational status and identify when a disruptive condition—such as a denial-of-service attack, resource exhaustion, temporary hardware error, or communication failure—has ended. Once the disruptive condition is no longer present, the product is recommended to be capable of autonomously restoring normal operations without requiring

user interaction. This includes restarting paused services, re-establishing network sessions, clearing internal resource locks, reinitializing communication stacks, and reapplying secure default states where necessary. The product is recommended to ensure that recovery procedures do not compromise security controls and that restored operations remain consistent with the system's defined security posture.

The automatic recovery process is recommended to be designed to avoid introducing additional instability. For example, repeated restart loops, aggressive retries, or premature transitions back to full operation is recommended to be avoided. The product is recommended to implement controlled back-off timers, validation checks, and conditions that confirm the disruptive event has fully cleared before normal service resumes. In scenarios involving corruption or inconsistent state, the system is recommended to rely on integrity-verified data or fallback mechanisms to ensure that recovery does not restore compromised information.

Security protections must remain in place during recovery. This includes ensuring that authentication, authorization, logging, and monitoring functions are re-established correctly after the disruption. The product is recommended to also retain logs of the disruptive condition and the recovery process to support forensic analysis, troubleshooting, and incident response activities. Documentation is recommended to clearly describe which events trigger recovery, which services or functions are restored, and how the system ensures integrity and availability during and after the process. Testing is recommended to include simulations of denial-of-service, hardware transients, communication failures, and resource conflicts to verify that the product consistently returns to normal operation without manual intervention.

7.9.2.4 Assessment

7.9.2.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.9.2.4.2 Conceptual assessment

7.9.2.4.2.1 Assessment purpose

7.9.2.4.2.2

7.9.2.4.2.3 Assignment of verdict

7.9.2.4.3 Functional sufficiency assessment

7.9.2.4.3.1 Assessment purpose

7.9.2.4.3.2 Assignment of verdict

7.9.3 [RLM-3] Network prioritization

7.9.3.1 Requirement

The product shall use a mechanism to prioritize the execution of functions in the case of a network resource conflict.

7.9.3.2 Rationale

The aim of this requirement is to ensure that, when network resources become constrained or contested, the product can continue to perform its most critical cybersecurity and operational functions without interruption. In situations where bandwidth is limited or multiple processes compete for network access, prioritization mechanisms guarantee that essential security processes—such as authentication, system monitoring, command processing, or intrusion detection—remain operational and responsive.

This requirement is necessary because network resource conflicts can lead to delays, dropped packets, or failures in critical communications. Without a prioritization mechanism, vital security functions may be starved of the network bandwidth they require, increasing the risk of system compromise, degraded performance, or operational downtime. Prioritization ensures resilience against network overload, denial-of-service conditions, or unexpected traffic spikes, thereby protecting the overall system integrity, availability, and security posture.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (h) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.AvailabilityDegradationDuringIncident]** and to meet the corresponding security objectives **[SO.IncidentResilience]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.9.3.3 Guidance

To meet this requirement, the product is recommended to implement a mechanism that ensures critical cybersecurity and operational functions continue to operate effectively even when network resources become constrained. This involves defining which system functions are essential to maintaining security and operational integrity, and assigning priority levels based on their criticality. The product is recommended to apply appropriate network traffic management techniques—such as prioritization queues, traffic shaping, or rate limiting—to ensure that high-priority communications are always transmitted before less critical ones. When applicable, network protocols are recommended to be configured to support differentiated services or priority tagging.

The product is recommended to also define clear resource allocation policies that specify how non-critical tasks are recommended to behave during periods of congestion, for example by delaying updates or reducing data refresh rates, thereby preventing them from consuming bandwidth required by essential processes. Additionally, mechanisms are recommended to be implemented to continuously monitor network conditions and detect resource conflicts so that prioritization can be activated automatically when thresholds are exceeded. Even in severe degradation scenarios, the system must maintain fail-safe behavior to preserve essential security functions and ensure system integrity.

Finally, the prioritization logic and behavior is recommended to be thoroughly documented in the system design, and verified through testing under simulated congestion or stress scenarios to confirm that the mechanism performs as intended.

7.9.3.4 Assessment

7.9.3.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.9.3.4.2 Conceptual assessment

7.9.3.4.2.1 Assessment purpose

7.9.3.4.2.2

7.9.3.4.2.3 Assignment of verdict

7.9.3.4.3 Functional sufficiency assessment

7.9.3.4.3.1 Assessment purpose

7.9.3.4.3.2 Assignment of verdict

7.9.4 [RLM-4] Resource prioritization

7.9.4.1 Requirement

The product shall use a mechanism to prioritize the execution of essential functions in the case of a CPU, memory or power resource conflict.

EXAMPLE The product uses the following prioritization in case of resource conflict (high to low priority): 1) Time sensitive availability relevant functions. 2) Authenticated consumer commands. 3) Background tasks (e.g. logging, updates).

NOTE At least the following resources can cause a processing resource conflict: CPU, memory, power

7.9.4.2 Rationale

The aim of this requirement is to ensure that the product remains capable of performing its critical cybersecurity and operational functions even when system resources such as CPU capacity, memory availability, or power supply become constrained. By applying prioritization, the system can continue executing essential tasks—such as security monitoring, authentication, data integrity checks, or safety-relevant processes—while less critical functions are delayed, reduced, or temporarily suspended. This maintains system stability, security posture, and predictable behavior under degraded conditions.

This requirement is necessary because resource conflicts can lead to system slowdowns, failures, or inability to execute time-critical security functions. High CPU load can delay essential

processes, memory exhaustion can cause crashes or unpredictable behavior, and insufficient power can force the system into unsafe or unsecure states. Without a mechanism for prioritization, critical operations may be starved of resources, increasing the risk of security breaches, data corruption, operational malfunction, or complete system unavailability. Prioritization ensures resilience against overload, protects system integrity, and supports safe and secure system operation even in exceptional or fault conditions.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (h) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.AvailabilityDegradationDuringIncident]** and to meet the corresponding security objectives **[SO.IncidentResilience]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.9.4.3 Guidance

To implement this requirement, the product is recommended to employ a resource-management strategy that ensures critical cybersecurity and operational functions continue to execute reliably even when CPU capacity, memory availability, or power supply becomes limited. This includes identifying the system's essential functions and assigning them a higher priority so they are guaranteed access to necessary resources under all operating conditions. The system is recommended to dynamically manage workloads by reducing, delaying, or suspending lower-priority tasks when resource pressure is detected, ensuring that essential functions such as security monitoring, authentication, logging, or safety-related processes are never starved of CPU cycles, memory space, or power.

The product is recommended to incorporate mechanisms capable of monitoring resource usage in real time and detecting early signs of conflict or degradation. Based on these detections, predefined resource-allocation policies are recommended to automatically adjust task scheduling, memory allocation, and power consumption to maintain predictable and secure system behavior. For power-constrained scenarios, the system is recommended to implement controlled fallback modes that preserve the ability to perform critical security functions even under reduced power conditions.

The prioritization logic, detection thresholds, and fallback strategies are recommended to be documented in the system's design specifications. Verification testing—such as stress tests, overload simulations, memory-pressure scenarios, and power-drop conditions— is recommended to be conducted to ensure that the prioritization mechanism consistently maintains system integrity and fulfills the requirement under various real-world stress situations.

7.9.4.4 Assessment

7.9.4.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.9.4.4.2 Conceptual assessment

7.9.4.4.2.1 Assessment purpose

7.9.4.4.2.2 Assignment of verdict

7.9.4.4.3 Functional sufficiency assessment

7.9.4.4.3.1 Assessment purpose

7.9.4.4.3.2 Assignment of verdict

7.9.5 [RLM-5] Resource management

7.9.5.1 Requirement

The product shall provide mechanisms to control and limit the resource usage of security-related functions to ensure protection against resource exhaustion conditions

The product shall provide mechanisms to warn the user before or at least during a essential function becomes unavailable due to resource limitations.

EXAMPLE 1 A cloud RDPS recognises a non-availability of its connected product and sends a notification to the user.

EXAMPLE 2 A product with a network-dependend essential function recognizes a low bandwidth and sends a notification to the user.

7.9.5.2 Rationale

The aim of this requirement is to ensure that security functions within the product do not unintentionally consume excessive system resources such as CPU, memory, storage, or network bandwidth. By limiting resource usage, the system maintains its ability to execute both security-critical and operationally essential functions reliably. This helps preserve system stability and predictability, even when security components are running intensive tasks such as scanning, logging, encryption, or monitoring.

This requirement is necessary because security functions that operate without boundaries can unintentionally trigger resource-exhaustion conditions, degrading overall system performance or causing critical operations to fail. Excessive resource consumption - whether due to misconfiguration, software defects, or malicious manipulation - can prevent the system from performing essential tasks, result in denial-of-service conditions, or create openings for attackers to exploit. By enforcing resource limitations, the product prevents self-inflicted denial-of-service behavior, ensures system availability, and maintains a stable operating environment, even during periods of high security workload or attempted resource-exhaustion attacks.

NOTE NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (h) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.AvailabilityDegradationDuringIncident]** and to meet the corresponding security objectives **[SO.IncidentResilience]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.9.5.3 Guidance

To fulfill this requirement, the product is recommended to implement mechanisms that control and limit the amount of CPU, memory, storage, and other resources consumed by its security functions. This includes defining clear operational boundaries for activities such as logging, monitoring, scanning, cryptographic operations, and network security processes. Resource-limiting strategies may include rate limiting, process throttling, memory quotas, workload scheduling, and the use of prioritized queues.

The system is recommended to monitor resource usage in real time and detect when security functions approach defined thresholds. When limits are reached, the product is recommended to automatically adjust behavior—such as reducing scan frequency, buffering logs intelligently, or pausing non-critical security tasks—while ensuring that essential protective measures remain active. The goal is to prevent uncontrolled resource consumption without weakening the core cybersecurity posture.

It is important that these limiting mechanisms are designed in a way that avoids inadvertently disabling necessary protections. Therefore, fallback strategies are recommended to ensure that essential cybersecurity controls continue to operate at a minimum functional level, even when restrictions are applied. Documentation is recommended to clearly describe the resource-management concepts, thresholds, fallback behaviors, and interactions with other system functions. Finally, verification activities are recommended to include stress tests, resource-exhaustion simulations, and fault-injection scenarios to ensure that the limiting mechanisms operate as intended and do not introduce new vulnerabilities or operational risks.

The mechanism includes capability to reconnect cleanly after a loss of network connection.

EXAMPLE A product loses connection to the local network as the network is temporarily unavailable. After recognizing the restored network, the product reconnects after a randomized delay to reconnect cleanly.

NOTE *Reconnecting cleanly* normally involves resuming connectivity to network in an expected, operational and stable state and in an orderly fashion taking the capability of the infrastructure into consideration.

7.9.5.4 Assessment

7.9.5.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.9.5.4.2 Conceptual assessment

7.9.5.4.2.1 Assessment purpose

7.9.5.4.2.2 Assignment of verdict

7.9.5.4.3 Functional sufficiency assessment

7.9.5.4.3.1 Assessment purpose

7.9.5.4.3.2 Assignment of verdict

7.9.6 [RLM-6] Control system backup

7.9.6.1 Requirement

The product

a) shall provide the capability to provide backup operations or to support the integration into a system to provide backup operations and

b) the backup process shall not negatively affect the normal component operations.

7.9.6.2 Rationale

The aim of this requirement is to ensure that the product can either perform backup operations itself or be integrated into a system architecture where reliable backup operations are provided. This supports the protection of critical data, configurations, and system states so that recovery is possible after failures, cyber incidents, or data corruption. In addition, the requirement aims to ensure that performing backups does not disrupt or degrade the product's normal operational functions or the performance of the broader system.

This requirement is necessary because backups are a fundamental cybersecurity and resilience measure. They protect against data loss caused by hardware faults, software defects, operator errors, or cyberattacks such as ransomware, manipulation, or tampering. Without a backup capability—or the ability to integrate into an external backup solution—the product may not be able to restore its secure and functional state after an incident, leading to extended downtime, unsafe operation, or permanent loss of critical configuration data. Ensuring that backup processes do not negatively impact normal operation is equally important, because uncontrolled resource consumption or service interruptions during backup could degrade system performance, interfere with time-critical functions, or introduce new security risks.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (h) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.AvailabilityDegradationDuringIncident]** and to meet the corresponding security objectives **[SO.IncidentResilience]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.9.6.3 Guidance

To comply with this requirement, the product is recommended to implement mechanisms that enable regular, secure, and consistent backup of relevant data, or provide interfaces that allow seamless integration into an external or system-level backup solution. This includes defining what data must be backed up—such as configuration parameters, security-related files, operational data, or system logs—and ensuring that the backup operation is reliable, complete,

and protected against unauthorized access or tampering. When the product relies on system-level backup infrastructure, it is recommended to offer well-documented interfaces, APIs, or protocols to ensure compatibility and secure data exchange.

The backup process is recommended to be designed so that it does not interfere with or degrade the product's normal operation. This may involve scheduling backups during low-load periods, applying throttling or prioritization techniques, or performing incremental rather than full backups when feasible. The system is recommended to monitor resource usage during backup and ensure that essential operational and cybersecurity functions remain fully available. If resource conflicts arise, the product is recommended to implement policies to adjust backup activities without compromising system safety, security, or responsiveness.

Security considerations are recommended to be embedded throughout the process. Backup data must be protected during generation, transmission, and storage through authentication, encryption, integrity checks, and access controls. Documentation is recommended to clearly describe the backup mechanisms, the required data scope, scheduling logic, fallback behavior, and any dependency on external systems. Testing is recommended to verify that backup operations complete successfully, that restored data is accurate, and that the backup process does not negatively impact the product's performance, real-time behavior, or cybersecurity posture under various operational scenarios.

7.9.6.4 Assessment

7.9.6.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.9.6.4.2 Conceptual assessment

7.9.6.4.2.1 Assessment purpose

7.9.6.4.2.2 Assignment of verdict

7.9.6.4.3 Functional sufficiency assessment

7.9.6.4.3.1 Assessment purpose

7.9.6.4.3.2 Assignment of verdict

7.10 [NMM] Network monitoring mechanism (EN 18031)

7.10.1 [NMM-1] Network monitoring mechanisms (EN 18031)

7.10.1.1 Requirement

The product shall provide network monitoring mechanism(s) to detect for indicators of attacks, e.g. DoS attacks and known exploits, in the network traffic between the product itself and connected devices.

7.10.1.2 Rationale

The aim of the requirement is to increase cyber resilience of a system as a whole against unusual network traffic related to the intended product functionality which could lead, e.g. to a DoS. Each product as a component of such a system needs to be able to detect indications for attacks, e.g. DoS events and known exploits.

This requirement is necessary as, with the fulfilment of the requirement, the product is able to detect unusual traffic and patterns which could be related to a DoS Attack or a known exploit.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat **[Threat.ExtServiceAvailabilityDegradation]** to meet the corresponding security objective **[SO.MonitorExternalImpact]**.

7.10.1.3 Guidance

Unusual traffic which ought to be taken into account are for instance network datagrams which can result in a partial or full Denial-of-Service of the network. The origin of a DoS event can be an unintentional malfunction of an arbitrary network resource as well as an intentional attack. Usually, the product which is implementing this requirement will not be the target of a DoS Attack. Probably it will route or forward the traffic directly or indirectly towards the target.

Detection of attacks, e.g. DoS events or known exploits, can be behaviour or pattern based, which ever method may be appropriate for the equipment, the intended equipment functionality and intended operational environment of use. The detection of known exploits should leverage indicators of compromise, signatures or protocol-aware analysis for vulnerabilities that are known to be exploitable in the relevant network services.

Examples of measures which could be implemented to monitor the network traffic with regard to possible DoS attacks or known exploits are:

- monitoring of the number of datagrams in a defined timeframe,
- monitoring if there are datagrams which are originating from an on the product unconfigured network or have a destination network which is outside of configured network of the network equipment,
- monitoring of malformed and modified datagrams,
- monitoring for known malicious payload patterns or signatures associated with known exploitable vulnerabilities in the protocols and services used by the product,
- monitoring for abnormal or unexpected protocol usage, e.g. unexpected combinations of messages, out-of-range field values, or use of deprecated or insecure options, that are characteristic of known exploit techniques,

- monitoring for repeated failed attempts to access or manipulate particular services, endpoints or functions, corresponding to known exploit scenarios.

7.10.1.4 Assessment

7.10.1.4.1 Assessment objective

The assessment covers a:

- conceptual assessment of [NMM-1],
- functional completeness assessment on the product capabilities that are addressed by [NMM-1],
- functional sufficiency assessment of each mechanism used by the product to fulfil [NMM-1] based on the default configuration from clause 'secure by default configuration'.

7.10.1.4.2 Assessment preparation

The following documentation for the product shall be complete:

- a list and description of [network monitoring mechanisms] and where they are used to [monitor network interfaces and detect events related to security and privacy assets],
- [description of monitored network interfaces, events, and detection rules]

The following test setups shall be prepared:

- [tests to verify that network monitoring mechanisms are implemented on relevant network interfaces]
- [tests to verify detection of security-relevant network events]
- [tests to verify completeness of monitored interfaces and events]

7.10.1.4.3 Assessment activities

The product's conformity to [NMM-1] shall be validated based on the documentation. The correctness and completeness of the documentation shall be verified by:

- [verification that all relevant network interfaces are covered by network monitoring mechanisms]
- [verification that monitored events related to security and privacy assets are documented]
- [verification that justification for applicability of network monitoring mechanisms is documented]

For each [network monitoring mechanism], its correct implementation shall be verified by:

- [test verifying that the monitoring mechanism is active on all applicable network interfaces]
- [test verifying that relevant network events are detected]
- [test verifying that no applicable interface is left unmonitored]

7.10.1.4.4 Assignment of verdict

The verdict PASS shall be assigned if:

- the documentation indicates the product's conformity to [NMM-1]; and
- the verification of the correctness and completeness of the documentation was successful by verifying that every documented [network monitoring mechanism] exists in the product and shows the expected behavior; and

The verification of the correct implementation of each [network monitoring mechanism] is successful by verifying:

- [that the monitoring mechanism is active on all applicable network interfaces];
- [that relevant network events are detected];
- [that all applicable network interfaces are monitored].

The verdict FAIL shall be assigned otherwise.

7.10.1.4.5 Supporting evidence

- records of the validation of the documentation
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation
- descriptions of the performed tests and records of performed tests to verify the correct implementation of each [network monitoring mechanism]

7.11 [TCM] Traffic control mechanism (EN 18031)

7.11.1 [TCM-1] Traffic control mechanism

7.11.1.1 Requirement

The product shall provide network traffic control mechanism(s) to manage the flow of data packets to protect the availability of services provided by other devices or networks.

7.11.1.2 Rationale

The aim of this requirement is that products can establish a robust defence against anomalous traffic, protect sensitive data, and maintain the integrity and availability of the intended equipment functionality through its applications and networks. This would also allow to manage the flow of data packets to protect the availability of services provided by other devices or networks.

This requirement is necessary as malicious data traffic may be generated by a compromised product. While operators' networks may implement measures to mitigate the effects of malicious traffic based on a datagram's header information, their knowledge of the network's properties might hinder an effective treatment. Products can have sufficient information to detect malicious traffic and a traffic control mechanism allows to prevent the network from corresponding harm.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat **[Threat.ExtServiceAvailabilityDegradation]** to meet the corresponding security objectives **[SO.LimitExternallImpact]** and **[SO.PreventAttackPropagation]**.

7.11.1.3 Guidance

Controlling data traffic on network layer based on network addresses includes the product's ability to block or redirect certain datagrams based on their source or destination address.

Traffic control mechanisms refer to the set of mechanisms that can be combined with policies, and procedures designed to monitor, manage, and secure the flow of data and communications. These mechanisms aim to protect the availability and reliability of critical services.

7.11.1.4 Assessment

7.11.1.4.1 Assessment objective

The assessment covers a:

- conceptual assessment of TCM-1,
- functional completeness assessment on the product capabilities that are addressed by TCM-1,
- functional sufficiency assessment of each mechanism used by the product to fulfil TCM-1

based on the default configuration required by clause 5.2.

7.11.1.4.2 Assessment preparation

The following documentation for the product shall be complete:

- a list and description of traffic control mechanisms and where they are used to control and manage network traffic,
- documentation of controlled network interfaces and traffic flows,
- documentation of rules and policies applied by traffic control mechanisms

The following test setups shall be prepared: • setup to generate and monitor network traffic across all relevant interfaces

- setup to simulate normal and abnormal traffic conditions
- setup to verify enforcement of configured traffic control rules • setup to validate behaviour under different traffic patterns

7.11.1.4.3 Assessment activities

The product's conformity to TCM-1 shall be validated based on the documentation. The correctness and completeness of the documentation shall be verified by:

- reviewing the specification of traffic control mechanisms
- verifying that all network interfaces requiring traffic control are documented

- checking that documented mechanisms define applicable traffic control policies

For each traffic control mechanism, its correct implementation shall be verified by:

- testing that traffic control mechanisms are present on applicable interfaces
- testing that traffic control rules are enforced according to documentation
- testing that unauthorized or abnormal traffic is handled as specified

7.11.1.4.4 Assignment of verdict

The verdict PASS shall be assigned if:

- the documentation indicates the product's conformity to TCM-1; and
- the verification of the correctness and completeness of the documentation was successful by verifying that every documented traffic control mechanism exists in the product and shows the expected behavior; and

The verification of the correct implementation of each traffic control mechanism is successful by verifying:

- presence of traffic control mechanisms on applicable interfaces
- enforcement of documented traffic control rules
- correct handling of unauthorized or abnormal traffic
- correct operation under defined traffic conditions

The verdict FAIL shall be assigned otherwise.

7.11.1.4.5 Supporting evidence

- records of the validation of the documentation
- descriptions of the performed tests and records of performed tests to verify the correctness and completeness of the documentation
- descriptions of the performed tests and records of performed tests to verify the correct implementation of each traffic control mechanism

7.12 [CCK] Confidential cryptographic keys

NOTE Confidential cryptographic key is a defined term. Other secrets, whose disclosure cannot be used to harm the product or its functioning or for the misuse of product resources, such as secrets solely protecting intellectual property are not covered by the definition of confidential cryptographic key.

7.12.1 [CCK-1] Appropriate CCKs (EN 18031)

7.12.1.1 Requirement

Confidential cryptographic keys that are preinstalled or generated by the equipment during its use, shall support a minimum security strength of 112-bits.

Warning — (Decision on 23.01.2026: The value of 112 bits is retained for the initial draft and subject to further discussion.)

NOTE 1 Depending on the expected product lifetime and the intended data protection duration, a higher security strength may be appropriate

NOTE 2 The requirement refers to all confidential cryptographic keys chosen by the product manufacturer either directly or imposed by a protocol. For instance, the manufacturer directly chooses/configures the cipher suite of TLS protocol to be used by the device, other protocols may impose one single option for cryptographic algorithms and their respective keys.

7.12.1.2 Rationale

The product can use cryptography and therefore CCKs for many and different purposes like for:

- authentication to enforce access control to assets,
- protecting confidentiality and integrity of assets at rest, when communicated to another entity
- the derivation of other CCKs.

If the confidentiality of a CCK is compromised, the assets protected by the CCK can get compromised too. A CCK of a product generated for an algorithm used for cryptographic protection is appropriate when:

- a successful attack on it does not affect of the other CCKs used or generated by this product or by other product
- the algorithm has an adequate security strength using this CCK to resist attacks proportionate to its use and targeting to break its confidentiality.

The aim of this requirement is to ensure that confidential cryptographic keys (CCKs) used by the product provide an appropriate level of security strength that is sufficient for their intended cryptographic purpose and the protection needs of the associated assets throughout the expected product lifetime.

This requirement is necessary to ensure that confidential cryptographic keys used by the product provide sufficient resistance against attacks proportionate to their intended use, so that the compromise of a key does not undermine the confidentiality or integrity of the assets it protects.

NOTE **This requirement is necessary** to meet the essential cybersecurity requirements (e) and (f) of Regulation (EU) 2024/2847. It is necessary to cover the **<threat_name> (TBD)** and to meet the corresponding security objective **SO.SecureProvisioning** as described in the PT2 TR.

It might also help to meet other essential cybersecurity requirements of Regulation (EU) 2024/2847 where cryptographic protection mechanisms are applied.

7.12.1.3 Guidance

The security strength supported by a CCK depends mainly on 3 parameters:

- the *entropy* of the RNG used for their generation; and
- its effective *length* (see BSI TR-02102-1 [19]); and
- on the *cryptographic algorithm* with which it is used.

Another important aspect which is related to the needed security strength supported by a CCK is the lifetime of the CCK. Long term CCKs which are stored and used repeatedly for a long period of time would need a longer in time resistance against attacks compared to short term CCKs which are usually generated on the product and only used for a short time. For instance, session keys used for a single communication session to encrypt the transferred security assets or network assets are a typical example for short term keys.

However perfect forward secrecy is an aspect that usually is taken into account for the security of session keys and so these are usually generated/derived with adequate cryptographic mechanisms so that session keys of past sessions cannot be compromised. Refer to CRY-1 for guidance on best practice.

Additional good security practices need also to be taken into account. For instance, it is a good security practice to use one CCK for a single purpose. Special care is to be taken for CCKs which are not used anymore, for instance these are to be deleted. It is recommended to follow recognized best practices for that, see CRY-1 requirement. It is also recommended that the same CCK is not replicated and used on the different specimens/units of this product.

NOTE The appropriate security strength can be determined based on state-of-the-art cryptography as specified in [CRY-1].

7.12.1.4 Assessment

7.12.1.4.1 Assessment objective

The assessment addresses the requirement CRY-1.

7.12.1.4.2 Required information

For all of the security assets and functions described in the Architectural Description (as defined by PT1) protected by cryptography, including for each cryptography used for cryptographic protection:

- A description of the cryptography used for cryptographic protection, including:
 - description of each cryptographic protection goal; and
 - evidence to justify that the cryptography is best practice for the cryptographic protection goals

NOTE 1 The documentation of a cryptographic protection goal includes the security objectives provided by cryptography.

NOTE 2 Cryptography used for cryptographic protection can amongst others include cryptographic schemes, algorithms, constructors and primes.

NOTE 3 Evidence to justify that the cryptography is best practice for the cryptographic protection goals can be based a reference catalogues, e.g., SOGIS Agreed Cryptographic Mechanisms (<https://www.sogis.eu>) [24], or other evidence, e.g., by crypto analysis.

7.12.1.4.3 Conceptual assessment

The purpose of this assessment case is the conceptual assessment whether security strength of confidential cryptographic keys complies with the requirements defined in CCK-1.

7.12.1.4.3.1 Assessment purpose

The purpose of this assessment is to determine whether the cryptography specified in the product's Architectural Description meet the requirement of CRY-1.

7.12.1.4.3.2 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- for each cryptographic cipher identified, the cipher strength is determined to meet the requirement of CRY-1.

The verdict FAIL for the assessment case is assigned if:

- any cryptographic cipher identified, the cipher strength is determined to not to meet the requirement of CRY-1.

7.12.1.4.4 Functional sufficiency assessment

7.12.1.4.4.1 Assessment purpose

The purpose of this assessment case is the functional assessment whether the cryptography in the Architectural Description [PT1] has been implemented as it has been described.

7.12.1.4.4.2 Assignment of verdict

The verdict of PASS for the assessment case is assigned, if cryptographic protection has been implemented as documented in the Architectural Description.

The verdict of FAIL for the assessment case is assigned, if cryptographic protection has not been implemented as documented in the Architectural Description.

7.12.2 [CCK-2] CCK generation mechanisms (EN 18031)

7.12.2.1 Requirement

The generation of confidential cryptographic keys shall adhere to best practice cryptography.

7.12.2.2 Rationale

CCKs that are generated by the product and used to protect assets, need to be generated appropriately in order to prevent successful attacks based on CCKs with insufficient security

strength. An appropriate CCK generation mechanism ensures that CCKs have the necessary properties based on the associated risks and the operational conditions of the product.

The aim of this requirement is to ensure that confidential cryptographic keys generated by the product possess sufficient randomness, unpredictability, and independence to support secure cryptographic operations.

This requirement is necessary to ensure that confidential cryptographic keys generated by the product are not weakened by predictable, insufficient, or correlated generation processes, which could otherwise undermine the effectiveness of cryptographic protection mechanisms.

NOTE **This requirement is necessary** to meet the essential cybersecurity requirements (e) and (f) of Regulation (EU) 2024/2847. It is necessary to cover the **<threat_name> (TBD)** and to meet the corresponding security objective **SO.SecureProvisioning** as described in the PT2 TR.

It might also help to meet other essential cybersecurity requirements of Regulation (EU) 2024/2847 where cryptographic protection mechanisms are applied.

7.12.2.3 Guidance

The security strength of a CCK is largely determined by the random number source (the main source of entropy) and the random number generator and the key generation/derivation algorithm which generate it.

Risks related to poor choices of random source, random number generators and key derivation can make a CCKs subject to attacks like

- guessing a CCK; or
- brute forcing a CCK; or
- reconstructing a CCK based on accessible information.

It is therefore essential that the CCK generation mechanism will generate CCKs with sufficient security strength. A robust CCK generation mechanism relies on a secure RNG providing random numbers with sufficient entropy. It is a complex task to create a securely robust CCK generation mechanism and the underlying RNG. It is highly recommended to follow well recognized standards for this purpose.

NOTE 1 There are various well-recognised standards for key generation mechanisms. For instance, recognized best practices for Random Number Generators are NIST SP800-90A[10], NIST SP800-90B[11], NIST SP800-90C[12], BSI AIS20 [37], BSI AIS31[18], ISO/IEC 18031 [38].

NOTE 2 Examples for well recognised best practices for key derivation are for instance described at SOG-IS Crypto Evaluation Scheme Agreed Cryptographic Mechanisms [22]. Alternatives are available here: ISO/IEC 11770 [26], NIST SP 800-108r1[13], NIST SP 800-132[15].

NOTE 3 Key generation methods can be determined based on state-of-the-art cryptography as specified in the Agreed Cryptographic Mechanisms published by ENISA.

7.12.2.4 Assessment

7.12.2.4.1 Assessment objective

The assessment addresses the requirement CRY-2.

7.12.2.4.2 Required information

For all of the security assets and functions described in the Architectural Description (as defined by PT1) protected by cryptography, including for each cryptography used for cryptographic protection:

- A description of the cryptography used for cryptographic protection, including:
 - description of each cryptographic asset generation process; and
 - evidence to justify that the cryptography generation process is best practice for the cryptographic protection goals

NOTE 1 The documentation of a cryptographic protection goal includes the security objectives provided by cryptography.

NOTE 2 Cryptography used for cryptographic protection can amongst others include cryptographic schemes, algorithms, constructors and primes.

NOTE 3 Evidence to justify that the cryptography is best practice for the cryptographic protection goals can be based a reference catalogues, e.g., SOGIS Agreed Cryptographic Mechanisms (<https://www.sogis.eu>) [24], or other evidence, e.g., by crypto analysis.

7.12.2.4.3 Conceptual assessment

7.12.2.4.3.1 Assessment purpose

The purpose of this assessment case is the conceptual assessment whether all confidential cryptographic key generation mechanisms listed are implemented as required per CCK-2.

7.12.2.4.3.2 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- for each cryptographic cipher identified, the cipher generation method is determined to meet the requirement of CRY-2.

The verdict FAIL for the assessment case is assigned if:

- for any cryptographic cipher identified, the cipher generation method is determined to not to meet the requirement of CRY-2.

7.12.2.4.4 Functional sufficiency assessment

7.12.2.4.4.1 Assessment purpose

The purpose of this assessment case is the functional assessment whether the cryptography generation method in the Architectural Description [PT1] has been implemented as it has been described.

7.12.2.4.4.2 Assignment of verdict

The verdict of PASS for the assessment case is assigned, if cryptographic generation method has been implemented as documented in the Architectural Description.

The verdict of FAIL for the assessment case is assigned, if cryptographic generation method has not been implemented as documented in the Architectural Description.

7.12.3 [CCK-3] Preventing static default values for preinstalled CCKs (EN 18031)

7.12.3.1 Requirement

Preinstalled confidential cryptographic keys shall be practically unique per product.

7.12.3.2 Rationale

Product can use cryptography and therefore CCKs to protect the assets on the product. The CCKs are sometimes predefined, e.g. in the manufacturing process. CCKs used for the above-mentioned purpose need to be appropriate to prevent successful attacks based on CCKs with insufficient strength, especially when preinstalled.

The aim of this requirement is to prevent the reuse of identical or predictable preinstalled confidential cryptographic keys across multiple product instances by ensuring that such keys are practically unique per product instance.

This requirement is necessary to limit the impact of a cryptographic key compromise to a single product instance, as the reuse of identical or predictable preinstalled confidential cryptographic keys across multiple products could enable large-scale compromise of protected assets.

NOTE This requirement is necessary to meet the essential cybersecurity requirements (e) and (f) of Regulation (EU) 2024/2847. It is necessary to cover the <threat_name> (TBD) and to meet the corresponding security objective **SO.SecureProvisioning** as described in the PT2 TR.

It might also help to meet other essential cybersecurity requirements of Regulation (EU) 2024/2847 where cryptographic protection mechanisms are applied.

7.12.3.3 Guidance

CCKs can be preinstalled on the product during manufacturing. Preinstalled CCKs that are unique per product instance and resist brute force attacks can mitigate cyber security risk associated with the specific use of the CCK.

Unique relates to not systematically reused or deducible for another product and cannot be easily derived from product properties (e.g., manufacturer name, model name or Media Access Control (MAC) address). Established random generator can be used to generate practically unique cryptographic keys.

In some manufacturing or integration scenarios, common or non-unique cryptographic keys may be temporarily present on the product for purposes such as testing, provisioning, or initial setup.

Such keys are not considered preinstalled confidential cryptographic keys for the purposes of this requirement, provided that they are replaced, removed, or rendered unusable before the product is placed on the market or enters its intended operational state.

The requirement applies to confidential cryptographic keys that remain present and active in the product's operational configuration and are used to protect assets during normal operation. Keys intended solely for manufacturing, test, or provisioning phases are relevant only insofar as their lifecycle management ensures they do not persist in the final product configuration.

7.12.3.4 Assessment

7.12.3.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.12.3.4.2 Conceptual assessment

The purpose of this assessment case is the conceptual assessment whether preinstalled confidential cryptographic keys comply with the requirements defined in CCK-3.

7.12.3.4.2.1 Assessment purpose

7.12.3.4.2.2 Assignment of verdict

7.12.3.4.3 Functional sufficiency assessment

7.12.3.4.3.1 Assessment purpose

7.12.3.4.3.2 Assignment of verdict

7.13 [GEC] General Equipment Capabilities

7.13.1 [GEC-1] Up-to-date software and hardware without known exploitable vulnerabilities (EN 18031 - Title modified - publicly)

7.13.1.1 Requirement

[GEC-1-RQ-01] The product shall have no insufficiently mitigated known exploitable vulnerabilities.

7.13.1.2 Rationale

Products can consist of hardware and software provided by different providers and the manufacturer might have insufficient visibility into the security practices of these providers.

It is essential that the manufacturer can identify known exploitable vulnerabilities in the hardware and in the software, both commercial and open-source software, used in the product and can handle these vulnerabilities.

NOTE 1 It is important to note that acceptable condition include vulnerabilities:

- that cannot be exploited in the specific conditions of the product; or
- that have been mitigated to an acceptable residual risk; or
- that have been accepted on a risk basis.

NOTE 2 **PROPOSAL FROM ROBERT :**

Products can consist of hardware and software provided by different providers and the manufacturer might have insufficient visibility into the security practices of these providers.

It is essential that the manufacturer can identify known exploitable vulnerabilities in the hardware and in the software, both commercial and open-source software, used in the product and can handle these vulnerabilities **according to a vulnerability handling process like [Error! Reference source not found.](#)**

The aim of this requirement is to ensure that the product has no known exploitable vulnerabilities prior to placing it on the market. This requirement is necessary to ensure the security of the product, as the presence of known exploitable vulnerabilities can pose significant risk.

7.13.1.3 Guidance

To facilitate software vulnerability monitoring, the manufacturer of the equipment keeps technical documentation of the software of the equipment, including both open-source software and commercial off the shelf components. Likewise, technical documentation of hardware can assist in the identification of the hardware vulnerabilities.

To identify the publicly known exploitable vulnerabilities in the hardware and software of the equipment, the manufacturer consults a public vulnerability database (e.g. NIST National Vulnerabilities Database <https://nvd.nist.gov/> and existing National European Vulnerabilities Databases).

Different factors the manufacturer considers when assessing the known exploitable vulnerabilities, include, but are not limited to:

- attack surface of the product and vectors/paths by which an attacker can gain access to the product to exploit the vulnerability;
- the evidence that the vulnerability has been actively exploited or it already has documented proof-of-concept or code exploits;
- the security capabilities and mechanisms implemented in the product which can mitigate the exploitation of the vulnerability;
- the “intended product functionality”;
- the product’s “intended operational environment of use” including the threat environment and the security capabilities and additional countermeasures provided by the environment which can mitigate or remediate the exploitation of the vulnerability.

NOTE **PROPOSAL FROM ROBERT :**

To prepare a risk assessment, as described in (PT1 reference), to evaluate the product risks for the determination of mitigating controls.

Manufacturers need to take steps to become aware of vulnerabilities in the product or its dependencies, especially exploitable vulnerabilities:

- Based on [Error! Reference source not found.](#), maintain a well-known public point of contact to facilitate vulnerability and incident reporting.
- Based on [Error! Reference source not found.](#), identify vulnerabilities in the product and its components by reviewing publicly available vulnerability databases and other sources, and aided by the product's software bill of materials and/or software composition analysis.
- Regularly test and review of the security of the product, based upon [Error! Reference source not found.](#), for the purpose of identifying vulnerabilities.
- Identify any missing controls that lead to a vulnerability in the products, as described in [Error! Reference source not found.](#).

Known exploitable vulnerabilities are those that:

- can be exploited under practical operating conditions of the product; and
- can be effectively used by an adversary; and
- have known and available exploitation techniques

The different factors that the manufacturer needs to consider when assessing known exploitable vulnerabilities, include, but are not limited to:

- attack surface of the product and vectors/paths by which an attacker can gain access to the product to exploit the vulnerability;
- the evidence that the vulnerability has been actively exploited or it already has documented proof-of-concept or code exploits;
- the security capabilities and mechanisms implemented in the product which can mitigate the exploitation of the vulnerability;
- the “intended equipment functionality”;
- the equipment’s “intended operational environment of use” including the threat environment and the security capabilities and additional countermeasures provided by the environment which can mitigate or remediate the exploitation of the vulnerability.

For each identified vulnerability, the manufacturer needs to determine whether a publicly available exploit exists by checking authoritative advisories such as, publicly available vulnerability databases (e.g. National European Vulnerability Database) or NIST National Vulnerabilities Database <https://nvd.nist.gov/>), exploit repositories (e.g. Exploit-DB, Metasploit), or open-source code platforms (e.g. GitHub). The presence of working code, or step-by-step instructions, to enact the exploitation constitutes a known and available exploitation technique.

Vulnerabilities assessed as exploitable need to be addressed and remediated, prior to the product being made available on the market.

Based on [Error! Reference source not found.](#), the security test plan needs to include final security tests against publicly available vulnerability databases prior making the product available on the market to ensure that there are no insufficiently mitigated known exploitable vulnerabilities and the final SBOM needs to be created.

Known exploitable vulnerabilities that occur after making the product available on the market are subject to vulnerability handling in [Error! Reference source not found.](#)

7.13.1.4 Assessment criteria

7.13.1.4.1 Assessment objective

The assessment addresses the requirement GEC-1.

7.13.1.4.2 Implementation categories

Not applicable.

7.13.1.4.3 Required information

[E.Info.GEC-1.Asset]: Description of each asset.

[E.Info.GEC-1.SoftwareDocumentation]: Description of the software of the product, including their versions, that affect the assets documented in [E.Info.GEC-1.Asset].

[E.Info.GEC-1.HardwareDocumentation]: Description of the hardware of the product that affect the assets documented in [E.Info.GEC-1.Asset].

[E.Info.GEC-1.ListOfVulnerabilities]: Description of all known exploitable vulnerabilities in the hardware and software that affect the assets documented in [E.Info.GEC-1.Asset]. The document includes also the source of the vulnerabilities' information. Further a justification is given for each vulnerability that affects assets about the remediation, mitigation and non-exploitation of the listed hardware or software publicly exploitable vulnerabilities including:

- (if the vulnerability is remediated) [E.Info.GEC-1.ListOfVulnerabilities.Remediated]: The measures implemented to remediate the vulnerability; and
- (if the vulnerability cannot be exploited in the specific conditions of the product) [E.Info.GEC-1.ListOfVulnerabilities.SpecificCondition]: The description of specific conditions in which the vulnerability cannot be exploited ; and
- (if the vulnerability is mitigated) [E.Info.GEC-1.ListOfVulnerabilities.Mitigated]: The description of the measures for the mitigation; and
- (if the vulnerability is accepted) [E.Info.GEC-1.ListOfVulnerabilities.Accepted]: The description of the acceptance of the vulnerability on a risk basis.

[E.Info.DT.GEC-1]: Description of the selected path through the decision tree in **Figure 1**. for each software and hardware documented in [E.Info.GEC-1.SoftwareDocumentation] and [E.Info.GEC-1.HardwareDocumentation] where known exploitable vulnerabilities exist.

[E.Just.DT.GEC-1]: Justification for the selected path through the decision tree documented in [E.Info.DT.GEC-1] with the following properties:

- the justification for the decision [DT.GEC-1.DN-1] is based on [E.Info.GEC-1.ListOfVulnerabilities],
- (if a decision from [DT.GEC-1.DN-2] results in "NOT APPLICABLE") the justification is based on [E.Info.GEC-1.ListOfVulnerabilities] and [E.Info.GEC-1.ListOfVulnerabilities.Remediated],

- (if a decision from [DT.GEC-1.DN-3] results in “NOT APPLICABLE”) the justification is based on [E.Info.GEC-1.ListOfVulnerabilities.SpecificCondition],
- (if a decision from [DT.GEC-1.DN-4] results in “NOT APPLICABLE”) the justification is based on [E.Info.GEC-1.ListOfVulnerabilities.Mitgated], and
- the justification for the decision [DT.GEC-1.DN-5] is based on [E.Info.GEC-1.ListOfVulnerabilities.Accepted].

7.13.1.4.4 Conceptual assessment

7.13.1.4.4.1 Assessment purpose

The purpose of this assessment case is the conceptual assessment whether the hardware or software publicly known exploitable vulnerabilities present in the hardware and software of the product under test, in factory default state, are not able to affect assets, if exploited as required per GEC-1.

7.13.1.4.4.2 Preconditions

None.

7.13.1.4.4.3 Assessment units

NOTE For rendering you can use: <https://www.planttext.com/>

```
@startuml
skinparam dpi 300
skinparam defaultFontName Utopia
skinparam defaultFontSize 11
:Product;
:For each software\nand hardware;
if (<b>DT.GEC-1.DN-1</b>\nDoes the software and/or the \nhardware contain\nknown
exploitable\nvulnerabilities? ) then (No)
    #lightgreen :<b>PASS</b>\nHardware and/or software \ndoes not contain \n known
exploitable \nvulnerabilities;
    detach;
else (Yes)
    :For each hardware's and/or \nsoftware's known \nexplotable vulnerability;
    if (<b>DT.GEC-1.DN-2</b>\nDoes the vulnerability\naffect assets?) then (No)
        #application :<b>NOT APPLICABLE</b>\nVulnerability does not\naffect assets;
        detach;
    else (Yes)
        if (<b>DT.GEC-1.DN-3</b>\nIs the vulnerability exploitable\nin the specific
conditions of\nthe product?) then (No)
            #application :<b>NOT APLLICABLE</b>\nVulnerability is not\nexploitable;
            detach;
        else (Yes)
            if (<b>DT.GEC-1.DN-4</b>\nHas the vulnerability \nbeen mitigated to an
acceptable residual risk?) then (Yes)
                #application :<b>NOT APPLICABLE</b>\nVulnerability has \nbeen mitigated;
                detach;
            else (No)
                if (<b> DT.GEC-1.DN-5</b>\nHas the vulnerability \nbeen accepted?) then
(Yes)
                    #application :<b>NOT APPLICABLE</b>\nVulnerability has \nbeen accepted;
                    detach;
                else (No)
```

```

#pink :<b>FAIL</b>\nVulnerability affects assets, is exploitable \nand
not mitigated;
    detach;
    endif
    endif
    endif
    endif
@enduml

```

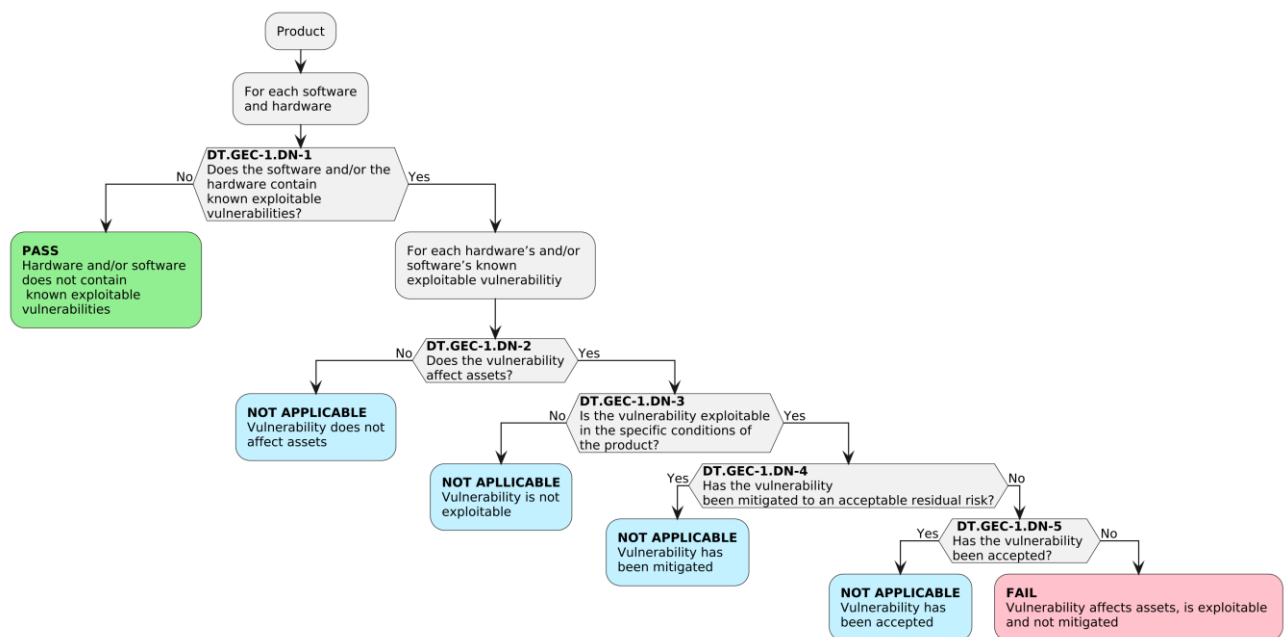


Figure 1 — Decision tree for requirement GEC-1

For each software in [E.Info.GEC-1.SoftwareDocumentation] and hardware documented in [E.Info.GEC-1.HardwareDocumentation], check whether the path through the decision tree documented in [E.Info.DT.GEC-1] ends with “NOT APPLICABLE” or “PASS”.

For each path through the decision tree documented in [E.Info.DT.GEC-1], examine its justification documented in [E.Just.DT.GEC-1].

7.13.1.4.4.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- at least one path through the decision tree documented in [E.Info.DT.GEC-1] ends with “PASS”; and
- no path through the decision tree documented in [E.Info.DT.GEC-1] ends with “FAIL”; and
- the information provided in [E.Just.DT.GEC-1] are correct justifications for all paths through the decision tree documented in [E.Info.DT.GEC-1].

The verdict FAIL for the assessment case is assigned if:

- a path through the decision tree documented in [E.Info.DT.GEC-1] ends with “FAIL”; or

- a justification provided in [E.Just.DT.GEC-1] is not correct or missing for a path through the decision tree documented in [E.Info.DT.GEC-1].

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

7.13.1.4.5 Functional completeness assessment

7.13.1.4.5.1 Assessment purpose

The purpose of this test case is the functional assessment of the product under test to verify the completeness of the documentation: that the vulnerabilities present in the product which affect assets are only those listed in [E.Info.GEC-1.ListOfVulnerabilities].

7.13.1.4.5.2 Preconditions

The product is in an operational and factory default state.

The date for the source of the vulnerabilities to be used in the assessment of the list of known exploitable vulnerabilities is recent.

7.13.1.4.5.3 Assessment units

Using up-to-date evaluation methods, functionally assess whether there are known hardware vulnerabilities that affect the security assets and the network assets, which are not listed in [E.Info.GEC-1.ListOfVulnerabilities].

Using up-to-date evaluation methods, functionally assess whether there are known software vulnerabilities that affect the security assets and the network assets, which are not listed in [E.Info.GEC-1.ListOfVulnerabilities].

NOTE Various software tools and measuring devices are available to automatically search for software and hardware vulnerabilities.

7.13.1.4.5.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if all found known software and hardware vulnerabilities that affect the security assets and the network assets are documented in [E.Info.GEC-1.ListOfVulnerabilities].

The verdict FAIL for the assessment case is assigned if a known software or hardware vulnerability that affects a security asset or a network asset is not documented in [E.Info.GEC-1.ListOfVulnerabilities].

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

7.13.1.4.6 Functional sufficiency assessment

7.13.1.4.6.1 Assessment purpose

The purpose of this test case is the functional assessment if the vulnerabilities present in the equipment which are listed in [E.Info.GEC-1.ListOfVulnerabilities] are not able to affect asset, if exploited.

7.13.1.4.6.2 Preconditions

The product is in an operational state.

The date for the source of the vulnerabilities to be used in the assessment of the list of known exploitable vulnerabilities is recent.

7.13.1.4.6.3 Assessment units

Functionally assess whether the measures described in [E.Info.GEC-1.ListOfVulnerabilities] are implemented considering also the specific conditions for the exploitability defined in [E.Info.GEC-1.ListOfVulnerabilities] to ensure that the vulnerabilities are not able to affect assets, if exploited.

NOTE For a lot of vulnerabilities Pentest tools are available to verify their exploitability.

7.13.1.4.6.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if there is no evidence that measures to ensure that vulnerabilities are not able to affect assets, if exploited, have not been implemented as described in [E.Info.GEC-1.ListOfVulnerabilities] considering also the specific conditions for the exploitability defined in [E.Info.GEC-1.ListOfVulnerabilities].

The verdict FAIL is assigned if there is evidence that measures to ensure that vulnerabilities are not able to affect assets, if exploited, have not been implemented as described in [E.Info.GEC-1.ListOfVulnerabilities] considering also the specific conditions for the exploitability defined in [E.Info.GEC-1.ListOfVulnerabilities].

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

7.13.2 [GEC-2] Limit exposure of services via related network interfaces (EN 18031)

7.13.2.1 Requirement

[GEC-2-RQ-01] In factory default state the product shall only expose:

- network interfaces; and
- services via network interfaces

affecting assets of the product which are necessary for equipment setup or for basic operation of the product.

NOTE The change proposed by Alessio and Riccardo

[GEC-2-RQ-01] In factory default state the product shall only expose interfaces affecting security assets which are necessary for product setup or basic operation.

Doubts Angelo: How this overlap to GEC-5?

7.13.2.2 Rationale

An important factor for reducing the potential risk that the network resource of the product becomes compromised for instance to harm the network, are exposed services. Therefore, these

exposed services need to be limited to those that are necessary for product setup and to operate the product in the intended operational environment of use.

NOTE 1 The change proposed by Alessio and Riccardo

The exposure of interfaces that affect security assets represents one of the primary entry points for attackers and therefore directly influences the overall attack surface of the product.

The aim of this requirement is to ensure that, in the factory default state, the product exposes only those interfaces that are strictly necessary for initial setup or basic operation, thereby reducing the likelihood of unauthorised access, misuse, or exploitation of security-relevant assets.

This requirement is necessary because interfaces that are enabled and accessible by default may be targeted before the product is properly configured or hardened by the user or integrator. Limiting such exposure in the factory default state reduces the attack surface at the moment the product is placed on the market.

NOTE 2 **NOTE - this can be removed in the future as already translated in the SECTION 5.**

This requirement supports the essential cybersecurity requirement (b) secure by default configuration of Regulation (EU) 2024/2847. It is necessary to cover the Threat.UnsecureDefaultConfigExploitation and to meet the corresponding security objective **SO.SecureDefaultConfiguration** as described in **PT2**.

7.13.2.3 Guidance

The configuration of the product can vary depending on the purpose of the product.

Generally, a differentiation is to be made between two types of products:

- Multipurpose product, e.g., smartphones, laptops: Offered services and functionality of multipurpose product are only under the control of the manufacturer until the equipment is placed on the market; and
- Product with a controlled fixed functionality, e.g., sensors, routers: Offered services and functionality of the product are embedded in an equipment-specific software which is provided by the manufacturer.

In case of product with a controlled fixed functionality only network interfaces or services (via network interfaces) are allowed in factory default state to be exposed which are essential to setup or use this functionality.

A multipurpose product has no specific intended use but is typically delivered by the manufacturer with a defined set of pre-installed applications. Further, the product provides an operational system for the following typical use cases in the factory default state:

- Manage/control the hardware of the product,
- Usage of the pre-installed applications,
- Installation of additional applications,
- Installation of software update.

These use case define the permitted scope for the exposed network interfaces and services (via network interfaces).

Affecting assets means that if the network interface or service (via network interfaces) is compromised it can have an impact on the security of the product.

NOTE The change proposed by Alessio and Riccardo - for all the section

The requirement concerns the exposure of interfaces as delivered in the factory default configuration.

In this context, exposure refers to interfaces that are enabled and accessible in a way that may affect security assets.

7.13.2.4 Assessment

7.13.2.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.2.4.2 Conceptual assessment

7.13.2.4.2.1 Assessment purpose

7.13.2.4.2.2 Assignment of verdict

7.13.2.4.3 Functional sufficiency assessment

7.13.2.4.3.1 Assessment purpose

7.13.2.4.3.2 Assignment of verdict

7.13.3 [GEC-3] Configuration of optional services and the related exposed network interfaces (EN 18031)

7.13.3.1 Requirement

Optional network interfaces or optional services exposed via network interfaces affecting assets, which are part of the factory default state shall have the option for an authorized user to enable and disable the network interface or service.

7.13.3.2 Rationale

This will reduce the attack surface related to network interfaces and to the services exposed via these.

NOTE 1 The change proposed by Alessio and Riccardo

The exposure of interfaces that affect security assets represents one of the primary entry points for attackers and therefore directly influences the overall attack surface of the product.

The aim of this requirement is to ensure that, in the factory default state, the product exposes only those interfaces that are strictly necessary for initial setup or basic operation, thereby reducing the likelihood of unauthorised access, misuse, or exploitation of security-relevant assets.

This requirement is necessary because interfaces that are enabled and accessible by default may be targeted before the product is properly configured or hardened by the user or integrator. Limiting such exposure in the factory default state reduces the attack surface at the moment the product is placed on the market.

NOTE 2 This requirement supports the essential cybersecurity requirement (b) secure by default configuration of Regulation (EU) 2024/2847. It is necessary to cover the Threat.UnsecureDefaultConfigExploitation and to meet the corresponding security objective **SO.SecureDefaultConfiguration** as described in PT2 TR.

7.13.3.3 Guidance

The product provides a functionality for an authorized user to configure (enable/disable) the exposed optional services and the related network interfaces which are part the factory default state.

The configuration of network related services ought to be protected according to access control mechanism (ACM) and authentication mechanism (AUM).

7.13.3.4 Assessment

7.13.3.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.3.4.2 Conceptual assessment

7.13.3.4.2.1 Assessment purpose

7.13.3.4.2.2 Assignment of verdict

7.13.3.4.3 Functional sufficiency assessment

7.13.3.4.3.1 Assessment purpose

7.13.3.4.3.2 Assignment of verdict

7.13.4 [GEC-4] Documentation of exposed network interfaces and exposed services via network interfaces (EN 18031)

7.13.4.1 Requirement

The products' user documentation shall contain a description of

- all exposed network interfaces; and
- all services exposed via network interfaces,

which are delivered as part of the factory default state.

NOTE The change proposed by Alessio and Riccardo

The product's user documentation shall contain a description of all interfaces which are delivered as part of the factory default state.

7.13.4.2 Rationale

The product itself and the surrounding network needs to be configured properly to assure the functionality of the product and to support the security of the network. Therefore, it is important to provide user information regarding the exposed network interfaces and exposed services (via network interfaces) and the intended operational environment of use.

NOTE 1 The change proposed by Alessio and Riccardo

User documentation describing the interfaces available in the factory default state enables correct configuration and secure operation of the product.

The aim of this requirement is to ensure that users and integrators are provided with clear and accurate information about all interfaces that are exposed in the factory default state, so that they can understand their purpose and potential impact on the protection of assets.

This requirement is necessary because undocumented or insufficiently described interfaces may be unintentionally left enabled, misconfigured, or exposed in operational environments, increasing the likelihood of unauthorised access, misuse, or exploitation.

NOTE 2 **NOTE - this can be removed in the future as already translated in the SECTION 5.**

This requirement supports the essential cybersecurity requirement (b) secure by default configuration of Regulation (EU) 2024/2847. It is necessary to cover the Threat.UnsecureDefaultConfigExploitation and to meet the corresponding security objective **SO.SecureDefaultConfiguration** as described in the PT2

7.13.4.3 Guidance

All network interfaces and exposed services (via network interfaces) in factory default state are to be listed in the documentation. For each service, its purpose could be provided as well. The aim is to provide transparency to the user about the connectivity of the equipment. Furthermore, the documentation serves to assess whether the commissioning of the equipment creates potential attack surfaces to the user's intended environment of use.

NOTE The change proposed by Alessio and Riccardo

This requirement concerns the documentation of interfaces that are exposed and available in the factory default state.

The description typically includes the type and purpose of each interface and its relevance for product setup or basic operation.

7.13.4.4 Assessment

NOTE Insert abbreviated assessment process after PoC Draft release, unless convenient to add notes whilst drafting the requirement.

7.13.4.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.4.4.2 Conceptual assessment

7.13.4.4.2.1 Assessment purpose

7.13.4.4.2.2 Assignment of verdict

7.13.4.4.3 Functional sufficiency assessment

7.13.4.4.3.1 Assessment purpose

7.13.4.4.3.2 Assignment of verdict

7.13.5 [GEC-5] No unnecessary external interfaces (EN 18031)

7.13.5.1 Requirement

The product shall expose only physical external interfaces that are necessary for its intended functionality.

NOTE The change proposed by Alessio and Riccardo

The product shall expose only external interfaces that are necessary for its intended purpose.

7.13.5.2 Rationale

Physical external interfaces need to be kept to the minimum in order to minimise the potential attack surface.

NOTE 1 The change proposed by Alessio and Riccardo

External interfaces can increase the attack surface of the product if unnecessarily exposed.

The aim of this requirement is to minimise the potential attack surface by limiting the exposure of external interfaces to those strictly necessary for the intended purpose of the product.

This requirement is necessary because attackers may use exposed interfaces to gain unauthorized access to the product and compromise its confidentiality, integrity or availability.

NOTE 2 This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (j) of Regulation 2024/2847. It is also necessary to cover the threat **Threat.UnnecessaryFunctionalityExploitation**, and to meet the corresponding security objective **SO.ReduceAttackSurface** as described in the PT2 TR.

7.13.5.3 Guidance

In cases where an unnecessary physical external interface is physically protected by its intended operational environment of use, this external interface is considered as not exposed by the product.

External interfaces that are disabled or blocked are considered as not exposed by the product as well.

Physical external interfaces might include external interfaces that are intentionally used for internal system communication as well as user interfaces and machine interfaces.

The intended functionality can cover multiple use-cases and the physical external interfaces exposed need to serve a purpose in at least one of the use-cases.

NOTE The change proposed by Alessio and Riccardo

In cases where an unnecessary external interface is physically protected by its intended operational environment of use, this interface is considered as not exposed by the product.

Interfaces that are disabled or blocked are considered as not exposed by the product as well.

External interfaces might include interfaces that are intentionally used for internal system communication as well as user interfaces and machine interfaces.

The intended functionality can cover multiple use-cases and the external interfaces exposed need to serve a purpose in at least one of the use-cases.

7.13.5.4 Assessment**7.13.5.4.1 Assessment objective**

The assessment addresses the requirement <Req #>.

7.13.5.4.2 Conceptual assessment**7.13.5.4.2.1 Assessment purpose**

7.13.5.4.2.2 Assignment of verdict

7.13.5.4.3 Functional sufficiency assessment

7.13.5.4.3.1 Assessment purpose

7.13.5.4.3.2 Assignment of verdict

7.13.6 [GEC-6] Input validation (EN 18031)

7.13.6.1 Requirement

The product shall validate input received via external interfaces if the input has potential impact on assets.

NOTE The change proposed by Alessio and Riccardo

The product shall validate input received via external interfaces if such input has the potential to impact the assets **of the product**.

7.13.6.2 Rationale

The product needs to validate any input that has the potential to impact its assets, in order to mitigate potential misuse, corruption, or unauthorized extraction of data from those assets.

Input validation is necessary to validate for instance the syntax, length and content of any input data that is provided as expected input and has the properties that are required to process the data correctly.

Improper input validation is regarded as one of the most common and dangerous software weaknesses which also contributes to several other software weaknesses like out-of-bounds write, and improper neutralization which can lead to various injection vulnerabilities (e.g., SQL injection, OS command injection and path traversal).

Especially data from potentially untrusted sources like any input received via network interfaces, need to be subject to input validation by checking the input for both syntax and semantics correctness. These checks ought to be done as early as possible when processing any input to avoid propagating invalid and perhaps even malicious input.

NOTE The change proposed by Alessio and Riccardo

The product needs to validate any input that has the potential to impact its assets, in order to mitigate potential misuse, corruption, or unauthorized extraction of data from those assets.

Input validation is necessary to ensure, for example, that the syntax, length and content of input data conform to expected formats and has the properties required for correct processing.

Improper input validation is considered one of the most common and dangerous software weaknesses. It also contributes to other critical vulnerabilities, such as out-of-bounds write, and improper input neutralization, which can lead to various injection vulnerabilities (e.g., SQL injection, OS command injection and path traversal).

In particular, input originating from potentially untrusted sources, such as data received via network interfaces, must be subject to input validation that checks both syntax and semantics correctness. **These checks should be performed as early as possible during input processing to prevent the propagation of invalid or malicious data.**

7.13.6.3 Guidance

Improper input validation is one of the root causes for many security vulnerabilities, input can only be successfully processed when it has been established that the input is valid by checking the syntax and semantics of the input, both on the raw data and metadata.

Syntax validation is checking that the input is delivered in the correct structure, for instance:

- the format of a date entry (e.g., dd-mm-yyyy or mm-dd-yyyy);
- the use of a decimal point or comma in a numeric input;
- the length of input;
- correct headers and structures for various file types (e.g., validate a .ZIP, .BMP or .JPEG file structure);
- a valid json, xml or html file.

Semantics validation is checking that the input is delivered with correct values, for instance:

- a value that is outside the expected range (e.g., a number that is too small or too large, a birthday in the future);
- special characters which are not allowed in a text input, e.g., special escape characters used for SQL injection;
- incorrect data size and offset values in a structure (e.g., an incorrect size might cause a buffer overrun when data is copied without checks, or a negative offset might copy incorrect data from the stack);
- inclusive listing (also known as “allow listing”) is a method which only permits defined input (e.g., specified values or expressions), everything else will be rejected as input.

Using parsers and/or regular expressions are methods to validate for instance text input. A developer could also consider other techniques to ensure an input can be successfully processed such as filtering and encoding.

Further guidance to be considered:

- Common Weakness Enumeration: Improper input validation (CWE-20), encoding/escaping (CWE-116), Improper Neutralization of Special Elements (CWE-138) and filtering (CWE-790); <https://cwe.mitre.org/data/index.html>
- Open Web Application Security Project (OWASP) Input Validation Cheat Sheet – https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

- IEC EN 62443-4-2[2] CR 3.5 (Input validation) and
- ETSI EN 303 645[5] 5.13 (Validate input data).

7.13.6.4 Assessment

7.13.6.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.6.4.2 Conceptual assessment

7.13.6.4.2.1 Assessment purpose

7.13.6.4.2.2 Assignment of verdict

7.13.6.4.3 Functional sufficiency assessment

7.13.6.4.3.1 Assessment purpose

7.13.6.4.3.2 Assignment of verdict

7.13.7 [GEC-7] Documentation of external sensing capabilities (EN 18031)

7.13.7.1 Requirement

All external sensing capabilities of the product that are related to the user's or subscriber's privacy shall be documented for the user.

NOTE The change proposed by Alessio and Riccardo

Information on all external sensing capabilities of the product that are related to the user's or subscriber's privacy shall be provided to the user.

The information shall include, at minimum:

- a description of each external sensing capability present in the product;
- the type of data that can be captured or inferred by each sensing capability;
- the conditions under which the sensing capability is active or can be activated;

- the means available to the user to limit or disable the sensing capability and to reduce privacy-related risks.

7.13.7.2 Rationale

External sensing functions could be misused to spy out the user of the product. If the user is not aware of the sensing capabilities of the product it may unintentionally be used in privacy related locations.

Documenting the external sensing capabilities makes users aware of what the product might technically expose about their privacy. With this awareness, users can adjust their use of the product to minimise the risk of their privacy being compromised.

NOTE The change proposed by Alessio and Riccardo

External sensing capabilities may expose information related to the user's or subscriber's privacy and, if misused or insufficiently understood, may lead to privacy or security risks.

If users are not aware of the presence and operation of such sensing capabilities, the product may be unintentionally used in privacy-sensitive environments or configurations. Providing clear and transparent information enables users to make informed decisions about the use, placement, and configuration of the product and to take appropriate measures to reduce privacy-related risks.

7.13.7.3 Guidance

The manufacturer needs to be clear and transparent to the user what can be captured with the sensors present in the equipment. Based on this information the user could, e.g. cover the camera with a sticker.

Furthermore, information concerning the sensing capabilities of the equipment during the initial configuration process may be given.

An example for an external sensing capability is a microphone or a camera

NOTE The change proposed by Alessio and Riccardo

Information on external sensing capabilities should be presented in a clear and understandable manner, taking into account the intended users of the product.

The information may be provided through documentation, user interfaces, onboarding procedures, or other appropriate means. Where applicable, information may include practical examples of how users can limit exposure, such as disabling specific sensing functions, restricting their activation, or applying physical or logical measures to prevent unintended data capture.

Examples of external sensing capabilities include, but are not limited to, microphones, cameras, and other sensors capable of capturing or inferring information about individuals or their environment.

7.13.7.4 Assessment

7.13.7.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.7.4.2 Conceptual assessment

7.13.7.4.2.1 Assessment purpose

7.13.7.4.2.2 Assignment of verdict

7.13.7.4.3 Functional sufficiency assessment

7.13.7.4.3.1 Assessment purpose

7.13.7.4.3.2 Assignment of verdict

7.13.8 [GEC-8] Product Integrity (EN 18031)

7.13.8.1 Requirement

Product, which processes **sensitive data**, shall cryptographically verify the boot process integrity and authenticity of its software (provided by the manufacturer or its sub-contractor), using a root of trust which is immutable or, mutable under cryptographically authenticated authorization, for each part of its software which processes assets.

7.13.8.2 Rationale

Boot integrity validation is a useful feature in many products to ensure that the software can start up in a known verified state. It also detects a corrupted or modified software by an attacker during the startup, restarting or resuming after standby (or hibernate) of the product's software. Attacks of this type can be used to alter the software operation with a view to accessing or altering the financial assets.

In conjunction with the supervisor function(s) to restart the product's processor(s) and the boot integrity function, this provides a robust method of triggering the restoration of authorised software.

Alternatively, at least an entity can be informed, that the software is not authenticated, and the product can be considered as corrupted, and thus it cannot be trusted.

7.13.8.3 Guidance

There are a variety of ways of implementing a root of trust, typically using a hardware-based root of trust.

The critical property of such a root of trust being that of its immutability or only being mutable under cryptographically authenticated authorization.

Such boot integrity checks are independent of each other. For example, where there is more than one processor in a piece of product and where multiple processors process **sensitive data**, all

these processors will need to validate the integrity of their boot processes before carrying out any functional interactions.

When several parts of the software used to process the **sensitive assets**, typically, when several software (on the same processor) are used, the authorized software can verify the integrity and authenticity of the software that is started/launched. This is needed to create a Chain of Trust that processes the financial assets and security assets.

7.13.8.4 Assessment

7.13.8.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.8.4.2 Conceptual assessment

7.13.8.4.2.1 Assessment purpose

7.13.8.4.2.2 Assignment of verdict

7.13.8.4.3 Functional sufficiency assessment

7.13.8.4.3.1 Assessment purpose

7.13.8.4.3.2 Assignment of verdict

7.13.9 [GEC-9] Secure startup configuration (NEW)

7.13.9.1 Requirement

The product shall provide a secure configuration during the initial commissioning process and prevent exposure of the assets of the product before the configuration is completed and the product transitions to normal operation state.

Warning — Editor's note: align the TR SO.SecureStartupConfig may be not required. Refer to OP-001

7.13.9.2 Rationale

The initial commissioning process marks the transition from delivery to operational use. During this phase, the product may not yet have been configured with user-specific credentials, access

controls, or secure communication settings. If the product exposes assets or functionalities before this process is completed, it may be vulnerable to unauthorized access or misuse.

To reduce this risk, the product must ensure that assets and security-relevant functionality are not accessible until the initialization is successfully completed by an authorized user.

While **[GEC-2] Limit exposure of services via related network interfaces** ensures that only essential interfaces and services are exposed in the factory default state, and **[GEC-3] Configuration of optional services and the related exposed network interfaces** governs how optional services can be configured, this requirement focuses on the secure behavior of the product during the initialization process. It ensures that even temporarily exposed functionalities cannot be accessed until the system has been securely configured.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (b) of Regulation 2024/2847. It is also necessary to cover the threat Threat.UnsecureDefaultConfigExploitation, and to meet the corresponding security objective SO.SecureStartupConfig.

7.13.9.3 Guidance

[TBD]

7.13.9.4 Assessment

7.13.9.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.9.4.2 Conceptual assessment

7.13.9.4.2.1 Assessment purpose

7.13.9.4.2.2 Assignment of verdict

7.13.9.4.3 Functional sufficiency assessment

7.13.9.4.3.1 Assessment purpose

7.13.9.4.3.2 Assignment of verdict

7.13.10 [GEC-10] Factory Reset (NEW)

7.13.10.1 Requirement

The product shall provide a mechanism to restore its factory default state.

This mechanism shall:

- delete all user configurations and data;
- remove any installed software or modifications introduced after delivery,
- retain only deviations resulting from applied security updates.

NOTE Data stored in physically non-erasable memory elements (such as e-fuses or read-only memory) cannot be deleted by the reset mechanism. Information about such data and its security implications is typically provided in the product documentation.

Warning — Editor's note: clarify for remote data processing

7.13.10.2 Rationale

A factory reset mechanism is needed to ensure the product can always return to a trusted, known-secure state. This reduces cybersecurity and privacy risks when the product changes ownership, is reused, or needs recovery after compromise. Without a reset, insecure configurations, unauthorized modifications, or malicious software introduced during the product lifecycle may persist and remain exploitable. Preserving applied security updates during reset avoids re-exposing the product to known vulnerabilities.

NOTE This requirement is necessary to meet the essential cybersecurity requirement (b) of Regulation 2024/2847. It is also necessary to cover the threats **Threat.MissingResetFunctionalityConfigExploitation**, **Threat.MissingResetFunctionalityMalwareExploitation**, **Threat.MissingResetFunctionalityDataExtraction** and to meet the corresponding security objective SO. **FactoryReset**.

7.13.10.3 Guidance

The reset mechanism should reliably remove user data, credentials, and configurations to prevent information leakage during transfer or disposal. It should also eliminate unauthorized or malicious software introduced after delivery. Implementation can take different forms (e.g. hardware reset button, firmware function, or management interface option) but should be safeguarded against accidental or unauthorized triggering. Secure erasure techniques are recommended to prevent recovery of sensitive data.

7.13.10.4 Assessment

7.13.10.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.10.4.2 Conceptual assessment

7.13.10.4.2.1 Assessment purpose

7.13.10.4.2.2 Assignment of verdict

7.13.10.4.3 Functional sufficiency assessment

7.13.10.4.3.1 Assessment purpose

7.13.10.4.3.2 Assignment of verdict

7.13.11 [GEC-11] Exploit mitigation mechanisms (NEW)

7.13.11.1 Requirement

The product shall implement exploitation mitigation mechanisms to prevent unauthorized code execution, privilege escalation and uncontrolled propagation of compromise.

7.13.11.2 Rationale

Even when a product is successfully compromised, the impact of the incident can be significantly reduced through appropriate exploitation mitigation mechanisms. Without such measures, an attacker may escalate privileges, move laterally within the product, or gain access to assets beyond those initially exposed by the exploited vulnerability.

The aim of this requirement is to ensure that products are designed and implemented in a way that contains the effects of successful exploitation and prevents uncontrolled extension of attacker capabilities beyond the originally compromised component.

This requirement is necessary because vulnerabilities cannot be completely eliminated. Therefore, products shall incorporate architectural and protections that reduce the severity and scope of damage in the event of a successful attack, supporting the objective of limiting the overall impact of cybersecurity incidents.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (k) of Regulation 2024/2847. It is also necessary to cover the threats [Threat.ExploitationMitigationFailure] and to meet the corresponding security objective [SO.ReduceImpactOfIncident] as described in the [4]. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the [4].

7.13.11.3 Guidance

Exploitation mitigation aims to ensure that, even if a vulnerability is successfully exploited, the consequences remains limited and controlled. The objective is to prevent the attacker from extending their control, escalating privileges, or accessing components, interfaces, or data beyond those directly affected by the original vulnerability.

This can be achieved by designing the product so that:

- Containment and isolation are applied, for example through isolation or sandboxing of critical components or processes;
- Least privilege and resource minimization is enforced, by reducing the privileges, accessible memory regions, and data available to each function;

- Functionality restriction is in place, by limiting the functionality available to compromised components;
- Runtime protection and integrity enforcement are implemented, such as Control Flow Integrity (CFI) or pointer authentication / memory tagging.
- Memory protection mechanisms are applied, such as stack protection mechanisms or Address Space Layout Randomization (ASLR)
- Side channel mitigation measures are applied, such as Differential Power Analysis (DPA) countermeasures, electromagnetic (EM) shielding, tamper detection and constant-time implementation of cryptographic operations.

7.13.11.4 Assessment

7.13.11.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.11.4.2 Conceptual assessment

7.13.11.4.2.1 Assessment purpose

7.13.11.4.2.2 Assignment of verdict

7.13.11.4.3 Functional sufficiency assessment

7.13.11.4.3.1 Assessment purpose

7.13.11.4.3.2 Assignment of verdict

7.13.12 [GEC-12] No Unneeded Software Components (NEW)

7.13.12.1 Requirement

The product shall minimize its software components to those required for the declared intended functionality and operation. Where additional components or dependencies are included, then inclusion shall be justified as per the cybersecurity risk assessment.

7.13.12.2 Rationale

Including only software components that are necessary for the intended purpose of the product reduces unnecessary complexity and limits the potential attack surface. Unnecessary software components, such as unused libraries, debugging tools, interpreters or modules unrelated to the

declared functionality, may introduce additional vulnerabilities and increase the number of potential attack vectors. They may also introduce dependencies that require monitoring and patching without contributing to the product's intended operation.

The aim of this requirement is to minimise the attack surface and reduce the risk of exploitable vulnerabilities by ensuring that only software components essential for the intended purpose of the product are included.

This requirement is necessary because unnecessary or unused software components increase the likelihood of vulnerabilities being present and exploited, thereby compromising the confidentiality, integrity or availability of the product and its assets.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (j) of Regulation 2024/2847. It is also necessary to cover the threats [Threat.UnnecessaryFunctionalityExploitation] and to meet the corresponding security objective [SO.ReduceAttackSurface] as described in the [4]. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the [4].

7.13.12.3 Guidance

In applying this requirement, the focus is on the presence and inclusion of software components in relation to the declared intended functionality and operation of the product.

Software components that are not required to support the intended functionality of the product may include, for example, unused libraries, development or debugging tools, test software interfaces, interpreters, sample code, or optional modules unrelated to the declared functionality. The inclusion of such components may increase the attack surface and introduce additional dependencies that require vulnerability monitoring and maintenance without contributing to the product's operation.

Where additional software components are included for reasons such as platform reuse, optional or future functionality, third-party integration, or development efficiency, the associated cybersecurity considerations can be examined. This may include identifying the component, its purpose, its activation or exposure conditions, and its potential impact on the attack surface and vulnerability management activities.

For products that are intended to be integrated into other products or systems (e.g. chipsets, system-on-chips, modules or platforms provided for integration by an external manufacturer), the software delivered with the product may include development, integration, diagnostic or validation tools intended to support platform bring-up, system integration, testing or customization.

In such cases, the presence of these tools does not necessarily indicate that they are required for the final intended functionality of the integrated product. The cybersecurity relevance of such tools depends on their activation state, exposure through interfaces, and accessibility in the default and operational configurations.

Information provided to integrators may include documentation describing the purpose of such tools, their default configuration, and the conditions under which they are enabled, restricted or disabled. This supports informed integration decisions and allows assessment of whether such components contribute to the attack surface of the final product.

7.13.12.4 Assessment**7.13.12.4.1 Assessment objective**

The assessment addresses the requirement <Req #>.

7.13.12.4.2 Conceptual assessment**7.13.12.4.2.1 Assessment purpose****7.13.12.4.2.2 Assignment of verdict****7.13.12.4.3 Functional sufficiency assessment****7.13.12.4.3.1 Assessment purpose****7.13.12.4.3.2 Assignment of verdict****7.13.13 [GEC-13] Report on possible unauthorised access and corruption (NEW)****7.13.13.1 [GEC-13-2] Reporting on possible unauthorized access and on corruption (NEW)**

The product shall provide the capability to report on possible unauthorized access and on corruption to the appropriate entity.

7.13.13.2 [GEC-13-2] Actively reporting on possible unauthorized access and on corruption (NEW)

The product shall provide the capability to actively report on possible unauthorized access and on corruption by notifying the appropriate entity.

7.13.13.3 Rationale

The aim of these requirements is to provide the necessary visibility to identify potential breaches, investigate security incidents, and execute a timely response to mitigate damage from both – unauthorized access attempts and data/program/configuration corruptions.

Especially, for [GEC-13-2], the objective is to ensure transparency allowing the appropriate entity to consider further actions or updates. Notifying in a timely manner allows to make an informed decision to handle the security event appropriately.

These two requirements are necessary as a lack of reporting on such events leaves the system vulnerable to prolonged, undetected compromises or degradation, which can lead to severe data loss, manipulation, or system failure. The early detection of unauthorized access is a critical security function.

NOTE 1 An anomaly is an event or pattern of events that deviates from what is standard, normal or expected.

NOTE 2 These requirements are necessary to meet the essential cybersecurity requirement (d) and (f) of Regulation 2024/2847. They are also necessary to cover the threat Threat.NotReportedUnauthorizedAccess and Threat.TamperingUndetected, and to meet the corresponding security objective SO.AccessControlReport and SO.IntegrityReport as described in the PT2 TR. They might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.13.13.4Guidance

The goal is to create meaningful, actionable, and context-rich reports that support security operations for both possible unauthorized access and corruption.

Effective reporting is enabled by the product's generation and secure storage of relevant logs and events. Events considered indicative of possible unauthorized access include, but are not limited to:

- multiple failed login attempts for a valid user account
- logins from new or atypical geographic locations, IP addresses, subnets, or devices
- access occurring outside of standard business hours or at times inconsistent with a user's normal activity patterns
- a user successfully gaining or attempting to gain higher-level permissions than those assigned
- attempts to access or modify critical system files, security configurations, or sensitive data repositories by unauthorized users or at unusual times
- any creation of a new administrative account or modification of an existing one
- any attempt to use an account that has been disabled, suspended, or has been inactive for an extended period.

Events considered indicative of corruptions include, but are not limited to:

- checksum, hash, or CRC verification failures on stored, transmitted, or processed data, programs, or configuration,
- detection of unexpected modifications to firmware, configuration files, or relevant data
- redundant copy mismatch or backup validation failures

The reporting capability is designed to be flexible and user-friendly. The implementation for reporting these events can include one or more of the following mechanisms:

- recording security events in a chronological and tamper-evident log
- displaying alerts on a dedicated alarm panel or security dashboard
- transmitting notifications to a configured email address
- presenting an on-screen pop-up window to an active administrator

However, for active reporting it is not sufficient to only record security events or to provide logs. Active reporting requires that the product notifies about possible unauthorized access and corruptions to the appropriate entity, so that this entity becomes aware without a need to manually inspect logs.

The reports have to be made available to appropriate entities, i.e. to those user(s), machine(s), or manufacturer(s), that are intended to receive and act on such reports.

A notification sent or displayed by the notification mechanism may be a text message, vocal message, links or any other equivalent communication to the appropriate entity, the information on notification policy could be also provided in advance in user documentation.

Providing notification in timely manner depends on the capabilities and status of the product, where the meaning of “timely” varies depending on the importance of the change and product notification mechanism as well as other factors. For example, if the product is offline, it may not be able to provide notification to a remote user and the notification would be sent on a best effort basis.

The content of a notification needs to be in a precise, transparent, comprehensible and easily accessible form.

7.13.13.5 Assessment

7.13.13.5.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.13.13.5.2 Conceptual assessment

7.13.13.5.2.1 Assessment purpose

7.13.13.5.2.2 Assignment of verdict

7.13.13.5.3 Functional sufficiency assessment

7.13.13.5.3.1 Assessment purpose

7.13.13.5.3.2 Assignment of verdict

7.14 [CRY] Cryptography

7.14.1 [CRY-1] Best practice cryptography (EN 18031)

7.14.1.1 Requirement

The product shall use best practice for cryptography for the protection of the assets.

7.14.1.2 Rationale

Cryptography that is not strong enough for a use case, e.g., because it is not suitable or broken and used for the protection of assets poses a security risk to them. Using best practices or even more advanced, evidently suitable cryptography supports trust in the cryptographic protection of these assets.

If a cryptographic algorithm is cracked or cryptographic primitives are compromised, it may be necessary to update the product accordingly (see requirement SUM) in order to preserve the protection of the assets the cryptography protects. While there is no absolute guarantee that this does not happen to any cryptography that is considered as best practice, it is more likely that cryptography becomes unsuitable for a certain use case, when there is already evidence that such cryptography might become deprecated within the intended lifetime of the product.

However, e.g., if the product can itself communicate over the internet and contains a hardware based crypto accelerator, it might not be prepared to update cryptography. In these cases, it is important that there is no evidence that the cryptography will not be best practice within the intended lifetime.

NOTE This requirement is necessary to meet the essential cybersecurity requirements (e), (f) of Regulation 2024/2847. It is also necessary to cover the threats Threat.DataAtRestDisclosure, Threat.DataProcessedDataDisclosure, Threat.DataInTransitDisclosure, Threat.DataAtRestTampering, Threat.DataInTransitTampering, Threat.ProcessedDataTampering, Threat.TamperingUndetected as described in the PT2 TR and to meet the corresponding security objectives SO.DataStoredConfidentiality, SO.DataProcessedConfidentiality, SO.DataTransmittedConfidentiality, SO.DataTransmittedIntegrity, SO.DataProcessedIntegrity, SO.ComAuth, SO.IntegrityReport. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.14.1.3 Guidance

There is various security guidance that can be used to identify best practices for cryptography, see respective ISO/IEC standards, publicly available crypto catalogues provided by SDOs and publi authorities such as sogis.eu, “SOGIS agreed Cryptographic Mechanisms” [22], ETSI TS 119 312 Electronic Signatures and Infrastructures; Cryptographic Suites [25] and guidance provided by ENISA and national agencies as the NIST SP 800 series [7]- [17] and BSI TR-02102-1[19]

A commonly used cryptographic method for a certain use case, with the lack of evidence for a feasible attack with current readily available techniques, can be considered as best practice.

However, it is also possible to provide evidence, that new cryptography is suitable for a certain use case and can therefore be considered as best practice for cryptography.

Cryptography is often used for protecting the relevant security assets and network assets, for example:

- Authentication (see AUM),
- Secure update (see SUM),

- Secure storage (see SSM),
- Secure communication (see SCM),
- Confidential Cryptographic key Generation (see CCK-2).

Cryptographic protection might not be compliant with best practice cryptography if interoperability is required. Legacy mechanism, that are deployed on a large scale are considered to provide an acceptable short – term security and suffer from some security assurance limitations as compared with the identified best practice mechanism in the above referenced crypto- catalogues (see e.g., sogis.eu). For up-to date lists of legacy mechanism and their validity period given by a deprecation deadline, the crypto catalogues are updated on a regular short-term basis (e.g., annually).

If reviewed or evaluated implementations according to the best practice are publicly available, these may be preferable used to deliver network and security functionalities, particularly in the field of cryptography.

To maintain best practices for cryptography within the intended lifetime of the equipment concepts to consider are crypto agility additional to the capability of updating cryptography on the equipment i accordance to SUM to respond to new attacks and new technological developments.

Elements to observe for the preparation of updating cryptography are amongst others:

- cryptographic schemes, protocols, algorithms, constructors and primes,
- the form of sensitive security parameters being used, and
- specific SSPs, such as roots of trust.

For product that cannot have their cryptographic algorithms or primitives updated for example if the implementation or part uses a hardware-based root of trust, it is important that the intended lifetime of the product does not exceed the recommended usage lifetime of the cryptographic algorithms and primitives used by the product.

7.14.1.4 Assessment

7.14.1.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.14.1.4.2 Conceptual assessment

7.14.1.4.2.1 Assessment purpose

7.14.1.4.2.2 Assignment of verdict

7.14.1.4.3 Functional sufficiency assessment

7.14.1.4.3.1 Assessment purpose

7.14.1.4.3.2 Assignment of verdict

7.15 [DTM] Data minimization

NOTE Contributor's note: See also proposal from Samim in CEN-CLC-JTC 13-WG 9_Derivation of Requirements - Data minimisation.xlsx

7.15.1 [DTM-1] Data minimisation in relation to intended purpose (NEW)

7.15.1.1 Requirement

The product shall, for its intended purpose and reasonably foreseeable use and in consideration of reasonably foreseeable misuse, ensure that it processes only data, whether personal or non-personal, that are adequate, relevant and limited to what is necessary in relation to that intended purpose, by:

- a) restricting data processing to data elements that are necessary in relation to the intended purpose of the product;
- b) limiting the precision, frequency, volume or granularity of data processed, where processing data at a reduced level of precision, frequency, volume or granularity is sufficient to achieve the intended purpose of the product;
- c) preventing, through design or configuration, the accumulation or continued processing of data beyond what is necessary in relation to the intended purpose.

7.15.1.2 Rationale

Processing data, whether personal or non-personal, beyond what is necessary for the intended purpose of a product can increase cybersecurity risks by enlarging the attack surface, increasing the volume and sensitivity of data exposed in the event of a security incident, and extending the duration of exposure through unnecessary accumulation or continued processing. Limiting data processing to what is necessary, and to the minimum level of precision, frequency, volume, or granularity sufficient to achieve the intended purpose, contributes to reducing both the likelihood and the impact of cybersecurity incidents.

7.15.1.3 Guidance

In applying DTM-1, data processing should be assessed in relation to the intended purpose of the product with digital elements, as defined by the manufacturer, taking into account reasonably foreseeable use or misuse.

For the purposes of conformity with this requirement, consideration may be given to:

- whether each category of data processed has a clear and demonstrable link to the intended purpose of the product, including any functional, performance, accuracy, or reliability characteristics that form part of that purpose ;
- the scope and nature of the data, including the types of data processed, the level of detail or aggregation, and whether the data processing results in unnecessary exposure, persistence, or accumulation of data beyond what is necessary in relation to the intended purpose;
- whether the processing of a specific data category, including its level of precision, frequency, volume, or granularity, would reasonably be expected by an informed user or integrator, in light of the product's intended functionality and reasonably foreseeable use or misuse.

7.15.1.4 Assessment

7.15.1.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.15.1.4.2 Conceptual assessment

7.15.1.4.2.1 Assessment purpose

7.15.1.4.2.2 Assignment of verdict

7.15.1.4.3 Functional sufficiency assessment

7.15.1.4.3.1 Assessment purpose

7.15.1.4.3.2 Assignment of verdict

7.15.2 [DTM-2] Default Data Processing Minimisation (NEW)

7.15.2.1 Requirement

The product shall ensure that, by default, the processing of data, whether personal or non-personal, is limited to what is necessary in relation to its intended purpose and reasonably foreseeable use.

In particular, the product shall:

- a) ensure that data processing which is not necessary to achieve the intended purpose of the product does not occur by default, including by not enabling such processing by default or by technically preventing it from occurring;
- b) where processing of data that is necessary to achieve the intended purpose of the product is enabled by default, ensure that such processing is performed at the lowest level of precision, frequency, volume or granularity that is sufficient to achieve that intended purpose.

7.15.2.2 Rationale

DTM-2 addresses the data minimisation requirement by focusing on the default configuration of data processing when a product with digital elements is placed on the market or put into service.

DTM-2 gives effect to the data minimisation requirement under Annex I, Part I (2)(g) of the Cyber Resilience Act in conjunction with the requirement for secure-by-default configuration set out in Annex I, Part I (2)(b).

Default configurations determine the actual data processing behaviour of products in real-world use, particularly where users or integrators do not modify configuration settings. Where data processing that is not necessary for the intended purpose is enabled by default, this can lead to unnecessary data exposure, increased attack surface, and heightened impact in the event of a cybersecurity incident.

By requiring that unnecessary data processing does not occur by default, including where it is not enabled by default or is technically prevented from occurring, and that any data processing enabled by default is limited to the minimum level sufficient to achieve the intended purpose, this requirement reduces cybersecurity risks associated with excessive, overly granular, or continuous data processing, while preserving the ability to support necessary functionality.

7.15.2.3 Guidance

In applying this requirement, consideration may be given to whether the default configuration of the product:

- enables only data processing that is necessary to achieve the intended purpose of the product and, where such processing is enabled by default, limits it to the minimum level of precision, frequency, volume, or granularity sufficient for that purpose;
- ensures that data processing which is not necessary to achieve the intended purpose does not occur by default, including by not enabling such processing by default or by technically preventing it from occurring.
- ensures that when data processing is not enabled by default, the data processing which is not necessary for the intended purpose should not be enabled, without the user's or integrator's action.

Default data processing minimisation may be achieved either by ensuring that unnecessary processing does not occur by default, including by technically preventing it from occurring, or by applying default configurations that reduce the precision, frequency, volume, or granularity of data processing where such reduction is sufficient for the intended purpose.

For the purposes of this requirement, **'technically preventing data processing from occurring'** refers to ensuring that data processing which is not necessary for the intended purpose does not run in the product as placed on the market or put into service, including in cases where such processing would otherwise start automatically as part of normal operation and is not controlled

through an enable/disable setting. This may include, for example, internal activity recording, counters, or diagnostic functions that are used during development or initial setup and would otherwise continue to operate automatically in the product as placed on the market or put into service, unless prevented.

Data processing may, depending on the intended purpose of the product, be necessary to achieve that purpose. Where such processing is necessary, it may be enabled by default, provided it is limited to the minimum level sufficient to achieve the intended purpose. Where such processing is not necessary to achieve the intended purpose, it should not occur by default, including by not being enabled by default or by being technically prevented from occurring.

Depending on the intended purpose of the product, examples of data processing that may or may not be necessary, include telemetry, diagnostics, analytics, or logging . Where a product is intended to be integrated into another product, such as a microprocessor or modem supplied as a component, its intended purpose may include integration into a larger system and operation within a final product defined by an integrator. In such cases, certain data processing functions, such as security logging, diagnostics, analytics, or telemetry, may be necessary to support integration, testing, validation, secure operation, or troubleshooting in the context of system integration.

Where such processing is not necessary for the operation of the final integrated product in accordance with its intended purpose, the component manufacturer provides technical means enabling integrators to identify, configure, limit, or disable such processing.

In demonstrating that data processing is limited to what is necessary in relation to the intended purpose, manufacturers may make use of internal data identification or mapping practices that associate data categories and processing functions with the intended purpose of the product.

This requirement addresses default data processing behaviour; the availability of configurable controls for optional data processing during the product lifecycle is addressed separately under DTM-3.

Similarly, this requirement addresses the baseline data-processing behaviour of the product as placed on the market or put into service; the prevention of unauthorised enabling of additional data processing is addressed through other applicable cybersecurity requirements.

7.15.2.4 Assessment

7.15.2.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.15.2.4.2 Conceptual assessment

7.15.2.4.2.1 Assessment purpose

7.15.2.4.2.2 Assignment of verdict

7.15.2.4.3 Functional sufficiency assessment

7.15.2.4.3.1 Assessment purpose

7.15.2.4.3.2 Assignment of verdict

7.15.3 [DTM-3] Configurable Controls for Optional Data Processing (NEW)

7.15.3.1 Requirement

The product with digital elements shall provide technical means to configure optional processing of data, whether personal or non-personal, so as to minimise such processing in relation to its intended purpose and reasonably foreseeable use or misuse.

In particular, the product shall be capable of:

- a) allowing users and integrators to configure optional processing of data so that the precision, frequency, volume or granularity of data processed can be limited, or such processing disabled altogether, where such limitation or disablement does not prevent the product from achieving its intended purpose;
- b) preventing the accumulation or persistence of data generated by optional processing beyond what is reasonably required to support the optional function for which such processing is enabled;
- c) supporting the cessation of optional processing of data, and preventing further use of data associated with such processing, consistent with the intended purpose of the product.

7.15.3.2 Rationale

DTM-3 supports the data minimisation requirement under Annex I, Part I (2)(g) of the Cyber Resilience Act by addressing data processing that is optional in relation to the intended purpose of the product with digital elements and that may be enabled during the product lifecycle.

Optional data processing, while not necessary to achieve the intended purpose of the product, can introduce additional cybersecurity risks, including increased attack surface, unnecessary persistence of

data, and prolonged exposure in the event of a security incident, particularly where such processing remains enabled over time or is not actively managed by users or integrators.

By requiring that products with digital elements provide technical means to limit, disable, or cease optional data processing, DTM-3 ensures that the presence of optional functionality does not result in unnecessary or uncontrolled data processing over time. This supports the consistent application of data minimisation in a manner that preserves the intended functionality of the product while contributing to the reduction of cybersecurity risks.

7.15.3.3 Guidance

For the avoidance of doubt, DTM-3 addresses the availability of technical controls to manage data processing that is optional in relation to the intended purpose of the product over its lifecycle, including where such processing is enabled by a user or integrator.

The assessment of whether data processing is necessary in relation to the intended purpose of the product is addressed under DTM-1, while the determination of whether such processing may be enabled by default, and under what default conditions, is addressed under DTM-2.

For the purposes of this requirement, “**optional data processing**” refers to data processing that is not necessary for the product with digital elements to achieve its intended purpose and that can be technically enabled, disabled, or limited without preventing the product from fulfilling that purpose.

Optional data processing, while not necessary to achieve the intended purpose of the product, may nonetheless be enabled to support ancillary, optimisation, or informational functions during the product lifecycle.

DTM-3 applies where such optional processing exists and focuses on the availability of technical controls to limit, disable, or cease such processing, and to prevent unnecessary persistence or reuse of data generated by it, rather than on whether optional processing is enabled or disabled by default.

In applying this requirement, reduced levels of precision, frequency, volume, or granularity of optional data processing may be sufficient to support the optional function for which such processing is enabled, without affecting the ability of the product to achieve its intended purpose.

Where optional data processing generates stored data, configurable controls may include mechanisms to limit the duration or extent of data persistence, or to enable the removal of such data, where this is consistent with the intended purpose of the product and relevant cybersecurity requirements.

In applying this requirement, consideration may be given to whether the product provides users or integrators with effective and usable means to manage optional data processing in a manner consistent with the intended purpose of the product.

The availability of configurable controls under this requirement does not affect the applicability of DTM-2 with respect to default data processing minimisation, nor does it allow data processing that would be inconsistent with the data minimisation requirement set out in DTM-1.

7.15.3.4 Assessment

7.15.3.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.15.3.4.2 Conceptual assessment

7.15.3.4.2.1 Assessment purpose

7.15.3.4.2.2 Assignment of verdict

7.15.3.4.3 Functional sufficiency assessment

7.15.3.4.3.1 Assessment purpose

7.15.3.4.3.2 Assignment of verdict

7.16 [MON] Monitoring of security activities (NEW)

7.16.1 [MON-1] Monitor security relevant activities

7.16.1.1 Requirement

The product shall be able to actively monitor security relevant activities (referred to as events) including unauthorized access attempts and tampering attempts, such as modification of data, services or functions.

7.16.1.2 Rationale

The aim of the requirement is to monitor early detection of security incidents, which is a key cybersecurity principle. Anomalies often signal potential security breaches, such as:

- Unauthorized access attempts
- Unauthorized modification of data, services or functions.
- Malware activity
- Misuse of privileges

By permanently observing events real time and analysing logs for anomalies, monitoring can support **detecting threats early**, allowing for faster response and mitigation.

NOTE 1 An anomaly is an event or pattern of events that deviates from what is standard, normal or expected.

NOTE 2 This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat.SecurityActivitiesNotMonitoredRecorded]** and to meet the corresponding security objective **[SO.DetectionOfSecurityRelevantActivities]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.16.1.3 Guidance

The product should implement a continuous monitoring capability that reliably observes security-relevant events and conditions throughout its operation. The monitoring mechanism should cover all relevant behaviors, including authentication attempts, authorization decisions, configuration changes, unexpected restarts, abnormal behavior, network connection attempts, and any other events identified through a risk assessment or threat model. Monitoring activities should follow established industry best practices to ensure consistency, reliability, and interoperability. This includes using structured and predictable event formats, minimizing operational impact, and enabling integration with external monitoring or SIEM systems.

The product should provide both local and remote reporting functions. When a critical security issue is detected, the product should generate timely alerts without interfering with essential functions or compromising system performance.

The monitoring functionality should be designed so that it does not degrade the product's core operational behavior. Continuous monitoring must operate in a non-blocking manner, handle failures gracefully, and avoid excessive resource consumption, especially in resource-limited or real-time environments. Monitoring data itself should be treated as sensitive information and protected in transit and at rest through appropriate access controls and cryptographic mechanisms. If necessary, sensitive fields should be masked or redacted to avoid unintentional data exposure.

The manufacturer should document the full scope of monitored events, the default configuration, and the available mechanisms for adjusting monitoring behavior. This documentation should also describe the interfaces used for accessing or exporting logs, expected system performance under monitoring load, and any relevant constraints. Verification activities should demonstrate that security-relevant events are accurately detected, logged, and reported, that alerts are generated under defined conditions, and that monitoring does not impair essential system functions.

7.16.1.4 Assessment

7.16.1.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.16.1.4.2 Conceptual assessment

7.16.1.4.2.1 Assessment purpose

7.16.1.4.2.2 Assignment of verdict

7.16.1.4.3 Functional sufficiency assessment

7.16.1.4.3.1 Assessment purpose

7.16.1.4.3.2 Assignment of verdict

7.16.2 [MON-2] Disable monitoring

7.16.2.1 Requirement

The product shall provide a mechanism to disable monitoring.

7.16.2.2 Rationale

The aim of the requirement is to provide an opt-out mechanism for the monitoring of security relevant internal activity in a product is a nuanced decision, whereas monitoring is crucial for security, transparency and user trust.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (l) of Regulation 2024/2847. It is also necessary to cover the threats **[Threat. MonitoringDataDisclosure]** and to meet the corresponding security objective **[SO. OptionDisableDataMonitoring]** as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.16.2.3 Guidance

A mechanism that allows monitoring to be disabled must be designed with strict safeguards to prevent misuse and maintain security assurance. Only highly trusted administrative roles should have the ability to deactivate monitoring, and this action must always require strong authentication such as MFA. Even when internal monitoring is turned off, the system must still log the fact that monitoring was disabled, capturing who performed the action, when it occurred, and the stated reason. This meta-event must be written to a protected or external audit log so that it cannot be erased or modified.

Such a mechanism should always operate on a temporary basis. It is important that monitoring automatically reactivates after a defined period unless an authorized user explicitly re-extends the window with justification. The mechanism should also allow disabling only the minimum necessary categories of monitoring rather than shutting off all event monitoring, ensuring essential security-relevant events remain captured.

The intended purposes to support the function for disabling monitoring—such as maintenance, troubleshooting, or preventing system overload—must be clearly documented and communicated. Disabling monitoring must never be used to obscure user activity or hide system behavior. Finally, remaining active security monitoring must track any occurrence of monitoring deactivation, issuing alerts to the responsible security team, which should review each instance to ensure it aligns with legitimate operational needs.

7.16.2.4 Assessment

7.16.2.4.1 Assessment objective

The assessment addresses the requirement <Req #>.

7.16.2.4.2 Conceptual assessment

7.16.2.4.2.1 Assessment purpose

7.16.2.4.2.2 Assignment of verdict

7.16.2.4.3 Functional sufficiency assessment

7.16.2.4.3.1 Assessment purpose

7.16.2.4.3.2 Assignment of verdict

7.17 [SPD] Secure Processed Data

7.17.1 [SPD-1] Secure Processed Data

7.17.1.1 Requirement

Appropriate technical measures shall be implemented in the product to ensure that processed critical data cannot be read or modified by non trusted or non-intended components, processes or other entities.

NOTE “Processed data” (aka. **data in use**) refers to data handled during runtime, as well as data actively used during execution of the system. (e.g. in volatile memory, registers, caches, buffers). This specifically distinguished from **data at rest**, which is stored on persistent media, and **data in transit**, which is being transmitted across network interfaces.

7.17.1.2 Rational

Products with digital elements may process sensitive data, including personal data, cryptographic material, proprietary algorithms, and security or safety-relevant operational information. During processing, such data may be temporarily stored in volatile memory, registers, caches, buffers, or other runtime storage locations.

If processed data is not adequately protected, an attacker may gain the ability to read or modify data that is processed by the product. Furthermore, if one component within the product is compromised, insufficient protection of processed data may allow the compromised component to read or modify runtime data of other components. This can facilitate further compromise within the system, including privilege escalation or propagation of the attack across execution contexts.

Unauthorized disclosure of processed data may lead to exposure of confidential information, compromise of intellectual property, privacy violations, or disclosure of critical information. Likewise, unauthorized modification of processed data may result in corrupted computations, altered security decisions, malfunctioning behaviour, or safety-relevant impacts.

The aim of this requirement is to ensure that the confidentiality and integrity of processed data are effectively protected by appropriate technical measures.

This requirement is necessary because missing protection of processed data increases the risk that an attacker may compromise confidentiality or integrity of processed data, potentially affecting security- or safety-relevant functions of the product.

NOTE This requirement is necessary to partially (processed data) meet the essential cybersecurity requirement (e) and (f) of Regulation 2024/2847. It is also necessary to cover the threats: *Threat.ProcessedDataDisclosure* and *Threat.ProcessedDataTampering* and to meet the corresponding security objectives: *SO.DataProcessedConfidentiality* and *SO.DataProcessedIntegrity* as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

7.17.1.3 Guidance

Disclosure or modifications of Processed Data may occur due to insufficient separation or isolation mechanisms, exploitable software or hardware weaknesses, shared execution environments, or improper handling of data.

Processed data is typically protected by a combination of ***structural separation mechanisms***, ***cryptographic protection mechanisms*** and ***system hardening measures***.

7.17.1.3.1 Separation Mechanisms for Processed Data

Separation mechanisms ensure that processed data remains restricted to its designated execution context and cannot be read or modified by non-intended components, processes or other entities. Furthermore, it helps contain the impact of partial system compromise, limiting cross-component access to processed data.

Different forms of isolation can be distinguished.

Logical Separation Measures

Logical separation enforces boundaries within the system architecture to restrict which components, execution contexts, or memory regions may access certain processed data. Examples can include but are not limited to concepts like:

- Separation of SW by design in multiple zones with different privileges
- separation of execution contexts through privilege levels or distinct execution domains
- virtualization or sandboxing mechanisms that prevent one component from reading the data of another

Examples of such mechanisms include but are not limited to:

Table 16

Logical Separation Measures	Confidentiality	Integrity
Software-defined privilege separation (e.g. user/kernel mode separation)	x	x

Execution domain separation (separate processes, sandboxing, containers)	x	x
Hypervisor-based virtualization (virtual machines)	x	x

Physical Separation Measures

Physical separation limits sensitive processing to dedicated hardware resources or protected processing domains.

Examples can include but are not limited to concepts like:

- dedicated secure processing environments
- memory protection mechanisms that restrict read or write access to defined memory regions
- hardware-based isolation components that separate sensitive execution from general-purpose processing
- restriction of direct memory access by non-intended peripherals or bus masters

Examples of such mechanisms include but are not limited to:

Table 17

Physical Separation Measures	Confidentiality	Integrity
Trusted Execution Environment (TEE (HW enforced e.g. ARM TrustZone))	x	x
Memory protection / management mechanisms (HW enforced MPU, MMU)	x	x
Hardware Security Module (HSM / SHE)	x	x
DMA protection (e.g. IOMMU)	x	x

7.17.1.3.2 Cryptographic Protection Mechanisms for Processed Data

Cryptographic protection mechanisms can protect processed data by ensuring that it cannot be meaningfully read outside its designated execution context.

Examples can include but are not limited to concepts like:

- memory encryption mechanisms protecting process data in volatile memory
- homomorphic encryption allowing computation on encrypted data without requiring decryption

Examples of such mechanisms include but are not limited to:

Table 18

Cryptographic protection of processed data	Confidentiality	Integrity
Runtime Memory encryption (TME, SME, ARM MEE)	x	-
Homomorphic encryption (where applicable)	x	-

NOTE Cryptographic protection of processed data is generally dependent on specialized hardware capabilities and may not be proportionate or feasible for some product categories.

7.17.1.3.3 System Hardening Measures

In addition to structural separation, such measures as Runtime Protection Measures and Secure Data Handling practices enhance system resilience and limit the exposure of sensitive processed data.

NOTE Runtime Protection Measures and Secure Handling of Processed Data do not replace *Separation mechanisms* but reduce the likelihood that vulnerabilities can be exploited to access or manipulate processed data.

Runtime Protection Measures

Runtime protection measures increase resistance against exploitation of vulnerabilities that could otherwise enable unauthorized read or modification of processed data.

Examples of such measures can be found in 7.13.11 [GEC-11] Exploit mitigation mechanisms.

Secure Handling of Processed Data

Secure handling practices reduce the exposure and lifetime of sensitive processed data within the system. Hereby it can help to reduce the attack surface and limit the impact of partial compromise by minimizing the availability of processed data.

Examples can include but are not limited to secure data handling principles such as:

Table 19

Secure Handling	Confidentiality	Integrity
Zeroization of sensitive data after use	x	-
Minimization of runtime lifetime of sensitive data	x	-
Avoidance of unnecessary storage of sensitive data in shared memory	x	x
Processing sensitive data within appropriate domains	x	x

7.17.1.4 Assessment

TODO <To be defined and added>

7.18 [LIM] Limitation of Negative Impact on External Systems

7.18.1 [LIM-1] Egress traffic rate limiting and connection throttling (NEW)

7.18.1.1 Requirement

The product shall provide mechanisms to limit sustained abnormal outbound traffic that could negatively impact the availability of services provided by other devices or networks, including at minimum:

- rate limiting of outbound packets/messages for connectionless protocols where applicable; and
- throttling of outbound connection attempts (including exponential backoff on repeated failures), where such communication is supported by the product.

7.18.1.2 Rational

The aim of this requirement is to reduce the risk that a product generates excessive or abnormal outbound network traffic that could degrade or disrupt the availability of services provided by other devices, systems, or networks, whether unintentionally (e.g. due to malfunction or misconfiguration) or as a result of exploitation.

This requirement is necessary because uncontrolled outbound traffic can contribute to resource exhaustion, network congestion, or amplification effects, including participation in denial-of-service attacks or large-scale scanning activities. Implementing mechanisms such as rate limiting and throttling of outbound communication helps to contain the impact of compromised or misbehaving products, limits the potential for attack propagation, and supports the protection of availability of interconnected systems and networks.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat [Threat.ExtServiceAvailabilityDegradation] to meet the corresponding security objectives [SO.LimitExternalImpact] and [SO.PreventAttackPropagation].

7.18.1.3 Guidance

To limit abnormal outbound traffic, the product shall provide the capability to monitor and control the volume and frequency of outbound communication initiated by the product. Such measures may be applied to both connectionless and connection-oriented protocols, taking into account the intended purpose and operational requirements of the product.

Examples of such measures include, but are not limited to:

- limiting the rate of outbound packets or messages for connectionless protocols in order to prevent traffic bursts or amplification effects;

- throttling outbound connection attempts, including the application of backoff mechanisms following repeated connection failures, to reduce the impact of malfunctioning or compromised components.

These mechanisms can be designed to allow legitimate operation while preventing sustained or abnormal traffic patterns that could degrade the availability of services provided by other devices or networks. Thresholds and limits may be selected based on the risk assessment, considering factors such as the expected communication behavior of the product, the operational environment, and potential impacts on interconnected systems.

Configured limits and retry behaviour should be documented in the technical documentation.

NOTE This requirement applies to products that can originate or forward network traffic to other devices/networks (including via connected devices controlled/managed by the product).

7.18.1.4 Assessment Criteria

7.18.2 [LIM-2] No unauthenticated reflection/amplification or open relay behaviour (NEW)

7.18.2.1 Requirement

[LIM-2--1] The product shall not, in factory default state, provide network services accessible from untrusted networks that can be abused as an unauthenticated reflector/amplifier or open relay to third parties.

[LIM-2-2] Where a service as in [LIM 2-1] is required for the intended purpose, the product shall implement abuse mitigations, such as one or more effective mitigations appropriate to the risk:

- restricting exposure to trusted networks/peers (allow-listing / local-scope binding);
- request authentication/authorization; or
- response rate limiting / proof-of-reachability mechanisms, where applicable.

7.18.2.2 Rational

[LIM-2--1] The aim of this requirement is to prevent a product, in its factory default state, from being misused by third parties as a reflector, amplifier, or open relay in network-based attacks, thereby limiting the potential impact of the product on the availability and integrity of external systems and networks.

This requirement is necessary because network services that are accessible without authentication can be exploited to generate or relay large volumes of traffic towards third-party targets, including through reflection or amplification techniques or as an open relay. Such misuse can contribute to denial-of-service attacks, reputational damage, and broader disruption of network services. Ensuring that products do not expose such services by default reduces the risk of large-scale abuse, supports the protection of availability of interconnected systems, and aligns with the principle that secure default configurations should minimize the potential for attack propagation.

[LIM-2-2] The aim of this requirement is to ensure that, where network services with potential for abuse are required for the intended purpose of the product, appropriate mitigations are in place to prevent their misuse as reflectors, amplifiers, or open relays while still allowing legitimate operation.

This requirement is necessary because network services that accept unauthenticated or unrestricted requests can be exploited by third parties to generate or relay disproportionate amounts of traffic, contributing to denial-of-service attacks, attack propagation, or other forms of network abuse. Implementing abuse mitigations, such as restricting exposure to trusted peers, enforcing authentication or authorization, or limiting responses through rate-limiting or proof-of-reachability mechanisms, reduces the likelihood that a product can be misused as part of large-scale attacks and supports the protection of availability of interconnected systems and networks.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat [Threat.ExtServiceAvailabilityDegradation] to meet the corresponding security objectives [SO.LimitExternalImpact] and [SO.PreventAttackPropagation]..

7.18.2.3 Guidance

[LIM2-1] Products should be designed and configured such that, in their factory default state, network services exposed to external networks do not permit unauthenticated use that would enable the product to act as a traffic reflector, amplifier, or open relay for third parties.

This may be achieved by, for example:

- disabling network services that are not required for the intended purpose of the product;
- requiring authentication, authorization, or equivalent access restrictions before a service can process or relay third-party requests;
- limiting or suppressing service responses that could generate disproportionate outbound traffic relative to inbound requests;
- constraining relaying or forwarding functionality to explicitly authorized peers or trusted networks only.

When assessing applicable services, consideration may be given to whether a service could be abused to reflect, amplify, or relay traffic without the knowledge or control of the product owner. Secure default configurations should minimize exposure of such services, while allowing manufacturers or users to explicitly enable them where necessary and appropriate for the intended operational environment and risk profile.

[LIM2-2] Where a network service that could potentially be abused is required for the intended purpose of the product, the implementation should include measures to reduce the likelihood that the service can be misused to reflect, amplify, or relay traffic to third parties.

Such mitigations may include, for example:

- limiting the exposure of the service to trusted networks, peers, or local interfaces only, including the use of allow-listing or binding the service to a restricted scope;
- requiring appropriate authentication or authorization prior to processing requests or generating responses;

- applying response controls, such as rate limiting or proof-of-reachability mechanisms, to prevent disproportionate outbound traffic.

The selection and combination of mitigation measures may depend on the characteristics of the service, the supported protocols, and the intended operational environment. Mitigations should be designed to allow legitimate use of the service while reducing the risk that the product can be abused as part of large-scale network attacks or other forms of misuse.

Responses generated by the service should be proportionate to the initiating request and should not enable amplification behaviour.

NOTE This requirements applies to products that expose network services that can be abused for reflection, amplification, relaying, proxying, or forwarding (e.g., UDP-based responders, discovery protocols, proxy/relay features).

7.18.3 [LIM-3] Source-address integrity / anti-spoofing (NEW)

7.18.3.1 Requirement

The product shall prevent the generation or forwarding of network traffic with spoofed source addresses that could facilitate denial-of-service attacks against other devices or networks, unless explicitly required by the intended purpose and justified in the cybersecurity risk assessment documented in the technical documentation, and implemented with compensating controls.

7.18.3.2 Rational

The aim of this requirement is to prevent the product from being misused to generate or forward network traffic with falsified source addresses that could be exploited to conduct or amplify denial-of-service attacks against third-party devices or networks.

This requirement is necessary because spoofed source addresses are a common technique used in reflection and amplification attacks, where traffic appears to originate from legitimate systems and is redirected toward victims at scale. If a product permits the generation or forwarding of such traffic without appropriate controls, it may contribute to large-scale attacks, hinder attribution and mitigation efforts, and negatively impact the availability of interconnected systems. Requiring the prevention of spoofed traffic by default, while allowing exceptions only where explicitly justified by the intended purpose and supported by compensating controls, helps limit abuse potential and supports the protection of network availability.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat [Threat.ExtServiceAvailabilityDegradation] to meet the corresponding security objectives [SO.LimitExternalImpact] and [SO.PreventAttackPropagation].

7.18.3.3 Guidance

The product should be designed and configured to prevent the generation or forwarding of network traffic with spoofed or falsified source addresses under normal operation.

This may be achieved by, for example:

- enforcing source address validation on outbound traffic to ensure that packets originate from legitimate and expected address ranges;

- restricting packet forwarding behavior such that traffic with implausible, inconsistent, or non-local source addresses is not generated or relayed;
- applying protocol-specific checks or controls to prevent misuse of connectionless or reflection-prone communication mechanisms.
- recording blocked spoofing attempts as events.

Where the intended purpose of the product requires the use of traffic with altered or non-verifiable source addressing (e.g. for diagnostic, testing, or specialized network functions), such behavior should be explicitly documented, justified by the cybersecurity risk assessment, and complemented by compensating controls. Such behavior should be restricted to authorized interfaces, trusted networks, or controlled operational modes. These controls may aim to limit exposure, detect misuse, or reduce the potential impact on third-party devices or networks.

NOTE This requirements applies to products that can forward, route, or bridge traffic for connected devices, or can craft packets beyond normal OS/network stack constraints.

7.18.4 [LIM-4] Abuse-aware monitoring focused on external impact (NEW)

7.18.4.1 Requirement

[LIM-4-1]] The product shall provide monitoring mechanisms to detect abnormal outbound traffic patterns indicative of participation in denial-of-service attacks or large-scale scanning that could impact other devices or networks. The detection of such patterns shall result in a recorded event.

[LIM-4-2] The product shall provide the capability to alert or report such conditions to an appropriate entity in a timely manner.

(This complements NMM-1 by explicitly covering “impact to others”, not only between the product and its connected devices.)

7.18.4.2 Rational

[LIM-4-1] The aim of this requirement is to enable the timely detection of abnormal outbound traffic generated or forwarded by the product that may indicate misuse, compromise, or malfunction, and that could contribute to denial-of-service attacks or large-scale scanning activities affecting other devices or networks.

This requirement is necessary because products participating unknowingly in denial-of-service attacks or scanning campaigns may generate traffic patterns that are not immediately visible to users or operators and may persist over time. Without monitoring mechanisms, such behavior can remain undetected, increasing the impact on third-party systems and networks and delaying mitigation actions. Providing mechanisms to detect abnormal outbound traffic supports early identification of security incidents, enables containment measures, and contributes to the protection of availability of interconnected systems and networks.

[LIM-4-2] The aim of this requirement is to ensure that abnormal outbound traffic conditions that may negatively impact third-party devices or networks are communicated in a timely manner to an appropriate entity, enabling awareness and coordinated response beyond the product itself.

This requirement is necessary because abnormal traffic patterns indicative of denial-of-service participation or large-scale scanning may not only affect the product and its directly connected devices, but may also cause harm to external systems, networks, or services. Without alerting or reporting capabilities, such conditions may remain unnoticed or unaddressed, delaying mitigation and increasing the risk of broader network disruption. Providing the capability to alert or report supports early intervention, accountability, and coordinated response, and complements monitoring requirements by ensuring that detected conditions can be acted upon effectively.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat [Threat.ExtServiceAvailabilityDegradation] to meet the corresponding security objectives [SO.LimitExternalImpact] and [SO.MonitorExternalImpact].

7.18.4.3 Guidance

[LIM4-1] The product should provide monitoring mechanisms capable of observing outbound traffic behavior and identifying patterns that deviate from expected or intended operation.

Such mechanisms may, for example:

- monitor the volume, frequency, or rate of outbound traffic to detect sustained or sudden increases inconsistent with normal operation;
- identify repetitive or widespread outbound communication attempts characteristic of scanning or probing activities;
- support detection of abnormal traffic patterns across different protocols or destinations.

The scope and sensitivity of monitoring may be determined based on the intended purpose of the product and the cybersecurity risk assessment. Monitoring mechanisms may be implemented in a manner that supports subsequent actions, such as alerting, logging, or triggering containment or limiting measures, while avoiding undue interference with legitimate operation.

[LIM-4-2] Where abnormal outbound traffic patterns indicative of potential misuse or compromise are detected, the product should support mechanisms to alert or report such conditions to an appropriate entity in a timely manner.

Such entities may include, for example:

- the user or operator of the product;
- an administrative or management system responsible for overseeing deployed products;
- a security operations or incident handling function, where applicable.

Alerting or reporting mechanisms may provide information sufficient to understand the nature and scope of the detected condition, such as the type of abnormal traffic, its persistence, or its potential external impact. Recorded events should be retained for a period sufficient to support incident investigation and conformity assessment. The form and destination of alerts or reports may be determined based on the intended purpose of the product and the operational environment, and may range from local notifications to remote reporting mechanisms.

These mechanisms should be designed to support timely mitigation actions and coordination, while avoiding unnecessary disruption of legitimate operation and respecting applicable constraints on information disclosure.

NOTE This requirements applies where the product provides network connectivity functions or can generate or forward significant traffic (including gateways, routers, hubs, controllers, and remotely managed devices).

7.18.5 [LIM-5] Quarantine / degraded networking mode to minimise harm (NEW)

7.18.5.1 Requirement

The product shall provide the capability to enter a restricted networking mode (manual and/or automatic upon detection of compromise/abuse) that limits communications to the minimum necessary to maintain essential functions and security updates, in order to minimise negative impact on other devices or networks.

The restricted networking mode shall result in a measurable reduction of outbound communications compared to normal operation.

7.18.5.2 Rational

The aim of this requirement is to provide a controlled means for the product to limit its network interactions in situations where compromise, misuse, or abnormal behavior is detected, thereby reducing the risk of ongoing harm to other devices or networks while preserving essential functionality.

This requirement is necessary because, in the presence of compromise or abuse, continued full network operation may enable sustained attack propagation, denial-of-service participation, or other forms of negative external impact. Without a restricted networking mode, the product may be unable to effectively limit its contribution to harmful traffic patterns once such conditions are identified. Providing the capability to enter a restricted networking mode supports containment, damage limitation, and recovery, and contributes to the protection of availability of interconnected systems and networks while maintaining essential security and maintenance functions.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat [Threat.ExtServiceAvailabilityDegradation] to meet the corresponding security objectives [SO.LimitExternalImpact] and [SO.PreventAttackPropagation] .

7.18.5.3 Guidance

The product should support a restricted networking mode that limits communications to those strictly required to maintain essential functions, security controls, and the application of security updates.

Such a mode may be entered, for example:

- manually, by a user or operator in response to suspected compromise or misuse; and/or
- automatically, upon detection of abnormal conditions indicative of compromise, abuse, or participation in network-based attacks.

- Automatic activation should be triggered by detected abnormal conditions or security events.

In restricted networking mode, non-essential network services and outbound communications may be reduced, suspended, or limited, while allowing functionality necessary for safe operation, diagnostics, management, incident handling, or receipt of security updates. The scope and behavior of this mode may be determined based on the intended purpose of the product and the cybersecurity risk assessment.

The design of the restricted networking mode should support containment and mitigation without requiring complete isolation where this would prevent recovery or remediation and should facilitate a controlled return to normal operation once the triggering conditions have been addressed.

NOTE This requirements applies to products that can enforce traffic restrictions on their own communications (and, where such traffic forwarding capability is supported by the product, traffic they forward for connected devices).

7.18.6 [LIM-6] Per-connected-device fairness controls for hubs/gateways (NEW)

7.18.6.1 Requirement

The product shall provide mechanisms to prevent any single connected device (or subset) from causing disproportionate outbound traffic that could negatively impact other devices or networks, such as per-device rate limiting, segmentation, or policy-based egress controls, as applicable. The application of per-device restrictions should be recorded as events.

7.18.6.2 Rational

The aim of this requirement is to ensure that the behavior of individual connected devices, or subsets of such devices, does not result in excessive outbound traffic that could disproportionately impact other devices or networks, even when the product as a whole is operating as intended.

This requirement is necessary because a single misbehaving, compromised, or malicious connected device can generate traffic volumes that exceed its fair share of network resources and contribute to denial-of-service conditions or large-scale traffic abuse. Without mechanisms to constrain the influence of individual devices, the product may unintentionally facilitate attack propagation or network congestion affecting third-party systems. Providing controls to limit disproportionate outbound traffic supports resilience, fairness in resource usage, and the protection of availability of interconnected devices and networks.

NOTE This requirement is necessary to meet the essential cybersecurity requirement ECR ANNEX I Part I (2) (i) of Regulation 2024/2847. It is also necessary to cover the threat [Threat.ExtServiceAvailabilityDegradation] to meet the corresponding security objectives [SO.LimitExternalImpact] and [SO.PreventAttackPropagation].

7.18.6.3 Guidance

The product should include mechanisms that enable the limitation of outbound traffic generated by individual connected devices or defined subsets of devices in proportion to their intended role and expected behavior.

Such mechanisms may include, for example:

- applying per-device or per-group rate limits to outbound traffic;
- logically segmenting connected devices to restrict the scope of traffic generation or forwarding;
- enforcing policy-based egress controls that define acceptable traffic volumes, destinations, or patterns for different classes of connected devices.

The selection and configuration of these mechanisms may be based on the intended purpose of the product, the expected communication behavior of connected devices, and the cybersecurity risk assessment. Controls should be designed to enable legitimate operation while preventing individual devices from dominating outbound traffic generation or contributing disproportionately to conditions that could negatively impact other devices or networks.

NOTE This requirements applies to products that mediate or provide shared connectivity for multiple connected devices (e.g., gateways, bridges, hubs, controllers).

Annex A (informative)

Mapping to the CRA essential requirements

Table A.1

ESR	SO	Technical security control
(a) Vulnerability assessment	5.1.3.1 S01 - SO.VulnerabilityManagementPr ocess	7.13.1 [GEC-1] Up-to-date software and hardware with no publicly known exploitable vulnerabilities
...		

Annex B
(informative)

Mapping between the RED 18031 and the 40000-1-4 controls

Table B.1

18031	40000-1-4
ACM-1, ACM-2	ACM-2

Annex C
(informative)

(T.B.D.) Mapping(s) other security control standards (e.g., EN 303645) to
the 40000-1-4 controls

Annex D

(informative)

Working Template to convert 18031 into 40000-1-4 requirements (TO BE DELETED)

Blue text represents building blocks.

Green text represents guidance text.

Black text stays as is.

1 Requirements

1.1 [XYZ] XYZ mechanism

1.1.1 Requirement

Combination of XYZ-1 and XYZ-2 requirement without exceptions and replacing any specific assets only with the generic word "assets".

After performing the combination, the new combined requirement is to be shown in section XYZ-2. Consequently, XYZ-1 is to be voided with the single word "void" standing under section XYZ-1. *Note: If the requirements from XYZ-1 and XYZ-2 are combined, consequently, the assessment are to be combined as well which is then shown in section 1.1.4 (see below).*

If there are more requirements, e.g. XYZ-3, -4, -5 etc. they are to be handled in an additional requirement section or also combined together with XYZ-2 as considered appropriate.

1.1.2 Rationale

Rationale of XYZ-1 and XYZ-2 can be copy-pasted here if appropriate.

<Aim of the requirement> The aim of this requirement is <...>. E.g.: The aim of this requirement is that the PWDE provides the option to change the authenticator for each authentication mechanism.

<Necessity of the requirement> This requirement is necessary <...>. E.g.: ... as static authenticators can be a security risk for the equipment, e.g., increased vulnerability to brute force and eavesdropping attacks. Therefore, the support for changing authenticators on the equipment is needed as a countermeasure. <Application Example> e.g. option in the settings menu. Moreover, for password-based authentication the changing of passwords in a regular interval has proven to increase the security.

<Link to CRA and PT2 TR> This requirement is necessary to meet the essential cybersecurity requirement [63] of Regulation 2024/2847. It is also necessary to cover the threat Threat ABC and to meet the corresponding security objective SO ABC as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

1.1.3 Guidance

Guidance of XYZ-1 and XYZ-2 can be copy-pasted here if appropriate.

Implementation Categories can be transferred to the Guidance section as well:

Common XYZ mechanisms as declared in the implementation categories of the EN 18031 series [63] are the following: XYZ1, XYZ2, XYZ3, ...

Implementation category dependent assessment units from EN 18031 are described:

Assessments based on XYZ1 may include to functionally confirm that:

Here one should place the text of [AUXYZ1]

Assessments based on XYZ2 may include to functionally confirm that:

Here one should place the text of [AUXYZ2]

Assessments based on XYZ3 may include to functionally confirm that:

38 Here one should place the text of [AU.XYZ3]
 39 [...]
 40 Assessments based on other XYZ mechanism may include to functionally confirm that:
 41 Here one should place the text of [AU.XYZ.General]
 42 **1.1.4 Assessment criteria**
 43 **1.1.4.1 Assessment objective**
 44 The assessment addresses the requirement XYZ.
 45 **1.1.4.2 Required information**
 46 Required information of XYZ-1 and XYZ-2 can be copy-pasted and modified here as needed.
 47 **1.1.4.2.1 Conceptual assessment**
 48 **1.1.4.2.1.1 Assessment purpose**
 49 The purpose of this assessment case is the conceptual assessment whether XYZ mechanisms are
 50 implemented as required per XYZ.
 51 **1.1.4.2.1.2 Preconditions**
 52 None.
 53 **1.1.4.2.1.3 Assessment units**
 54 For each asset documented in [E.Info.XYZ.Asset] check whether there are XYZ mechanism described in
 55 [E.Info.XYZ.Asset.XYZ] and whether those XYZ mechanism ensure that only authorized entities have
 56 access to the corresponding asset.
 57 In addition, examine the justification documented in [E.Just.XYZ].
 58 **1.1.4.2.1.4 Assignment of verdict**
 59 The verdict PASS for the assessment case is assigned if:
 60 — for every asset documented in [E.Info.XYZ.Asset] there is at least one XYZ mechanism as
 61 described in [E.Info.XYZ.Asset.XYZ], and
 62 — for every asset documented in [E.Info.XYZ.Asset] the corresponding XYZ mechanism(s)
 63 ensure(s) that [the appropriateness property is met], and
 64 — the information provided in [E.Just.XYZ] are correct justifications.
 65 The verdict FAIL for the assessment case is assigned if:
 66 — there is an asset documented in [E.Info.XYZ.Asset] whose access is not managed via an XYZ
 67 mechanism, or
 68 — there is an asset documented in [E.Info.XYZ.Asset] whose corresponding XYZ mechanism(s)
 69 described in [E.Info.XYZ.Asset.XYZ] is/are not ensuring that [the appropriateness property is
 70 met],

Blue text represents building blocks.
 Green text represents guidance text.
 Black text stays as is.

71 — a justification provided in [E-Just-XYZ] is not correct or missing.

72 The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

73 **1.1.4.2.2 Functional assessment**

74 **1.1.4.2.2.1 Assessment purpose**

75 The purpose of the functional assessment is to:

76 - verify that all the assets that are accessible by entities, are documented in [E-Info-XYZ-Asset],
 77 - verify whether XYZ mechanisms are implemented as required per XYZ.

78 **1.1.4.2.2.2 Preconditions**

79 The equipment is in an operational state.

80 **1.1.4.2.2.3 Assessment units**

81 Functionally assess whether there are assets, that are accessible by entities, in the equipment, which are
 82 not documented in [E-Info-XYZ-Asset], e.g. by inspecting all parts of the software such as built-in software,
 83 installed applications and interfaces for connected peripherals.

84 In addition, for each asset documented in [E-Info-XYZ-Asset] functionally confirm that:
 85 XYZ specific properties are listed here

86 **1.1.4.2.2.4 Assignment of verdict**

87 The verdict PASS for the assessment case is assigned if:

88 - all assets found are documented in [E-Info-XYZ-Asset],
 89 - there is no evidence that an XYZ mechanism documented in [E-Info-XYZ-Asset-XYZ] is not
 90 implemented, and
 91 - for each asset documented in [E-Info-XYZ-Asset]:
 92 the listed and assessed XYZ specific properties are fulfilled

93 The verdict FAIL for the assessment case is assigned if:

94 - an asset is found that is not documented in [E-Info-XYZ-Asset], or
 95 there is evidence that an XYZ mechanism documented in [E-Info-XYZ-Asset-XYZ] is not
 96 implemented, or
 97 - for an asset documented in [E-Info-XYZ-Asset]:
 98 one of the listed and assessed XYZ specific properties is not fulfilled

99 The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

NOTE The template text is repeated below without color coding for copying, where:

- *Italic text* represents building blocks.
- Normal text represents guidance text.
- Underlined text stays as is.

1 Requirements

1.1 [XYZ] XYZ mechanism

1.1.1 Requirement

Combination of XYZ-1 and XYZ-2 requirement without exceptions and replacing any specific assets only with the generic word “assets”.

After performing the combination, the new combined requirement is to be shown in section XYZ-2. Consequently, XYZ-1 is to be voided with the single word “void” standing under section XYZ-1. Note: If the requirements from XYZ-1 and XYZ-2 are combined, consequently, the assessment are to be combined as well which is then shown in section 1.1.4 (see below).

If there are more requirements, e.g. XYZ-3, -4, -5 etc. they are to be handled in an additional requirement section or also combined together with XYZ-2 as considered appropriate.

1.1.2 Rationale

Rationale of XYZ-1 and XYZ-2 can be copy-pasted here if appropriate.

<Aim of the requirement> The aim of this requirement is <...> . E.g.: The aim of this requirement is that the PWDE provides the option to change the authenticator for each authentication mechanism.

<Necessity of the requirement> This requirement is necessary <...> . E.g.: ... as static authenticators can be a security risk for the equipment, e.g., increased vulnerability to brute force and eavesdropping attacks. Therefore, the support for changing authenticators on the equipment is needed as a countermeasure, <Application Example> e.g. option in the settings menu. Moreover, for password-based authentication the changing of passwords in a regular interval has proven to increase the security.

<Link to CRA and PT2 TR> This requirement is necessary to meet the essential cybersecurity requirement (x) of Regulation 2024/2847. It is also necessary to cover the threat *Threat.ABC* and to meet the corresponding security objective *SO.ABC* as described in the PT2 TR. It might also help to meet other essential cybersecurity requirements of Regulation 2024/2847 and other threats and security objectives of the PT2 TR.

1.1.3 Guidance

Guidance of XYZ-1 and XYZ-2 can be copy-pasted here if appropriate.

Implementation Categories can be transferred to the Guidance section as well:

Common XYZ mechanisms as declared in the implementation categories of the EN 18031 series [i.x] are the following: XYZ1, XYZ2, XYZ3, ...

Implementation category dependent assessment units from EN 18031 are described:

Assessments based on XYZ1 may include to functionally confirm that:

Here one should place the text of [AU.XYZ1]

Assessments based on XYZ2 may include to functionally confirm that:

Here one should place the text of [AU.XYZ2]

Assessments based on XYZ3 may include to functionally confirm that:

Here one should place the text of [AU.XYZ3]

[...]

Assessments based on otherXYZmechanism may include to functionally confirm that:

Here one should place the text of [AU.XYZ.General]

1.1.4 Assessment criteria

1.1.4.1 Assessment objective

The assessment addresses the requirementXYZ.

1.1.4.2 Required information

Required information of XYZ-1 and XYZ-2 can be copy-pasted and modified here as needed.

1.1.4.2.1 Conceptual assessment

1.1.4.2.1.1 Assessment purpose

The purpose of this assessment case is the conceptual assessment whetherXYZmechanisms are implemented as required perXYZ.

1.1.4.2.1.2 Preconditions

None.

1.1.4.2.1.3 Assessment units

For each asset documented in [E.Info.XYZ.Asset] check whether there are XYZ mechanism described in [E.Info.XYZ.Asset.XYZ] and whether those XYZ mechanism ensure that only authorized entities have access to the corresponding asset.

In addition, examine the justification documented in[E.Just.XYZ].

1.1.4.2.1.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- *for every asset documented in [E.Info.XYZ.Asset] there is at least one XYZ mechanism as described in [E.Info.XYZ.Asset.XYZ], and*
- *for every asset documented in [E.Info.XYZ.Asset] the corresponding XYZ mechanism(s) ensure(s) that [the appropriateness property is met], and*
- the information provided in[E.Just.XYZ]are correct justifications.

The verdict FAIL for the assessment case is assigned if:

- *there is an asset documented in [E.Info.XYZ.Asset] whose access is not managed via an XYZ mechanism, or*
- *there is an asset documented in [E.Info.XYZ.Asset] whose corresponding XYZ mechanism(s) described in [E.Info.XYZ.Asset.XYZ] is/are not ensuring that [the appropriateness property is met],*

- a justification provided in [E.Just.XYZ] is not correct or missing.

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

1.1.4.2.2 Functional assessment

1.1.4.2.2.1 Assessment purpose

The purpose of the functional assessment is to:

- *verify that all the assets that are accessible by entities, are documented in [E.Info.XYZ.Asset],*
- *verify whether XYZ mechanisms are implemented as required per XYZ.*

1.1.4.2.2.2 Preconditions

The equipment is in an operational state.

1.1.4.2.2.3 Assessment units

Functionally assess whether there are assets, that are accessible by entities, in the equipment, which are not documented in [E.Info.XYZ.Asset], e.g. by inspecting all parts of the software such as built-in software, installed applications and interfaces for connected peripherals.

In addition, for each asset documented in [E.Info.XYZ.Asset] functionally confirm that:

XYZ specific properties are listed here

1.1.4.2.2.4 Assignment of verdict

The verdict PASS for the assessment case is assigned if:

- *all assets found are documented in [E.Info.XYZ.Asset],*
- *there is no evidence that an XYZ mechanism documented in [E.Info.XYZ.Asset.XYZ] is not implemented, and*
- *for each asset documented in [E.Info.XYZ.Asset]:*
 - *the listed and assessed XYZ specific properties are fulfilled*

The verdict FAIL for the assessment case is assigned if:

- *an asset is found that is not documented in [E.Info.XYZ.Asset], or*
- *there is evidence that an XYZ mechanism documented in [E.Info.XYZ.Asset.XYZ] is not implemented, or*
- *for an asset documented in [E.Info.XYZ.Asset]:*
 - *one of the listed and assessed XYZ specific properties is not fulfilled*

The verdict NOT APPLICABLE for the assessment case is assigned otherwise.

Annex K (normative)

Annex K

V 07 (2026-04-10)

Editor : *This normative Annex is intended to provide generic requirements and assessment criteria for the use of state -of- the- art cryptography to be used in the context of Vertical Standards for the CRA as common framework.*

The current approach is intended to allow for two approaches in the requirements

i)ENISA ACM catalogue (i.e. concrete Crypto whitelist)

ii) evidence to be provided for the use of further crypto- appropriateness as State-of-the Art

e.g. by referencing in the required documentation

- publicly available national crypto catalogues or

- publications of use case specific or sector specific crypto- algorithm or catalogues

*Case (i) :Annex K seems expected by the EC to provide a reference to an explicit list of state -of-the-art algorithms **publishedby ECCG**as an accredited body*

Case (ii) For provision of conformity vertical standards are additionally expected to have clearly explicitly list any additional algorithms they use, including references to a published catalogue or standard issued by a recognized body.”.

- The Footnotes are Editors Notes only designed for integration into the main text of the Vertical Standards as provided for input e.g. for the Terms & Definition, Normative References or Bibliography or as additional explanation , not to be integrated in the final version

D.1 K.1 State of the Art Cryptography (CRY-SOTA)

D.1.1 K.1.1 Requirement

The default configuration for each security mechanism supported by the product shall use (*one or more*) public available cryptographic algorithms[1][GM1] , which are

(i) listed in the ECCG Agreed Cryptographic Mechanism (ACM) catalogue[1] classified as [CRY-SOTA-listed] **or**[GM2]

(ii) suitable and feasible for the corresponding use case, classified as [CRY-SOTA-unlisted]

[1] ENISA European Cybersecurity Certification Group: “Agreed Cryptographic Mechanisms, vers 2.0” (ACM) [2]

NOTE 1: The use of *security mechanism as for example*

integrity, authentication, access control, secure communication, secure storage and secure update are described in the main text of this standard.

NOTE 2 Supporting evidence options for (ii) [CRY-SOTA unlisted], that an algorithm, which is suitable and feasible for the respective use case, is listed in the related assessment criteria (K.1.2.1) clause.

[1] cryptographic algorithm

-sequence of instructions based on mathematical properties to protect confidentiality, integrity or authenticity against attacks.

Note: Cryptographic algorithms describe cryptographic protocols/schemes/constructors/atomic primitives such as TLS/ Symmetric Entity Authentication Schemes/AES-128 as part of a CMAC/AES-256

[2] The ACM document (ECCG) is available at the ECCG cryptography page at the below link:

— https://certification.enisa.europa.eu/document/download/a845662b-ae0-484e-9191-890c4cfa7aaa_en?filename=ECCG%20Agreed%20Cryptographic%20Mechanisms%20version%202.pdf

ECCG cryptography page: https://certification.enisa.europa.eu/publications/eucc-guidelines-cryptography_en

[GM1] Editor : "reachable over an external interface" is deleted according to TF decision

[GM2] *deleted* :

The product shall, by default, use State-of-the-Art cryptography algorithms listed in (CRY-SOTA), to be used for the supported security mechanism of the product where applicable.

CR007 and CR008 Solved by Substitution of "possible and" or "applicable "and" by or and changing the place of i) and ii))

[GM1] See CR 008 to avoid the term "applicable " and CR 007 NCSC-01

D.1.2 K.1.2 Assessment criteria

K.1.2.1 Assessment objective:

The purpose of this assessment case is to check whether the implemented algorithms for the default configuration are appropriately identified as CRY SOTA, (see (K 1.1 (i[GM1]))

K.1.2.1.1 Assessment preparation:

Preconditions for the assessment : If the product has a default configuration, then the default configuration shall be used for the assessment. Otherwise, the delivery state configuration shall be used (i.e. the configuration when the product is made available on the market in accordance with CRA Annex I part 1(2) (b[GM2]).

K.1.2.1.2 Assessment activities:

- For every security mechanism the list of all used algorithms[GM3] , shall be documented with evidence to be provided , if they are identified as CRY- SOTA.

Supporting Evidence:

- Documentation includes default configuration description (in accordance with K.1.2.1.2) with references to algorithm listed in (ACM)

Assignment of verdict:

- The verdict PASS shall be assigned if evidence has been provided.
- The verdict FAIL shall be assigned otherwise

NOTE 3: Functional correctness and completeness assessment criteria of the documentation can be specified in accordance with the capabilities set in the specific Vertical Standards[GM4] .

[GM1]according SAR 07 (ed)

[GM2]ed: see CR011, NXP.11

[GM3]deleted that are reachable over an external interface in accordance to NCS 04

[GM4] Editor comment : "are to" is replaced by " can"

K.1.2.2 Assessment objective:

The purpose of this assessment case is to check that evidence is provided in the documentation that a suitable and feasible algorithm has been implemented. (see K1.1 (ii))

K.1.2.2.1 Assessment preparation:

- Preconditions for the test: If the product has a default configuration, then the default configuration shall be used for the assessment. Otherwise, the delivery state configuration shall be used (i.e. the configuration when the product is made available on the market in accordance with CRA Annex I part 1(2) (b).

K.1.2.2.2 Assessment activities:

For every security mechanism and for every used algorithm[GM1] , and identified as not included in CRY- SOTA, the documentation shall provide evidence

- that this algorithm is suitable and feasible for the respective use case

Supporting Evidence:

- a) Identification of the certain algorithm by reference to publicly available referenced algorithm catalogues or publications issued by a recognized body and stable for the last two years as[GM2] for example
- b) [1] or

- c) [2] or
- d) [GM3]
- e) [GM4] (2.5) or[GM5]
- f) Supplemental verification , not sufficient for their own[GM6] : no entry of known exploitable vulnerabilities provided in ENISA “European Vulnerability Database”[3] and the Single Reporting Platform (SRP) established for the CRA[4][GM7]

Assignment of verdict:

- The verdict PASS shall be assigned if respective evidence has been provided,
- The verdict FAIL shall be assigned otherwise.

EXAMPLE 1: As example for a national cryptographic algorithm catalogue can serve

- A national published Crypto Catalog by the NCCAs[5] [GM8] or a national public available crypto algorithm catalogue referenced in the ACM, e.g.
 - BSI – BSI TR-02102-1, Cryptographic Mechanisms: Recommendations and Key Lengths, Vers. 2026-01, January 31, 2026

EXAMPLE 2: As examples for a use case sector specific public available cryptographic algorithm catalogue can serve

- [a] European Payments Council EPC342-08: "Guidelines on cryptographic algorithms usage and key management".
- [b] ETSI TS 119 312: "Electronic Signatures and Trust Infrastructures (ESI); Cryptographic Suites".
- [c] 3GPP TS 33.210: “3rd Generation Partnership Project; Technical Specification Group Services and System Aspects; Network Domain Security (NDS); IP network layer security

EXAMPLE 3: As examples for a use case Industry specific public available cryptographic algorithm catalogue can serve

- QARMA-128 with a 256-bit key and AES-128-XEX with two independent 128-bit keys used e.g. in ARM Confidential Compute Architecture (CCA) Security Model, Section 12.3.3

NOTE 4 : Further Vertical Standard -specific evidence for the appropriateness of the used cryptography can be added by the respective Vertical Standard[GM9] in the main text e.g. *description and formal verification or cryptographic security proof or security analysis of a new algorithm*[GM10] [GM11]

NOTE 5: Formal verification can use mathematical proofs or rigorous methods to prove an algorithm's correctness, ensuring it meets its formal specification for all valid inputs, unlike testing which only samples cases[GM12] .

[1] e.g. BSI – BSI TR-02102-1, Cryptographic Mechanisms: Recommendations and Key Lengths , Vers. 2026-01, January 31, 2026

[2] e.g. EPC342-08 /Version 15.0 /Guidelines on cryptographic algorithms usage and key management - PPSSG / 7 March 2025

In addition to general cryptographic catalogues, certain industry sectors maintain their own specialized algorithm catalogues optimized for specific threat models, hardware and/or software architectures or performance constraints. These vertical use-case specific cryptographic algorithm catalogues may serve as supporting evidence when they explicitly recognize algorithms as suitable for the intended use case, *e.g. the ARM Confidential Compute Architecture (CCA) Security Model, Section 12.3.3 ("Memory Encryption")*, recommends specific algorithms for memory protection in dedicated hardware environments, including: QARMA-128 with a 256-bit key and AES-128-XX with two independent 128-bit keys

[3] European Vulnerability Database established pursuant

to Article 12(2) of Directive (EU) 2022/2555, <https://euvd.enisa.europa.eu/ENISA>

[4] SRP = , Single Reporting Platform CRA

<https://www.enisa.europa.eu/topics/product-security-and-certification/single-reporting-platform-srp>

[5] NCCA = [National Cybersecurity Certification Authorities](#)

[GM1] deleted : "reachable over an interface of the product"

Reason CR007- NCS C-04

[GM2] added according EC(06) :

- (2)it is stable for at least two years;

[GM3] added according ARGE comment , see CR 046 /047

[GM4] further refined as required by SAR , due to the CRA act and Guidelines Draft on Complex systems (2.5)

[GM5] non replaceable deleted according to Renesas oral comment

[GM6]Due to acceptance of EC 06 (4)

[GM7] due to acceptance of EC comment 07 added added

[GM8]editorial

[GM9] To reach presumption of conformity additional Vertical specific means may be added

[GM10] Comment Qualcomm 2 postponed , Example to be added for methodology

[GM11] to be discussed if NOTE 4 can be deleted or modified , overlap with 1 d)

[GM12]SAR 12 : last sentence deleted

D.2 K.2. Crypto agility

D.2.1 K.2.1 Requirement

Where a security mechanism supported by the product uses in[GM1] its the default configuration a cryptographic algorithm that is

(i) listed in the CRY-SOTA catalogue or

(ii) referenced in a crypto catalogue within the context of K.1.1.(ii) in accordance to the Cyber Resilience Act (CRA)

and that algorithm is expected to be deprecated within the intended lifetime of the product, the product shall provide a mechanism for updating the cryptographic algorithm or deprecating its usage.

EXAMPLE 4 : Hybridization serves as a strategy to mitigate the case of deprecation, For instance , if within a secure storage mechanism, it can involve combination classical asymmetric cryptographic algorithms with quantum.resistant algorithm through dual encapsulation. This approach ensures data confidentiality data over a specific future time horizon , assuming that at least one of the employed algorithm remains uncompromised during this period[GM2]

NOTE 6: To maintain SOTA for cryptographic algorithm within the intended lifetime of the product concepts to consider are crypto agility additional to the capability of updating cryptographic algorithms on the product in accordance to Secure Update and Secure Communication mechanism.

NOTE 7: The [ACM] listing consist of wo classes of SOTA algorithms; **Legacy mechanisms** with an expiry date as defined in ACM, and **Recommended mechanisms** with no set expiry date.

NOTE 8 : For products that[GM3] cannot have their cryptographic algorithms updated for example if the implementation or part uses a hardware-based root of trust, it is important to check if the intended lifetime of the equipment does not exceed the recommended usage lifetime of their cryptographic algorithms state[GM4] . Thereby the implementation of an algorithm can include the specific implementation of their parameters e.g. their key length.

NOTE 9: If a component storing the algorithm or corresponding parameters of a main product is replaced by a new component, the product is considered as a new product according to the New Legislative Framework Blue Guide, if the replacement provides a substantial modification to the main product

[GM1]ed changed acc. SAR 11

[GM2]Example 4 added due to EC 08 , updated ed . in r2

[GM3] REN 02 Exception a) accepted in principle

Exception is met by deleting " or components " , to meet the case , where any upgraded protocol is supported in software

[GM4] Editor comment : added in NOTE 8

- Substitute "that " by "to check if" to meet the case " b) of Exception REN 02.

D.2.2 K.2.2 Assessment criteria

K.2.2.1 Assessment objective:

The purpose of this assessment case is (the conceptual assessment) whether the product is prepared to update cryptographic algorithms for the supported security mechanism.

K.2.2.1.1 Assessment preparation:

- Preconditions for the test: If the product has a default configuration, then the default configuration shall be used for the assessment. Otherwise, the delivery state configuration shall be used (i.e. the configuration when the product is made available on the market in accordance with CRA Annex I part 1(2) (b).

K.2.2.1.2 Assessment activities:

- For every used algorithm, the life span of the algorithm[GM1] is documented, as well its property, in case of SOTA and if otherwise available, if the algorithm is considered as legacy or recommended algorithm.[1]
- If the life span of the product exceeds the life span of a legacy algorithm, the algorithm is marked as updatable by a recommended algorithm in the documentation.
- If an algorithm is identified as recommended in the documentation , no further action is required respective the update of the specific algorithm[GM2] .

K.2.2.1.3 Supporting Evidence:

- Description /documentation of the performed test.
- All test records of the performed test.

K.2.2.1.4 Assignment of verdict:

- The verdict PASS shall be assigned if respective evidence has been provided,
- The verdict FAIL shall be assigned otherwise.

[1] defined in [ACM]

[GM1] enhanced as well for K1 (ii) algorithm according CR007NCS C-08

[GM2] due to acceptance of EC 10 added: § respective the update of the specific algorithm.

Bibliography

- [1] prEN 40000-1-2, *Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience*
- [2] EN IEC 62443-4-1:2018/prAA:2026, *Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements*
- [3] prEN 40000-1-3, *Cybersecurity requirements for products with digital elements - Part 1-3: Vulnerability Handling*
- [4] ISO 21745:2019, *Electronic record books for ships — Technical specifications and operational requirements*
- [5] ISO/TS 23565:2021, *Biotechnology — Bioprocessing — General requirements and considerations for equipment systems used in the manufacturing of cells for therapeutic use*
- [6] EN 18031-1:2024, *Common security requirements for radio equipment - Part 1: Internet connected radio equipment*
- [7] NIST SP 800-63B, *Digital Identity Guidelines - Authentication and Lifecycle Management*
- [8] ISO/IEC 27555:2021, *Information security, cybersecurity and privacy protection — Guidelines on personally identifiable information deletion*